US CLOUD Act & Deutsche Datensouveränität

Rechtliche Analyse · Anbieterbewertung · Globale Strategien · DSGVO-Handlungsempfehlungen

Autor: Björn Degenkolbe, Geschäftsführer · 4K Analytics GmbH / HIGL – Health Innovators Group Leipzig

Stand: April 2026

Version: 22.0 — April 2026 · 210 Quellen · 19 Kapitel

Zweck: Wissensgrundlage für GKV (Gesetzliche Krankenversicherung)/KV (Kassenärztliche Vereinigung)/Klinik-IT-Beratung, LinkedIn-Content, interne Architekturentscheidungen

Hinweis: Dieses Dokument basiert auf öffentlich verfügbaren Quellen, wurde mit Claude (Anthropic) erstellt und stellt keine Rechtsberatung dar.

1. Das Kernproblem: Gesundheitsdaten unter US-Zugriff

1.1 Die Regelungslücke zwischen IT-Sicherheit und Jurisdiktion

> ***Wer ist betroffen?*** *Dieses Dokument adressiert alle Institutionen der Gesundheitswirtschaft, die Patientendaten verarbeiten — nachfolgend einheitlich* ***"Gesundheitsinstitutionen"*** *genannt. Das umfasst:*
>
> - ***Kostenträger:*** *Gesetzliche Krankenversicherungen (GKV), Private Krankenversicherungen (PKV), Berufsgenossenschaften (BG), Unfallkassen*
> - ***Kassenärztliche und -zahnärztliche Vereinigungen (KV/KZV)*** *sowie deren Bundesvereinigungen (KBV, KZBV)*
> - ***Stationäre Leistungserbringer:*** *Krankenhäuser, Universitätsklinika, Rehabilitationskliniken, Pflegeheime*
> - ***Ambulante Leistungserbringer:*** *Arzt- und Zahnarztpraxen, Praxisverbünde, MVZ (Medizinische Versorgungszentren)*
> - ***Weitere Leistungserbringer:*** *Apotheken, Physiotherapiepraxen, Hebammen, Rettungsdienste, Pflegedienste*
> - ***Medizinischer Dienst (MD/MDK):*** *Gutachter- und Prüforganisation der GKV*
> - ***Praxisverwaltungssysteme und KIS-Hersteller*** *als Auftragsverarbeiter der o.g. Institutionen*
>
> *Alle genannten Institutionen unterliegen § 393 SGB V und DSGVO Art. 9 bei der Cloud-Verarbeitung von Gesundheitsdaten.*

Gesundheitsinstitutionen verarbeiten Patientendaten heute auf einem breiten Spektrum von Infrastrukturen: eigene Rechenzentren und On-Premise-Systeme, spezialisierte Gesundheits-IT-Dienstleister mit eigenen RZ (wie EWERK, Arvato Health, Telekom Healthcare), EU-souveräne Cloud-Anbieter (plusserver, STACKIT) — und zunehmend auf Cloud-Infrastruktur US-amerikanischer Hyperscaler wie Microsoft Azure, AWS und Google Cloud. Genau dieser letzte Trend offenbart eine Regelungslücke: Zwei Rechtsnormen regeln unterschiedliche Aspekte derselben Cloud-Nutzung — aber keine von beiden deckt das vollständige Risiko ab.

Norm	Anforderung	Status
DSGVO Art. 9 Abs. 1	Gesundheitsdaten = besondere Kategorie. Verarbeitung grundsätzlich verboten außer expliziter Rechtsgrundlage. Höchste Schutzkategorie im EU-Recht.	[!] Verletzt durch US-Zugriff
DSGVO Art. 48	Datentransfer an ausländische Behörden nur über anerkannte Rechtshilfemechanismen — nicht durch einseitige US-Gesetze.	[!] Verletzt durch CLOUD Act

Norm	Anforderung	Status
§ 393 SGB V (Juli 2024)	Cloud-Nutzung durch KVen/GKVen erlaubt, wenn BSI-C5-Typ2-Testat vorhanden (BSI = Bundesamt für Sicherheit in der Informationstechnik). Azure hat C5. Formell compliant.	[OK] Formell erfüllt
BSI C5-Testat (Cloud Computing Compliance Criteria Catalogue)	Prüft Informationssicherheit und technische Maßnahmen. Prüft **nicht**, ob US-Behörden rechtlich zugreifen können. C5:2026 (April 2026, 168 Kriterien) schließt diese Lücke nicht — das BSI plant Souveränitätskriterien als separates Dokument.	[!] Lücke: kein Rechtsschutz

§ 393 SGB V und DSGVO Art. 48 widersprechen sich nicht — sie regeln unterschiedliche Fragen. § 393 SGB V ist eine sozialrechtliche Erlaubnisnorm: Sie erlaubt die Cloud-Verarbeitung von Gesundheitsdaten unter der Bedingung, dass ein BSI C5 Typ 2 Testat die IT-Sicherheit nachweist. Das ist ihr Regelungsgegenstand — und das ist auch der richtige Ort dafür. Die Frage, ob ein Anbieter unter US-Jurisdiktion steht und von einem US-Gericht zur Datenherausgabe gezwungen werden kann, ist hingegen keine Frage der IT-Sicherheit. Sie gehört nicht in § 393 SGB V — sie gehört in die DSGVO und ins internationale Recht. DSGVO Art. 48 beantwortet diese Frage klar: Datentransfer an ausländische Behörden nur über anerkannte Rechtshilfemechanismen. Das BSI C5 Testat prüft Informationssicherheit, nicht Jurisdiktion. Es kann einem US-Anbieter technische Sicherheit attestieren, obwohl US-Bundesbehörden diesen Anbieter per CLOUD Act zur Datenweitergabe verpflichten können — das BSI-Testat ändert daran nichts, weil es dafür nicht gemacht ist.

Die Lücke liegt nicht im Gesetz, sondern im Verständnis: § 393 SGB V wird in der Beschaffungspraxis häufig als ausreichender Compliance-Nachweis missverstanden. Aber § 393 entbindet nicht von der DSGVO. Jede Gesundheitsinstitution bleibt unabhängig vom C5-Testat verpflichtet, die DSGVO einzuhalten — einschließlich Art. 48. Ein C5-konformer Anbieter, der dem CLOUD Act unterliegt, erfüllt § 393 SGB V. Er löst aber nicht die DSGVO-Pflicht ein. Wenn US-Behörden tatsächlich auf Gesundheitsdaten zugreifen, ist das ein meldepflichtiger Datenschutzvorfall nach Art. 33 DSGVO — unabhängig davon, ob § 393 eingehalten wurde, und unabhängig davon, ob die Organisation davon erfährt.

Keine Norm verlangt heute, die CLOUD-Act-Exposition eines Anbieters als Kriterium neben dem C5-Testat in Ausschreibungen zu prüfen. C5 ist Pflicht. Eine Jurisdiktionsprüfung ist es nicht. Also wird sie in Vergabeverfahren regelmäßig weggelassen — nicht aus bösem Willen, sondern weil die DSGVO-Pflicht neben § 393 SGB V unsichtbar bleibt. Das Ergebnis: Eine Organisation kann § 393 SGB V vollständig einhalten, ein gültiges C5-Testat vorlegen und gleichzeitig ein latentes DSGVO-Risiko tragen, das bei einem US-Behördenzugriff schlagartig zum Datenschutzvorfall wird.

Microsoft hat das in einer offiziellen Anhörung vor dem französischen Senat (Juni 2025) selbst bestätigt: **Eine Garantie, dass keine Daten an US-Behörden weitergegeben werden, ist nicht möglich.**

Was das konkret bedeutet — dokumentierte Beispiele:

Das ist kein hypothetisches Szenario. Es gibt mehrere belegte Fälle, in denen die USA europäische Staatsbürger auf Sanktionslisten gesetzt haben — nicht wegen Straftaten, sondern wegen politischer Konflikte.

Fall 1 — Nord Stream 2 (2019/2020): Die USA haben unter dem PEESCA-Gesetz (Protecting Europe's Energy Security Act) Sanktionen gegen Unternehmen und einzelne Mitarbeiter verhängt, die am Bau der Gaspipeline Nord Stream 2 beteiligt waren — einem legalen europäischen Infrastrukturprojekt. Betroffen waren unter anderem die Nord Stream 2 AG mit Sitz in der Schweiz, das niederländische Verlegeschiff-Unternehmen Allseas und namentlich benannte Führungskräfte und Mitarbeiter, darunter deutsche Staatsbürger. Diese Personen standen auf der SDN-Liste des Office of Foreign Assets Control (OFAC) — der zentralen US-Sanktionsliste.

Fall 2 — HateAid (Dezember 2025): Am 23. Dezember 2025 setzte US-Außenminister Marco Rubio die beiden Geschäftsführerinnen der deutschen gemeinnützigen Organisation HateAid — Josephine Ballon und Anna-Lena von Hodenberg — auf die US-Sanktionsliste. HateAid unterstützt Opfer von Hass und Gewalt im Internet und

setzt sich für die Durchsetzung europäischen Rechts auf US-Plattformen ein, insbesondere des Digital Services Act. Die USA stuften sie als "radical activists" und ihre Organisation als "weaponized NGO" ein. Gleichzeitig wurden der ehemalige EU-Kommissar Thierry Breton sowie Vertreter britischer Anti-Desinformations-Organisationen sanktioniert. Die Bundesregierung verurteilte die Maßnahme; Bundestags-Vizepräsident Nouripour forderte die Einbestellung des US-Geschäftsträgers. [Quellen: HateAid Pressemitteilung, 14. Januar 2026; CNN, 24. Dezember 2025; The Local, 24. Dezember 2025]

Was bei den ICC-Richtern bereits geschehen ist: Der MIT Technology Review dokumentierte im Januar 2026, was Sanktionen in der Praxis bedeuten: Ein sanktionierter Richter des Internationalen Strafgerichtshofs verlor nach seiner Sanktionierung den Zugang zu Microsoft, Amazon, Gmail, Visa, Mastercard, American Express und PayPal — sein gesamtes digitales Leben wurde abgeschaltet. HateAid-Geschäftsführerin Ballon wird dazu zitiert: "If Microsoft does that to someone who is a lot more important than we are, they will not even blink to shut down the email accounts from some random human rights organization in Germany." [Quelle: MIT Technology Review, 19. Januar 2026]

In dem Moment, in dem eine Person auf der US-Sanktionsliste steht, ist jeder US-kontrollierte Anbieter rechtlich verpflichtet, sämtliche Daten zu dieser Person einzufrieren und auf Anfrage herauszugeben. Microsoft, AWS, Google, Oracle — sie haben keine Wahl. Ein Verstoß gegen US-Sanktionsrecht wird strafrechtlich verfolgt.

Wenn eine sanktionierte HateAid-Mitarbeiterin oder ein sanktionierter Nord-Stream-2-Ingenieur bei einer deutschen Krankenkasse versichert ist, deren Abrechnungsdaten auf Azure laufen, werden Diagnosen, Medikationspläne, Behandlungsverläufe und Arzt-Patienten-Kontakte automatisch Teil der Herausgabepflicht. Nicht weil diese Personen eine Straftat begangen haben, sondern weil die US-Regierung europäische Rechtsdurchsetzung als "Zensur" oder europäische Energiepolitik als Bedrohung eingestuft hat. Wenn ein Universitätsklinikum sein KIS bei Oracle Cerner betreibt, werden die klinischen Daten — Anamnese, Operationsberichte, psychiatrische Befunde — Teil der Herausgabepflicht. Die Kasse oder die Klinik erfährt davon in der Regel nicht, weil US-Recht eine Schweigeverpflichtung vorsehen kann.

Für die betroffene Gesundheitsinstitution ist das ein meldepflichtiger Datenschutzvorfall nach Art. 33 DSGVO — den sie nicht melden kann, weil sie nicht weiß, dass er stattgefunden hat. Und für den betroffenen Patienten ist es ein Eingriff in seine sensibelsten Grundrechte, gegen den er keinen Rechtsschutz vor US-Gerichten hat.

1.2 Warum es trotzdem passiert — sieben Realitätsgründe

1.2.1 Pragmatismus — Service-Tiefe und Ökosystem-Lock-in

EU-Anbieter können heute für GKV- und Klinik-Kernworkloads skalieren — die Kapazitätslücke ist nicht das Hauptproblem. Das eigentliche Hindernis ist die Service-Tiefe: AWS und Azure bieten je über 200 verwaltete Dienste (Managed Databases, Serverless, IoT/Edge, DevOps-Toolchains, Data Warehouse, globale CDN) — EU-Anbieter wie STACKIT bieten 40–60 Kernservices. Architekturen, die tief in AWS- oder Azure-Managed-Services eingebaut sind, lassen sich nicht einfach migrieren. Hinzu kommt das Ökosystem-Problem: Azure ist kein einzelner Dienst, sondern 15–20 integrierte Schichten — E-Mail, Identity, Collaboration, Datenbanken, KI. Wer alle ersetzt, baut neu. Wer nur einzelne ersetzt, hat hybride Komplexität. Details in Kapitel 7 und 8.

1.2.2 Kein Enforcement — dokumentiertes Vollzugsdefizit

Die DSK (Datenschutzkonferenz — Koordinierungsgremium aller 17 deutschen Datenschutzaufsichtsbehörden) hat Microsoft 365 zweimal als nicht DSGVO-konform eingestuft — 2020 und 2022. Kein einziges Bußgeld gegen eine Gesundheitsinstitution wegen US-Cloud-Nutzung ist öffentlich bekannt. Artikel91.eu fasste es 2021 präzise zusammen: "Viel Dialog, fast keine Sanktionen."

Das hat strukturelle Gründe: DSK-Beschlüsse sind nicht rechtsverbindlich, Prüfungen erfolgen nur anlassbezogen, und grenzüberschreitende Verfahren gegen US-Anbieter dauern Jahre. Das einzige nennenswerte deutsche GKV-Bußgeld — 1,2 Mio. EUR gegen die AOK Baden-Württemberg 2020 — betraf Gewinnspielmissbrauch, nicht Cloud-Datenschutz.

Das Vollzugsdefizit ist kein Freifahrtschein. Bei einem Schrems-III-Urteil des EuGH (Europäischer Gerichtshof, Luxemburg) würde sich das Enforcement-Bild schlagartig ändern — mit sofortigem Handlungsdruck für alle Organisationen, die dann noch auf US-Cloud setzen.

1.2.3 Legislative Umgehung — § 393 SGB V als Kompromissnorm

§ 393 SGB V (in Kraft seit 1. Juli 2024 durch das Digital-Gesetz / DigiG) erlaubt die Cloud-Verarbeitung von Gesundheitsdaten unter drei Bedingungen: EU-Rechtsraum, BSI C5 Typ 2 Testat und Umsetzung kundenseitiger Sicherheitsmaßnahmen. Die Norm ist ein politischer Kompromiss, kein datenschutzrechtliches Konzept. Drei strukturelle Schwächen:

Erstens — CLOUD Act bleibt unberührt: § 393 SGB V adressiert ausschließlich die Frage, *ob* Gesundheitsdaten in einer Cloud verarbeitet werden dürfen. Die Frage, ob ein US-Anbieter diese Daten auf Anfrage einer US-Behörde herausgeben muss, regelt § 393 SGB V nicht. Das C5-Testat prüft Informationssicherheit, nicht Jurisdiktion. Ein AWS- oder Azure-Rechenzentrum in Frankfurt mit gültigem C5-Testat ist § 393-konform — und gleichzeitig CLOUD-Act-exponiert.

Zweitens — DPF als Lückenbüßer: Die zulässige Nutzung von US-Cloud-Diensten stützt sich auf das Data Privacy Framework (DPF) als Angemessenheitsbeschluss. Das DPF hängt an einer US-Präsidialverordnung, nicht an einem Gesetz. Schrems II (2020) hat das identische Vorgängermodell gekippt. Ein Schrems-III-Verfahren ist bei noyb (None of Your Business — europäische Datenschutz-NGO von Max Schrems) bereits anhängig.

Drittens — C5 als regulatorische Mindestanforderung, nicht als Souveränitätsnachweis: Der Gesetzgeber hat mit § 393 SGB V BSI C5 als Pflichtstandard eingeführt, weil er verfügbar und praxistauglich ist — nicht weil er vor US-Behördenzugriff schützt. Auch der am 7. April 2026 veröffentlichte C5:2026 (168 Kriterien, Nachfolger des C5:2020) ändert daran nichts: Das BSI hat Souveränitätskriterien bewusst als separates Dokument angekündigt, das "in Kürze" erscheinen soll [188]. C5 zertifiziert Informationssicherheit, nicht Datensouveränität im geopolitischen Sinne.

1.2.4 Struktureller Interessenkonflikt bei Beratern

Die IT-Strategie- und Digitalisierungsberatung für Gesundheitsinstitutionen wird überwiegend von US-amerikanischen Beratungshäusern erbracht — Deloitte, EY, McKinsey, PwC, KPMG, Accenture — die ihrerseits tiefe kommerzielle Partnerschaften mit denselben US-Hyperscalern unterhalten, die sie empfehlen könnten. Accenture und Microsoft betreiben gemeinsam Avanade (50.000 Mitarbeitende, ausschließlich Microsoft-Implementierung). McKinsey hat die Amazon McKinsey Group (AMG) für AWS-Migrationen gegründet. KPMG hat 2 Milliarden Dollar über fünf Jahre in die Microsoft-Partnerschaft investiert. McKinsey, BCG, Accenture und Capgemini sind Gründungspartner von OpenAIs Frontier Alliance mit Vorabzugang zu GPT-Modellen. Wer die Strategie entwirft, verdient an der Umsetzung — und erhält Partnerprovisionen vom Cloud-Anbieter, den er empfiehlt. Ausführlich dokumentiert in Kapitel 12.

1.2.5 Aktiver Vertrieb der Hyperscaler

Microsoft, AWS und Google betreiben in Deutschland dedizierte Public-Sector- und Healthcare-Vertriebsteams, die aktiv auf Gesundheitsinstitutionen zugehen — mit maßgeschneiderten Angeboten, Förderbudgets, KHZG-Beratung (KHZG = Krankenhauszukunftsgesetz, Digitalisierungsförderung) und kostenloser Proof-of-Concept-Infrastruktur. EU-souveräne Alternativen wie STACKIT, plusserver (deutscher Cloud-Anbieter, Tochter der Ionos Group SE) oder EWERK verfügen über deutlich kleinere Vertriebsorganisationen und sind in Beschaffungsprozessen häufig nicht vertreten, wenn Anforderungen formuliert werden. Wer nicht im Raum ist, wenn die Ausschreibung entsteht, wird selten berücksichtigt.

1.2.6 Sovereignty Washing — irreführendes Marketing als Beschaffungstreiber

Microsoft, AWS, Google und Oracle vermarkten aktiv Produkte unter den Bezeichnungen "Sovereign Cloud", "EU Data Boundary", "Isolated Realm" oder "European Sovereign Cloud" — und suggerieren eine Datensouveränität, die rechtlich nicht besteht. Das ist nicht nur ungenau, sondern irreführend im Sinne wettbewerbsrechtlicher Maßstäbe: Ein Anbieter, der "souverän" vermarktet, obwohl er als US-Unternehmen dem CLOUD Act unterliegt und das — wie Microsoft vor dem französischen Senat — selbst bestätigt hat,

erzeugt bei der einkaufenden Institution einen Vertrauensschutz, der juristisch nicht existiert.

Das C5-Testat verstärkt diesen Effekt. Es ist ein Informationssicherheitsnachweis — kein Souveränitätsnachweis. Aber in Kombination mit der Marketingbezeichnung "Sovereign Cloud" entsteht in der Beschaffungspraxis der Eindruck, die Souveränitätsfrage sei gelöst. "Daten in Deutschland" plus "C5-zertifiziert" plus "Sovereign Cloud" klingt nach dreifacher Absicherung — tatsächlich adressiert keine der drei Komponenten die Jurisdiktionsfrage.

Für die Haftungsbewertung ist das relevant: Eine Gesundheitsinstitution, die sich auf die "Sovereign Cloud"-Vermarktung eines US-Anbieters verlassen hat, ohne eine eigene Jurisdiktionsprüfung durchzuführen, kann sich im Schadensfall nicht auf das Marketing des Anbieters berufen. Die DSGVO-Verantwortung liegt beim Verantwortlichen — nicht beim Anbieter, der seine Produkte geschickt benennt. 25 CEOs europäischer Cloud-Anbieter haben in einem offenen Brief an die EU-Kommission (CISPE, 17. März 2026) genau dieses Phänomen als irreführend kritisiert. Ausführlich dokumentiert in §5.5 und §5.6.

1.2.7 Politische Einflussnahme der Hyperscaler

Big Tech gibt 19-mal mehr für EU-Lobbyarbeit aus als die Automobilindustrie. 890 Digital-Lobbyisten arbeiten Vollzeit in Brüssel — mehr als Sitze im Europäischen Parlament. Das Google-Lobbypapier vom August 2025 zur Einschränkung des DSGVO-Auskunftsrechts wurde wortgleich in den Digital-Omnibus-Entwurf der EU-Kommission übernommen. Datenschutz gilt — aber seine Weiterentwicklung und Durchsetzung wird durch diese Finanzasymmetrie systematisch gebremst. Ausführlich dokumentiert in Kapitel 11.

2. Rechtliche Grundlagen: Was der CLOUD Act wirklich sagt

2.1 Gesetzestext und Geltungsbereich

Der Clarifying Lawful Overseas Use of Data Act (CLOUD Act) wurde am 23. März 2018 als Teil des Consolidated Appropriations Act (Public Law 115-141) verabschiedet.

> ***"The CLOUD Act applies to all electronic communication service or remote computing service providers that operate or have a legal presence in the U.S."***
>
> *— 18 U.S.C. § 2713*

Das Gesetz gilt **nicht nur für US-Unternehmen**. Es gilt für jeden Anbieter mit rechtlicher Präsenz in den USA — unabhängig vom Hauptsitz, unabhängig vom Serverstandort.

2.2 Wer ist betroffen — und wie vererbt sich die Pflicht?

Es gibt zwei grundlegende Konstellationen, die sich in ihrer Risikostruktur unterscheiden:

Konstellation A: US-Mutter → EU-Tochter

Die klassische Konstellation bei AWS, Azure, Google. Die Herausgabepflicht fließt von der US-Mutter auf alle Töchter weltweit. Kein Widerspruch möglich. Selbst wenn die EU-Tochter eigenständig agiert: die US-Mutter ist zur Herausgabe verpflichtet.

Konstellation B: EU-Mutter mit US-Tochter (der Hetzner-Fall)

Hier ist die Richtung umgekehrt. Ein EU-Unternehmen mit US-Tochtergesellschaft kann einer CLOUD-Act-Anfrage zunächst widersprechen und sich auf DSGVO Art. 48 berufen. Aber: US-Behörden können die US-Tochter als Druckmittel nutzen — Lizenzentzug, Betriebsaussetzung, Geldstrafen — um die EU-Mutter zur Kooperation zu bewegen. Das ist kein theoretisches Risiko, sondern dokumentierte Behördenpraxis.

Konstellation C: EU-Schwestergesellschaft mit US-Präsenz (der STACKIT-Fall)

Wenn Schwestergesellschaften gesellschaftsrechtlich getrennt sind, aber unter demselben Privateigentümer — wie bei der Schwarz Gruppe (STACKIT als Schwester von Lidl US) — ist die CLOUD-Act-Exposition juristisch unklar. STACKIT behauptet aktiv und öffentlich CLOUD-Act-Freiheit und verzichtet bewusst auf US-Investitionen, um genau diese Angreifbarkeit zu vermeiden.

2.3 Die 25%-Schwellen-Argumentation

Laut Gutachten des Wissenschaftlichen Dienstes des Bundestags (WD 3-105-23, 2024) wird in der Literatur argumentiert, dass US-Gerichte Kontrolle im Sinne des CLOUD Act bereits annehmen könnten, wenn eine Tochtergesellschaft nur zu 25 Prozent im Eigentum eines US-amerikanischen Unternehmens steht. Das ist keine gesicherte Rechtsposition, zeigt aber den potentiellen Anwendungsbereich.

3. Die vier US-Zugriffsebenen im Detail

Es gibt nicht einen, sondern **vier rechtlich verschiedene Wege** für US-Behörden auf Daten zuzugreifen, die bei US-kontrollierten Anbietern liegen. Sie unterscheiden sich erheblich in Voraussetzungen, Hürden und Relevanz für Gesundheitsdaten:

Rechtsgrundlage	Akteur	Voraussetzungen	Hürde	Relevanz Health
CLOUD Act (18 U.S.C. § 2713)	FBI, DOJ	Richterlicher Herausgabebeschluss + hinreichender Verdacht auf konkrete Straftat	Mittel	Strafermittlungen gegen Personen/Institutionen
FISA § 702 (Foreign Intelligence Surveillance Act — US-Gesetz zur nachrichtendienstlichen Massenüberwachung)	NSA, CIA, FBI	Keine Einzelfallprüfung. Pauschale Jahreszertifizierung durch geheimen FISC. RISAA 2024 (Reforming Intelligence and Securing America Act) erweiterte Anbieter-Definition massiv. Auslaufdatum: **20. April 2026** — Verlängerung zum Redaktionsschluss offen.	Niedrig	Systematische Erfassung — betrifft potenziell alle US-Server-Daten
National Security Letter	FBI	Kein Richter. Kein Verdacht. Schweigegebot für Anbieter. Gilt für Metadaten.	Minimal	Metadaten über Arzt-Patienten-Kontakte, Verbindungsdaten
Grenzkontrolle (Grenzkontrollen-Ausnahme)	CBP	Kein Herausgabebeschluss. Kein Verdacht. Physisches Gerät an US-Grenze.	Null	Relevant für Mitarbeitergeräte bei US-Dienstreisen

3.1 CLOUD Act — Strafverfolgung mit richterlicher Kontrolle

Der CLOUD Act (18 U.S.C. § 2713, in Kraft seit März 2018) ist das bekannteste Instrument — aber nicht das gefährlichste. Er verpflichtet US-Provider zur Herausgabe von Daten, die sich "under the provider's possession, custody, or control" befinden, unabhängig vom Serverstandort.

Was ihn von den anderen Zugriffsebenen unterscheidet: Für Inhaltsdaten (E-Mails, Dateien, Kommunikationsinhalte) ist ein richterlicher Herausgabebeschluss erforderlich — mit hinreichendem Tatverdacht auf eine konkrete Straftat. Der Provider kann durch einen Widerspruch (motion to quash) widersprechen, wenn der Zugriff mit dem Recht des Landes kollidiert, in dem die Daten liegen. Ein US-Gericht entscheidet dann nach US-Maßstäben über den Konflikt — ein Verfahren, das strukturell die Interessen der USA priorisiert, aber immerhin juristisch anfechtbar ist.

Für Metadaten (Verbindungsdaten, IP-Adressen, Zeitstempel) genügt eine Gerichtsbeschluss mit abgesenkten Anforderungen — kein voller Herausgabebeschluss nötig. Für Abonnentendaten (Name, Adresse, Zahlungsdaten) reicht in vielen Fällen eine behördliche Auskunftsanordnung ohne Richterbeteiligung.

Relevanz für Gesundheitsdaten: Der CLOUD Act trifft typischerweise konkrete Strafverfolgungsszenarien — wenn eine Ermittlung gegen eine Person oder Institution läuft, die Daten bei einem US-Provider verwaltet. Für eine GKV mit 5 Millionen Versicherten, die Kernabrechnungsdaten bei Azure hostet, ist das Risiko: bei Ermittlungen gegen einen Leistungserbringer, Arzt oder Versicherten könnten umfangreiche Gesundheitsdaten im Rahmen der Ermittlung mit abgerufen werden, ohne dass die GKV davon erfährt.

Der Sanktionslisten-Automatismus: Besonders greifbar wird das Risiko bei US-Sanktions- und Terrorlisten. Wenn eine in Deutschland lebende Person oder eine politische Gruppierung auf eine solche Liste gesetzt wird

— etwa auf die Specially Designated Nationals (SDN)-Liste des Office of Foreign Assets Control (OFAC) —, sind alle US-kontrollierten Unternehmen unmittelbar und ohne weitere richterliche Anordnung verpflichtet, sämtliche Daten zu dieser Person einzufrieren und auf Anfrage herauszugeben. Das betrifft nicht nur Bankkonten und Finanzdaten, sondern alle Daten "under the provider's possession, custody, or control" — einschließlich Gesundheitsdaten in Cloud-Systemen. Microsoft, AWS, Google und Oracle können dem nicht widersprechen; ein Verstoß gegen US-Sanktionsrecht wird strafrechtlich verfolgt. Für die Gesundheitsinstitution, deren Daten betroffen sind, entsteht ein Datenschutzvorfall, von dem sie in der Regel nicht einmal erfährt.

Dass das keine Theorie ist, zeigen zwei dokumentierte Fälle: Die USA haben 2019/2020 unter dem PEESCA-Gesetz Sanktionen gegen europäische Unternehmen und namentlich benannte Mitarbeiter des Nord-Stream-2-Projekts verhängt — darunter deutsche Staatsbürger —, die an einem legalen europäischen Infrastrukturprojekt beteiligt waren. Im Dezember 2025 setzte US-Außenminister Rubio die beiden Geschäftsführerinnen der deutschen gemeinnützigen Organisation HateAid auf die Sanktionsliste — weil sie sich für die Durchsetzung des europäischen Digital Services Act auf US-Plattformen einsetzen. Bei sanktionierten ICC-Richtern wurde der Cloud-Zugang bereits abgeschaltet: Microsoft, Amazon, Gmail, Visa, Mastercard, PayPal — alles gesperrt. Die Einstufungskriterien lagen in allen Fällen ausschließlich bei US-Behörden — ohne europäische Beteiligung, ohne richterliche Prüfung, ohne Rechtsschutz für die Betroffenen.

3.2 FISA § 702 und RISAA 2024 — die unterschätzte Gefahr

FISA § 702 ist das strukturell riskanteste Instrument für Gesundheitsdaten — weil es keine Einzelfallprüfung erfordert und damit massenweise Daten erfassen kann.

Der Reforming Intelligence and Securing America Act (RISAA, April 2024) verlängerte FISA § 702 und **erweiterte gleichzeitig den Anbieter-Begriff massiv**. Für Gesundheitsdaten bedeutet das: Jedes US-Unternehmen, das Kommunikation oder Daten von Nicht-US-Bürgern verarbeitet, kann unter FISA § 702 zur Herausgabe verpflichtet werden — ohne richterliche Einzelfallprüfung, ohne Information der Betroffenen.

Wie FISA § 702 funktioniert: Statt eines Einzelfall-Herausgabebeschlusses genehmigt der geheime Foreign Intelligence Surveillance Court (FISC) einmal jährlich ein pauschales Überwachungsprogramm. Die NSA, CIA und das FBI können dann im Rahmen dieses Programms Daten von Nicht-US-Personen bei US-Providern abfragen — ohne dass der Provider im Einzelfall widersprechen könnte, ohne Benachrichtigung der Betroffenen, ohne nachträgliche gerichtliche Kontrolle für Nicht-US-Bürger.

RISAA 2024 — die stille Ausweitung: Die RISAA-Novelle erweiterte die Definition von "Electronic Communication Service Provider" drastisch: Nun können auch Unternehmen, die lediglich Zugang zu Netzwerkinfrastruktur haben — Rechenzentren, Server-Co-Location-Betreiber, Cloud-Infrastruktur — zur Herausgabe verpflichtet werden. Das EFF bezeichnete dies als "Make Everyone a Spy Bill". Für Gesundheits-IT bedeutet das: Auch Dienstleister, die nicht primär Kommunikationsdienste anbieten, aber US-kontrollierte Server betreiben, können erfasst sein.

Auslaufdatum 20. April 2026 (FISA-Auslaufdatum): FISA § 702 läuft ohne erneute Verlängerung aus. Zum Redaktionsschluss läuft die Verlängerungsdebatte — Trump unterstützt eine saubere Verlängerung ohne Reformen, eine Reform-Koalition (EFF, Brennan Center, 130+ Organisationen) fordert richterliche Genehmigungspflicht für US-Personen-Abfragen und Schließung des Datenhändler-Lückes. Ein Ablauf würde US-Behördenzugriff temporär blockieren, aber keine strukturelle DSGVO-Lösung schaffen.

3.3 National Security Letter — kein Richter, kein Verdacht, Schweigegebot

National Security Letters (NSL, 18 U.S.C. § 2709 und verwandte Statuten) sind behördliche Auskunftsanordnungen, die das FBI ohne richterliche Genehmigung und ohne Verdachtsnachweis ausstellen kann. Sie sind das am wenigsten diskutierte, aber operativ bedeutsame Instrument.

Was NSLs erfassen: Primär Metadaten — Verbindungsdaten, E-Mail-Header (nicht Inhalte), Abonnentendaten, IP-Adressen, Zeitstempel von Transaktionen. Für Gesundheitsdaten relevant: Wer hat wann mit welchem Arzt, welcher Klinik, welcher GKV kommuniziert? Welche IP-Adressen haben wann auf welche Gesundheitsportale

zugegriffen? Diese Metadaten können im Gesundheitskontext hochsensibel sein — sie erlauben Rückschlüsse auf Diagnosen, Behandlungen und Lebensumstände.

Das Schweigegebot (Schweigeverfügung): Provider, die einen NSL erhalten, dürfen die betroffene Person oder Institution in der Regel nicht informieren. Eine automatische, zeitlich unbegrenzte Geheimhaltungspflicht war der Standard — seit einem Urteil des Second Circuit (2013) können Provider dieses Schweigegebot gerichtlich anfechten, aber der Anfechtungsprozess ist langwierig und der Ausgang unsicher.

HIPAA-Schnittstelle: US-amerikanische Gesundheitsorganisationen (Krankenhäuser, Versicherungen, Pharmaanbieter) können unter der HIPAA National Security Exception ohne Gerichtsbeschluss Gesundheitsdaten an Bundesbehörden für Geheimdienstzwecke weitergeben — freiwillig, ohne Anfrage der Behörde, ohne Benachrichtigung der Patienten. Diese Exception ist für europäische GKV-Daten nicht direkt anwendbar — aber wenn ein US-Provider beteiligt ist, greift die NSL-Logik.

Praktische Bedeutung: Das FBI hat zwischen Dezember 2024 und November 2025 laut offiziellen Berichten 7.413 FISA-Abfragen von US-Personendaten durchgeführt — ein Anstieg von über einem Drittel gegenüber dem Vorjahreszeitraum. NSL-Zahlen werden weniger transparent veröffentlicht, liegen aber im Bereich von mehreren tausend pro Jahr.

3.4 CBP-Grenzkontrolle — physischer Gerätezugriff ohne Beschluss

Die Grenzkontrollen-Ausnahme (Grenzkontrollen-Ausnahme) ist der einzige Zugriffsweg, der keinerlei rechtliche Hürde kennt — kein Richter, kein Verdacht, keine Rechtfertigung. Sie betrifft Mitarbeitende mit Zugang zu sensiblen Gesundheitssystemen bei Reisen in die USA.

Rechtsgrundlage: US Customs and Border Protection (CBP) hat nach der Grenzkontrollen-Ausnahme das Recht, alle Geräte an US-Grenzen und internationalen Flughäfen ohne Herausgabebeschluss und ohne konkreten Verdacht zu durchsuchen. Grundlagendokument: CBP Directive No. 3340-049B.

Unterschied Basisdurchsuchung vs. Erweiterte Durchsuchung (Basic Search vs. Advanced Search):

- **Basisdurchsuchung** (Basic Search — manuelle Durchsicht): Ohne jeden Verdacht zulässig. Jedes Gericht bisher einig. 2024: über 42.000 Basisdurchsuchungen durchgeführt.
- **Erweiterte Durchsuchung** (Advanced Search — forensische Kopie des Geräteinhalts): CBP-Direktive verlangt hinreichenden Verdacht — aber die Umsetzung ist circuit-abhängig und uneinheitlich. Der 11. Circuit erlaubt Erweiterte Durchsuchungen ohne jede Begründung. Der 9. Circuit verlangt zumindest hinreichenden Verdacht. Kein bindender Supreme-Court-Entscheid bisher.

Aktuelle Entwicklung: Die Zahl warrantloser Gerätedurchsuchungen hat sich zwischen 2015 und 2024 mehr als verfünffacht — von ~8.500 auf über 47.000 jährlich. 2025 verzeichnet das dritte Quartal mit 14.899 Durchsuchungen einen absoluten Quartalsrekord. Eine Zivilklage (Pacific Legal Foundation, Dezember 2025) fordert ein Herausgabebeschluss-Erfordernis; der Fall ist beim D.C. District Court anhängig.

Relevanz für Gesundheits-IT-Personal: Mitarbeitende von Gesundheitsinstitutionen mit VPN-Zugängen, SSH-Keys oder App-Zugriffen auf Kernsysteme sind bei US-Dienstreisen exponiert. CBP kann physische Geräte beschlagnahmen, forensisch kopieren und den Inhalt an andere Bundesbehörden weitergeben — ohne dass die betroffene Person oder ihre Organisation zeitnah informiert wird. Die kopierten Daten bleiben bis zu 75 Tage in CBP-Systemen und können innerhalb der US-Bundesbehörden geteilt werden.

4. Europäischer Behördenzugriff: e-Evidence-VO, Five Eyes und die ethische Frage

4.1 Die blinde Seite der Souveränitätsdebatte

In der Diskussion um CLOUD Act und Datensouveränität wird eine naheliegende Gegenfrage oft nicht gestellt: **Was können europäische Behörden eigentlich?** Und: Warum sollte man nicht einfach darauf vertrauen, dass westliche Verbündete — NATO, Five Eyes, EU-Partner — ähnliche Sicherheitsinteressen teilen und damit ethisch akzeptabler sind als ein "Souveränitäts"-Denken, das Kooperation verhindert?

Die Antwort auf diese Frage ist differenziert — und für die Architekturentscheidung wichtiger als häufig angenommen.

4.2 Die e-Evidence-Verordnung — der europäische CLOUD Act

Die EU hat mit der Verordnung (EU) 2023/1543 ein Instrument geschaffen, das strukturell dem CLOUD Act ähnelt: **grenzüberschreitender Direktzugriff auf elektronische Daten ohne klassisches Rechtshilfeverfahren.** Ab 18. August 2026 verbindlich.

Das Instrumentarium:

- **EPOC (Europäische Herausgabeanordnung):** Strafverfolgungsbehörde eines EU-Mitgliedstaats fordert direkt bei einem Anbieter in einem anderen EU-Staat Daten an — Abonnentendaten, Verkehrsdaten, Inhaltsdaten. Keine vorherige Einschaltung der Justiz des Providerstaats erforderlich.
- **EPOC-PR (Sicherungsanordnung):** Sofortige Datensicherung, damit keine Daten gelöscht werden können.
- **Frist:** Zehn Tage im Normalfall, sechs bis acht Stunden im Notfall.
- **Sanktionen:** Bis zu 500.000 EUR oder 2% des weltweiten Jahresumsatzes bei Nichtbefolgung.
- **Reichweite:** Gilt auch für Anbieter aus Drittstaaten (USA, UK, Schweiz), sofern sie Dienste in der EU anbieten — diese müssen einen EU-Rechtsvertreter benennen.

Das klingt zunächst symmetrisch zum CLOUD Act. Aber es gibt fundamentale strukturelle Unterschiede.

4.3 Der strukturelle Vergleich: CLOUD Act vs. e-Evidence-VO

Dimension	US CLOUD Act	EU e-Evidence-VO
Anknüpfungspunkt	Jurisdiktion über den Provider (Possession, Custody, Control)	Erbringung von Diensten im EU-Markt
Gerichtliche Kontrolle (Inhaltsdaten)	Richterlicher Herausgabebeschluss erforderlich	Richterliche Genehmigung + Prüfung durch Vollstreckungsbehörde
Gerichtliche Kontrolle (Metadaten)	Gerichtsbeschluss mit abgesenkten Anforderungen, teilweise nur behördliche Auskunftsanordnung	Richterliche Kontrolle abhängig von Datenkategorie
Kontrolle ohne Richter	NSL: kein Richter, kein Verdacht, für Metadaten	Kein strukturelles Äquivalent
Massenüberwachung	FISA § 702: Pauschale Jahreszertifizierung, kein Einzelfall	Kein Äquivalent in der e-Evidence-VO
Ablehnungsgründe	Nur Comity-Verfahren (völkerrechtliche Rücksichtnahme), entschieden nach US-Maßstäben	Katalog EU-Ablehnungsgründe: Grundrechtsverletzung, ne bis in idem, Immunität, fehlende beiderseitige Strafbarkeit
Benachrichtigung Betroffener	Kann durch Schweigeverfügung dauerhaft blockiert werden	Pflicht bei Inhaltsdaten; Ausnahmen, aber keine unbegrenzte Sperrung
Rechtsschutz für Nicht-US-Bürger	Faktisch nicht vorhanden vor US-Gerichten	EU-Grundrechtecharta (Art. 8, Art. 47), nationaler Rechtsweg
Verhältnismäßigkeit	Nicht strukturell verankert für Nicht-US-Bürger	DSGVO + GRCh Art. 52 als fester Maßstab

Dimension	US CLOUD Act	EU e-Evidence-VO
Geheimdienstlicher Zugriff	FISA § 702, EO 12.333, NSL — ohne richterliche Einzelfallkontrolle	Kein Äquivalent; nationale Nachrichtendienste agieren nach nationalem Recht
DSGVO-Konformität	Strukturell verletzt Art. 48 DSGVO (verbietet Datentransfer in Drittstaaten ohne EU-rechtliche Grundlage)	Ist EU-Recht — kein Konflikt
Überprüfbarkeit	US-Gerichte, US-Maßstäbe	EuGH, Grundrechtecharta, nationale Verfassungsgerichte

Das Kernresultat: Europäische Strafverfolgungsbehörden können auf Basis der e-Evidence-VO auf Daten zugreifen — aber in einem Rechtssystem, das an Grundrechte gebunden, verhältnismäßig angewendet und durch unabhängige Gerichte überprüfbar ist. Das ist strukturell ein anderes Vertrauensniveau als FISA § 702 oder National Security Letters.

4.4 Ist DSGVO relevant für europäischen Behördenzugriff?

Direkt: Nein. Die DSGVO regelt die Verarbeitung personenbezogener Daten durch private Verantwortliche — nicht die staatliche Strafverfolgung. Strafverfolgungsbehörden agieren auf Basis der JI-Richtlinie (2016/680) und nationalen Strafprozessordnungen. Das ist keine Lücke — es ist bewusste Systemtrennung.

Indirekt: Ja. Die DSGVO setzt — zusammen mit der EU-Grundrechtecharta — den übergeordneten Grundrechtsrahmen, in dem jede EU-Behördenhandlung stattfinden muss. Art. 52 GRCh verlangt Verhältnismäßigkeit bei Grundrechtseingriffen. Dieser Maßstab ist in EU-Recht strukturell eingebaut und durch den EuGH einklagbar. Im US-System ist er für Nicht-US-Bürger strukturell nicht eingebaut.

4.5 Five Eyes, NATO und die ethische Frage

Die naheliegende Position lautet: NATO-Verbündete teilen Sicherheitsinteressen, gemeinsame Werte, gemeinsame Bedrohungsanalysen. Mit Ländern, mit denen wir Geheimdienstinformationen teilen und gemeinsam kämpfen, könnten wir doch auch Gesundheitsdaten teilen — ethisch vertretbar im Sinne eines westlichen Werteverbunds?

Diese Position verdient eine ehrliche Auseinandersetzung in drei Dimensionen:

Dimension 1: Was Five Eyes strukturell ist

Five Eyes (USA, UK, Kanada, Australien, Neuseeland) ist ein Geheimdienstkooperationsrahmen auf Basis des UKUSA-Abkommens von 1946, der alle SIGINT (Fernmeldeaufklärung)-Daten standardmäßig teilt. Das bedeutet: Daten, die US-Behörden über FISA § 702 oder NSL erfassen, fließen strukturell in die Five-Eyes-Partner. Enthüllungen durch Edward Snowden und parlamentarische Untersuchungen haben gezeigt, dass Five Eyes-Staaten die eigenen Bürger der Partner ausspioniert haben — weil heimisches Recht die Überwachung der eigenen Bürger verbietet, nicht aber die Überwachung fremder Bürger durch Partnerstaaten.

Hinzu kommen 9 Eyes (+ Dänemark, Frankreich, Niederlande, Norwegen), 14 Eyes (+ Deutschland, Belgien, Italien, Spanien, Schweden) und Tier-B-Kooperationen, zu denen auch Deutschland gehört. Diese Ebenen haben unterschiedliche Kooperationstiefe, teilen aber alle das Grundprinzip: Nachrichtendienste sind keine Datenschutzbehörden.

Dimension 2: Der Kategorieunterschied

NATO und Five Eyes sind für einen spezifischen Zweck konstruiert: Sicherheit und Gefahrenabwehr gegen externe Bedrohungen. GKV-Gesundheitsdaten — Krebsdiagnosen, psychiatrische Befunde, HIV-Status, Medikamentenpläne von 74 Millionen Versicherten — sind nicht Gegenstand dieser Kooperation und es gibt keinen Legitimitätsgrund, warum sie es sein sollten.

Der CLOUD Act ist kein Geheimdienstgesetz — er ist ein Strafverfolgungsgesetz. Ein FBI-Agent, der in einer Drogenermittlung E-Mails eines Verdächtigen anfordert und dabei die Gesundheitsakten unbeteiligter

GKV-Versicherter miterfasst, handelt nicht im Sinne eines "westlichen Werteverbunds." Er handelt im Rahmen eines Gesetzes, das keine adäquaten Schutzmechanismen für Nicht-US-Bürger enthält.

Dimension 3: Die geopolitische Realität 2025/2026

Der "westliche Verbund"-Gedanke hat seit 2025 eine neue Dimension bekommen. Die US-Regierung hat EU-Handelspartner mit Zöllen belegt, Druck auf europäische Institutionen ausgeübt und — im ICC-Präzedenzfall — demonstriert, dass Cloud-Dienste als politisches Druckmittel eingesetzt werden können. Wer Infrastrukturarchitektur auf politischem Vertrauen in einen spezifischen Verbündeten aufbaut, macht diese Architektur von politischen Konstellationen abhängig, die sich ändern.

Fazit zur ethischen Frage:

Es gibt keinen pauschalen "westlichen Verbund", dem man Gesundheitsdaten strukturell anvertrauen kann oder sollte. Es gibt Rechtssysteme — und europäisches Recht ist für diese Zwecke strukturell vertrauenswürdiger als US-Recht, weil es:

1. An Verhältnismäßigkeit gebunden ist (GRCh Art. 52) 2. Durch unabhängige Gerichte überprüfbar ist (EuGH, BVerfG) 3. Rechtsschutz für alle Betroffenen — nicht nur für eigene Bürger — vorsieht 4. Keine Massenüberwachung ohne Einzelfallprüfung kennt (kein FISA-Äquivalent) 5. Nicht von politischen Konstellationen einer einzelnen Regierung abhängt

Das ist kein antiamerikanisches Argument. Es ist ein rechtsstaatliches. Und es trägt die Konsequenz: Wer Gesundheitsdaten auf EU-souveräner Infrastruktur mit EU-rechtlichem Behördenzugriff hält, hat strukturell einen höheren Schutz — nicht weil Europa besser ist, sondern weil das europäische Recht für diesen Zweck besser konstruiert ist.

4.6 Praktische Konsequenz: Was dieser Vergleich für Architekturentscheidungen bedeutet

Szenario	Bewertung
Strafverfolgungszugriff EU-Behörde mit Richtererlaubnis (e-Evidence-VO)	[OK] Rechtsstaatlich, DSGVO-kompatibel, anfechtbar
Strafverfolgungszugriff US-Behörde mit Herausgabebeschluss (CLOUD Act, Inhaltsdaten)	[Y] Formal gerichtlich, aber kein Rechtsschutz für EU-Bürger
Strafverfolgungszugriff US-Behörde ohne Richter (NSL, Metadaten)	[R] Kein Richter, kein Verdacht, Schweigegebot
Geheimdienstlicher Zugriff (FISA § 702)	[R] Keine Einzelfallprüfung, kein EU-Rechtsschutz, Five-Eyes-Weitergabe
Five-Eyes-Intelligence-Sharing auf Basis US-erfasster Daten	[R] Kein transparentes Rechtsregime für Betroffene

Für Gesundheitsdaten nach § 393 SGB V gilt: Nur Stufe 1 (EU-rechtlicher Strafverfolgungszugriff) ist akzeptabel. Alle anderen Szenarien sind mit dem DSGVO-Schutzniveau für besondere Datenkategorien (Art. 9) unvereinbar.

5. Anbieterbewertung: CLOUD-Act-Risiko und EU-Marktübersicht

5.1 Marktkontext

Die EU-Kommission hat im Oktober 2025 einen **180-Millionen-Euro-Tender** für souveräne Cloud-Services ausgeschrieben — die erste direkte Umsetzung des Cloud Sovereignty Framework mit 8 messbaren Souveränitätskriterien. Frankreich migriert seinen nationalen Gesundheitsdaten-Hub (67 Millionen Bürger) bis 2026 von Microsoft Azure zu einem SecNumCloud-zertifizierten Anbieter (SecNumCloud: strengstes EU-Cloud-Sicherheitszertifikat der französischen Behörde ANSSI). Die Suche nach "European cloud alternatives" ist 2025 um 660% gestiegen.

Marktverteilung Europa 2025: AWS ~30%, Microsoft Azure ~25%, Google Cloud ~15%, EU-Anbieter gesamt ~15%, Sonstige ~15%.

5.2 Die drei Risikofragen — Bewertungslogik

Das entscheidende Kriterium ist **nicht der Serverstandort, sondern die Unternehmensstruktur.** Für jeden Anbieter sind drei Fragen maßgeblich:

1. Ist das Unternehmen oder seine Muttergesellschaft in den USA börsennotiert oder hat Hauptsitz in den USA? 2. Unterhält das Unternehmen Niederlassungen, Tochtergesellschaften oder signifikante Geschäftsaktivitäten in den USA? 3. Gibt es eine indirekte Druckposition über eine US-Schwester- oder Tochtergesellschaft?

Wenn eine dieser Fragen mit Ja beantwortet wird: CLOUD-Act-Risiko real — unabhängig von Serverstandort, AVV (Auftragsverarbeitungsvertrag nach Art. 28 DSGVO) und SCCs (Standard Contractual Clauses — EU-Standardvertragsklauseln).

5.3 Zertifizierungsstandards im Vergleich

Standard	Land	CLOUD-Act-Immunität	Stärke
BSI C5:2026	Deutschland	[X] Nicht geprüft — nur technische Sicherheit (168 Kriterien, Apr. 2026)	Technische Mindestsicherheit
BSI Souveränitätskriterien	Deutschland	■ Angekündigt — gemeinsam mit ANSSI (Nov. 2025), Veröffentlichung "in Kürze"	Noch nicht verfügbar
SecNumCloud 3.2	Frankreich	[OK] Explizit — max. 24%/39% nicht-EU-Anteile, EU-Personal	Strenger Souveränitätsstandard
BSI Cloud Platform Requirements	Deutschland	[OK] Implizit — deutsches Personal, kein US-Zugang	Für VS-NfD-Daten
ISO 27001	International	[X] Nicht geprüft	Informationssicherheits-Baseline
HDS	Frankreich	[X] Nicht direkt	Gesundheitsdaten-Hosting
EUCS (blockiert)	EU	Souveränitätsstufe gestrichen; Pattsituation seit 2024	Nicht absehbar

> ***Kernaussage:*** *C5 belegt technische Sicherheit — nicht rechtliche Souveränität. Azure hat C5 und unterliegt dem CLOUD Act. plusserver hat C5 und unterliegt ihm strukturell nicht.*

Warum Frankreich SecNumCloud hat und Deutschland nicht

Die Tabelle oben zeigt eine auffällige Asymmetrie: Frankreich hat mit SecNumCloud 3.2 einen Cloud-Zertifizierungsstandard, der explizit vor extraterritorialen Gesetzen wie dem CLOUD Act schützt. Deutschland hat mit BSI C5 einen Standard, der nur technische Informationssicherheit prüft — die Jurisdiktionsfrage bleibt ausgeklammert. Diese Lücke ist kein Zufall, sondern das Ergebnis unterschiedlicher

politischer Traditionen, konkreter Krisen und divergierender Lobbykonstellationen.

Frankreichs Weg: Von der Souveränitätstradition zum Zertifizierungsstandard

Frankreich hat eine gewachsene Tradition der *souveraineté numérique*. Der Begriff wurde 2014 von Pierre Bellanger (Gründer des Radiosenders Skyrock) in seinem gleichnamigen Buch geprägt und zwischen 2014 und 2017 auf drei nationalen Gipfeltreffen politisch verankert — aus diesen entstand das Institut de la Souveraineté Numérique als permanente Denkfabrik [174]. Diese Tradition speist sich aus demselben strategischen Denken, das auch Frankreichs nukleare Eigenständigkeit (*force de frappe*) begründet: Souveränität als nicht-delegierbare Kernaufgabe des Staates.

ANSSI (Agence nationale de la sécurité des systèmes d'information) veröffentlichte die erste SecNumCloud-Version 2016. Version 3.1 (2018) strich die Differenzierung in "Essential" und "Advanced" zugunsten eines einheitlichen Labels und harmonisierte mit der DSGVO. Der entscheidende Schritt war **Version 3.2 (März 2022)**: Erstmals enthielt der Standard explizite **Souveränitätsanforderungen** — über 360 Anforderungen in 14 Sicherheitsthemen, darunter die Kernklausel, dass qualifizierte Anbieter mehrheitlich in EU-Hand sein, ihren Hauptsitz in der EU haben und **nicht dem Recht von Nicht-EU-Staaten unterliegen** dürfen [175]. Konkret: maximal 24 % nicht-EU-Kapitalanteile pro Einzelaktionär und 39 % kollektiv, kein Vetorecht und keine Vorstandsmehrheit für Nicht-EU-Entitäten, ausschließlich EU-Personal mit Zugang zu Kundendaten, vollständige Immunität gegen extraterritoriale Gesetze.

Der Auslöser: Die Health-Data-Hub-Krise

Der konkrete Katalysator für die Souveränitätswende war die Kontroverse um den französischen Health Data Hub (Plateforme des données de santé). Die Plattform — konzipiert als zentraler Gesundheitsdatenpool für 67 Millionen Franzosen — wurde ursprünglich auf Microsoft Azure betrieben. 2020 intervenierte die CNIL (französische Datenschutzbehörde) und der Conseil d'État ordnete zusätzliche Schutzmaßnahmen an: Das Risiko eines US-Behördenzugriffs über den CLOUD Act sei real und durch technische Maßnahmen allein nicht eliminierbar. Die französische Regierung beschloss daraufhin die Migration zu einem SecNumCloud-zertifizierten Anbieter — eine Migration, die bis 2026 abgeschlossen wird [62]. Der Health Data Hub wurde zum politischen Symbol: Frankreich demonstrierte, dass Souveränität für Gesundheitsdaten keine abstrakte Forderung ist, sondern eine konkrete Infrastrukturentscheidung.

Die Doctrine "Cloud au centre"

Im Juli 2021 formalisierte Premierminister Jean Castex per Rundschreiben die *Doctrine Cloud au centre*: Cloud-Computing wird Voraussetzung für alle neuen digitalen Projekte des Staates. Für Daten "besonderer Sensibilität" — auch wenn sie keine personenbezogenen Daten im DSGVO-Sinne sind — ist die Nutzung eines **SecNumCloud-qualifizierten Anbieters verpflichtend** [176]. Die Doctrine wurde im Mai 2023 unter Premierministerin Borne aktualisiert und der Sensibilitätsbegriff erweitert. Im Januar 2026 bekräftigte Digitalministerin Anne Le Hénanff auf den *Rencontres de la souveraineté numérique* die Forderung nach einer "préférence européenne". Das Ergebnis: Ein wachsendes SecNumCloud-Ökosystem mit mittlerweile über einem halben Dutzend qualifizierten Anbietern (3DS Outscale, S3NS, Cloud Temple, OVHcloud, NumSpot, Scaleway in Prüfung) — ein Markt, den es ohne die staatliche Nachfragepolitik so nicht gäbe.

Deutschlands Weg: C5 als pragmatischer Kompromiss

Deutschland hat eine andere Tradition. Das BSI hat sich historisch als Behörde für **technische** Informationssicherheit definiert — nicht für geopolitische Souveränitätsfragen. Der BSI C5-Katalog (Cloud Computing Compliance Criteria Catalogue) wurde 2016 veröffentlicht, zeitgleich mit SecNumCloud 1.0, aber mit einem fundamental anderen Ansatz. Die am 7. April 2026 veröffentlichte aktuelle Version **C5:2026** prüft 168 Kriterien in 17 Domänen — Verschlüsselung, Zugriffskontrolle, Netzwerksicherheit, Container-Management, Post-Quanten-Kryptographie, Confidential Computing — und beantwortet die Frage "Ist der Cloud-Dienst technisch sicher?" [188]. Die Frage "Kann eine ausländische Regierung den Anbieter zur Herausgabe zwingen?" wird auch in C5:2026 **bewusst nicht gestellt** — obwohl der Katalog strukturell an das europäische EUCS angelehnt wurde [177].

Für den Bereich der Verschlusssachen (VS-NfD und höher) existiert mit den **BSI Cloud Platform Requirements** ein strengerer Maßstab, der de facto Souveränitätsanforderungen stellt: deutsches Personal, keine US-Zugriffsmöglichkeit, BSI-Prüfung aller Updates. Aber dieses Instrument ist nicht als öffentlicher Marktstandard konzipiert — es gilt nur für die Bundesverwaltung und Delos Cloud ist der erste (und bisher einzige) Nutzer im US-Technologie-Kontext. Für den regulären Gesundheitsmarkt bleibt C5 der Referenzstandard — und § 393 SGB V hat C5 als Pflichttestat verankert, ohne eine Souveränitätsprüfung danebenzustellen. Symptomatisch: Das BSI hat mit AWS eine Kooperationsvereinbarung unterzeichnet und begrüßte die AWS European Sovereign Cloud in Brandenburg als Beitrag zur europäischen Souveränität [185] — eine Position, die diametral zu ANSSIs Haltung steht, wonach US-Hyperscaler ohne strukturelle Trennung grundsätzlich nicht souveränitätsfähig sind.

C5:2026 (veröffentlicht 7. April 2026) ist ein substanzieller Fortschritt bei der technischen Sicherheit — 168 statt 121 Kriterien, erstmals Confidential Computing und Post-Quanten-Kryptographie, strukturell an EUCS angelehnt [188]. Aber die Souveränitätsfrage bleibt auch in C5:2026 **ausgeklammert**: Das BSI hat angekündigt, Souveränitätskriterien als **separates Dokument** "in Kürze" zu veröffentlichen — nicht als integralen Bestandteil der Zertifizierung [186]. Der Unterschied zu Frankreich bleibt damit strukturell: ANSSI hat Souveränität in den Zertifizierungsstandard selbst eingebaut. Das BSI hält Souveränität und technische Sicherheit getrennt — auch in der neuesten Version.

Das EUCS-Scheitern — und Deutschlands Rolle

Die Chance auf eine europäische Harmonisierung bestand im EUCS (European Cybersecurity Certification Scheme for Cloud Services), das unter dem Cybersecurity Act von ENISA entwickelt wurde. Der ursprüngliche Entwurf sah eine höchste Stufe ("High+") mit Souveränitätsanforderungen nach SecNumCloud-Vorbild vor: EU-Eigentum, EU-Hauptsitz, Immunität gegen extraterritoriale Gesetze. Frankreich, Italien und Spanien unterstützten diese Stufe.

Die Opposition kam aus zwei Richtungen: Erstens lobbyierten US-Industrieverbände massiv gegen die Souveränitätsstufe — der US Council for International Business (USCIB), die US Chamber of Commerce und der Information Technology Industry Council (ITI) forderten öffentlich die Streichung der Souveränitätsanforderungen [178]. The Register dokumentierte, dass US-Lobbyisten Studien finanzierten, die die EU-Regulierung als handelsfeindlich darstellten [179]. Zweitens reichten sieben EU-Mitgliedstaaten — darunter die Niederlande, Dänemark, Schweden und Estland — ein Non-Paper ein, das die Souveränitätsstufe als "diskriminierend gegenüber Nicht-EU-Anbietern" ablehnte [180].

Deutschlands Position war ambivalent: Anfangs unterstützte Deutschland in Abstimmung mit Frankreich die Souveränitätsstufe, schwenkte dann aber unter innenpolitischem Industriedruck um und schloss sich der Oppositionsgruppe an [180]. Die European Business Review beschrieb die Situation 2024 als zunehmendes "Auseinanderdriften" von Frankreich und Deutschland in der Cloud-Souveränitätsfrage [181]. Bitkom — Deutschlands größter Digitalverband, dessen Mitglieder sowohl deutsche als auch US-Anbieter umfassen — unterstützte zwar grundsätzlich digitale Souveränität (78 % der befragten Unternehmen im Bitkom Cloud Report 2025 halten Deutschland für zu abhängig von US-Cloud-Anbietern), vermied aber die Forderung nach harten Eigentümerschaftskriterien [182]. Das Ergebnis: Die Souveränitätsstufe wurde aus dem EUCS-Entwurf gestrichen. Stand April 2026 befindet sich das EUCS in einer Pattsituation — das cep (Centrum für Europäische Politik) bezeichnete die Situation im April 2025 als "Impasse" [183]. Frankreich behält SecNumCloud als nationalen Standard bei. Deutschland hat nichts Vergleichbares.

Gaia-X — der gescheiterte gemeinsame Ansatz

Gaia-X, 2019 als deutsch-französisches Prestigeprojekt unter Bundeswirtschaftsminister Altmaier und seinem französischen Amtskollegen Le Maire gestartet, sollte ein europäisches Cloud-Ökosystem mit gemeinsamen Souveränitätsstandards schaffen. Das Projekt scheiterte an der Governance: US-Hyperscaler (AWS, Microsoft, Google) wurden als Mitglieder aufgenommen, Souveränitätsanforderungen blieben als "Labels" unverbindlich [184]. Frankreich zog daraus den Schluss, den eigenen Weg mit SecNumCloud zu vertiefen. Deutschland verblieb ohne gleichwertigen Standard.

Ansätze zur Konvergenz — und ihre Grenzen

Drei jüngere Entwicklungen deuten auf ein deutsches Umdenken hin — wobei die Lücke bis heute fortbesteht:

Erstens veröffentlichten ANSSI und BSI am 17. November 2025 ein **gemeinsames Statement zu Cloud-Souveränitätskriterien**, unterzeichnet von ANSSI-Generaldirektor Vincent Strubel und BSI-Präsidentin Claudia Plattner [189]. Darin verpflichten sich beide Behörden, gemeinsam Souveränitätskriterien auf Basis des EU Cloud Sovereignty Framework zu entwickeln — mit konkreten Anforderungen: strikte Datenlokalisierung, ausschließliche Anwendung europäischen Rechts, **kein Zugang durch nicht-europäische Dritte**, und Geschäftskontinuität ohne außereuropäische Akteure oder Technologien. Entscheidend: Das Statement führt eine **Progressionslogik** ein — nicht binär (souverän/nicht-souverän), sondern drei Stufen: minimale Rechtskonformität, erweiterter operativer Kontrolle und volle strategische Autonomie. Wo das Nicht-Erfüllen disqualifizierend wirkt, soll die Methodik festlegen.

Zweitens veranstalteten Macron und Bundeskanzler Merz am 18. November 2025 den **Gipfel für Europäische Digitale Souveränität** in Berlin (900+ Teilnehmer) mit privatwirtschaftlichen Investitionszusagen von über 12 Mrd. EUR und einer gemeinsamen Task Force [187].

Drittens schlug die EU-Kommission im März 2025 eine Überarbeitung des Cybersecurity Act vor, die erstmals "nicht-technische Anforderungen" in Zertifizierungsschemata ermöglichen würde — ein Türöffner, um Souveränitätskriterien doch noch in EUCS zu verankern [183].

Das ANSSI-BSI-Statement ist der bislang konkreteste Schritt. Aber: Die angekündigten gemeinsamen Souveränitätskriterien sind bislang nicht veröffentlicht. C5:2026 (7. April 2026) enthält sie nicht. Solange die Kriterien nicht vorliegen, bleibt die Lücke operativ bestehen: Frankreich zertifiziert Souveränität seit 2022. Deutschland plant es — noch.

Die strukturelle Konsequenz für das Gesundheitswesen

Dimension	Frankreich	Deutschland
Zertifizierungsstandard	SecNumCloud 3.2 (seit 2022)	BSI C5:2026 (April 2026, nur technische Sicherheit)
Souveränitätsprüfung	[OK] Seit 2022 in Zertifizierung integriert	■ ANSSI-BSI-Statement Nov. 2025: Souveränitätskriterien angekündigt, noch nicht veröffentlicht
Staatliche Nachfragepolitik	Doctrine "Cloud au centre" (2021, 2023)	§ 393 SGB V: C5 als Pflicht, keine Souveränitätspflicht
Gesundheitsdaten-Konsequenz	Health Data Hub → Migration weg von Azure	ePA / FDZ: Keine vergleichbare Migrationsentscheidung
Zertifizierte souveräne Anbieter	6+ (Outscale, S3NS, Cloud Temple, OVHcloud, NumSpot…)	0 (C5:2026 prüft Souveränität nicht)
EU-Harmonisierung (EUCS)	Aktiv für Souveränitätsstufe	Seit Nov. 2025: gemeinsamer Ansatz mit FR (ANSSI-BSI-Statement)

Die Konsequenz ist konkret: In Frankreich kann ein Krankenhaus einen SecNumCloud-zertifizierten Anbieter auswählen und darauf vertrauen, dass die Zertifizierung die CLOUD-Act-Frage adressiert. In Deutschland muss jede Organisation die Jurisdiktionsprüfung eigenständig durchführen — das C5-Testat sagt darüber nichts aus. Frankreich hat den Markt durch regulatorische Nachfrage geschaffen. Deutschland überlässt die Souveränitätsentscheidung dem Einzelnen.

5.4 DACH-Kernmarkt: Risikoübersicht

Die Tabelle unterscheidet drei Risikotypen, die unterschiedliche CLOUD-Act-Konsequenzen haben:

- **Typ A — Direkte US-Institution:** Eigene US-Niederlassung, US-Tochtergesellschaft oder US-Muttergesellschaft, die denselben Cloud-Dienst betreibt oder direkten Datenzugriff hat. Herausgabepflicht direkt erzwingbar.
- *Direkt:* US-Hauptsitz / US-Mutter (Oracle, Microsoft, AWS, Qlik)

• *Indirekt:* EU-Mutter mit US-Cloud-Tochter im gleichen Geschäftsfeld (Hetzner US LLC, IONOS Cloud Inc., OVH US Corp.)

• **Typ B — US-Technologieabhängigkeit:** Europäischer Anbieter, aber US-Software, US-Lizenz oder US-Infrastrukturpartner. Kein direkter CLOUD-Act-Zugriff auf EU-Kundendaten, aber Restrisiko über den Lieferanten.

• **Typ C — Konzernhebel:** EU-Unternehmen mit US-Tochter oder US-Schwester in einem *anderen* Geschäftsfeld, die keinen operativen Zugriff auf Cloud-Kundendaten hat. CLOUD-Act-Zugriff nur über indirekten Unternehmensdruck möglich — nicht über direkte Datenhoheit. Gilt sowohl für formale Tochterbeziehungen (Deutsche Telekom → T-Mobile US/Telekommunikation) als auch für eigentümerschaftlich verbundene Schwestergesellschaften (Schwarz-Gruppe → Lidl US/Handel).

Anbieter	C5	Börse / Eigentümer	US-Verbindung	Risikotyp	CLOUD-Act-Risiko	Regionale Datenhaltung	Empfehlung
Oracle Cerner / OCI	Nein	NYSE: ORCL	US-Hauptsitz Austin/TX	**A — direkt**	[R] Hoch	Frankfurt (EU Sovereign), Madrid	KIS-Migration (KIS = Krankenhausinformationssystem) auf OCI: CLOUD-Act-Exposition ungelöst
Microsoft Azure	[OK]	NYSE: MSFT	US-Muttergesellschaft	**A — direkt**	[R] Hoch	Frankfurt (GWC), Amsterdam	Nicht für Gesundheitsdaten
AWS Germany	[OK]	NASDAQ: AMZN	AWS Germany = US-Tochter	**A — direkt**	[R] Hoch	Frankfurt (eu-central-1)	Nicht für Gesundheitsdaten
Qlik Cloud	Nein (C5 geplant Q1 2026)	US-Unternehmen (PA, Thoma Bravo)	US-Hauptsitz	**A — direkt**	[R] Hoch	Frankfurt, Irland, Paris, London, Mailand (alle auf AWS)	Nicht für Gesundheitsdaten — Frankfurt-Region ändert US-Jurisdiktion nicht
OVHcloud	[OK] 2025	Euronext Paris	OVH US Corp. (eigene US-Tochter)	**A — indirekt**	[R] Bestätigt	Strasbourg, Roubaix, Paris, Frankfurt	SNC-Tier für regulierte Workloads
Hetzner (EU-RZ)	[OK] Feb. 2026	Privat (DE)	Hetzner US LLC (eigene US-Cloud-Tochter)	**A — indirekt**	[O] Bedingt	Nürnberg, Falkenstein (DE); Helsinki (FI)	Dev/SMB; nicht für § 393-Daten
Arvato Systems	[OK]	Bertelsmann (privat, DE)	AWS + Azure als Infrastrukturpartner	**B — Technologie**	[R] Indirekt	Gütersloh (3 eigene RZ, DE)	Eigene RZ, aber US-Software-Risiko
Delos Cloud (SAP × Azure)	BSI CPR	SAP SE (DAX)	Microsoft = Technologielieferant (lizenziert)	**B — Technologie**	[Y] Operator-Modell	Frankfurt (Azure Germany West Central)	Für M365/Azure-abhängige Verwaltung
SAP BTP / RISE	Teilweise	DAX: SAP SE	Eigene US-Niederlassungen (SAP America)	**A + B**	[Y] Infrastrukturell	Frankfurt (Azure GWC + AWS eu-central-1)	Je nach Hosting-Variante prüfen
IONOS	[OK] 2023	MDAX: UTDI	IONOS Cloud Inc. (eigene US-Cloud-Tochter)	**A — indirekt**	[O] BMI-bestätigt	Karlsruhe, Berlin, Frankfurt, Nürnberg (DE)	Prüfung erforderlich
Deutsche Telekom / OTC	[OK]	DAX: DTE (ADR: NYSE DTEGY)	T-Mobile US = Telekom-Tochter, kein Cloud-Betrieb	**C — Konzernhebel**	[Y] Strukturell	Biere/Sachsen-Anhalt, Magdeburg (DE); NL	Mit Vorbehalt — T-Mobile US hat keinen Zugriff auf OTC-Daten

Anbieter	C5	Börse / Eigentümer	US-Verbindung	Risikotyp	CLOUD-Act-Risiko	Regionale Datenhaltung	Empfehlung
STACKIT	[OK] C5 Typ 2 (Aug. 2024)	Privat (Schwarz Gruppe, DE)	Lidl US = Handelsschwester (kein Datenzugriff)	**C — Konzernhebel**	[Y] Juristisch unklar	Neckarsulm, Düsseldorf (DE); Wien (AT)	Valide mit Vorbehalt
plusserver	[OK] C5	Privat (DE)	Keine	**Keiner**	[G] Gering	Köln, Hamburg, Frankfurt (DE)	Sauberste DE-Option
EWERK Leipzig	ISO 27001, ISAE 3402 Typ II (C5 in Vorbereitung)	NORD Holding (DE, privat) + Gründer	Keine	**Keiner**	[G] Gering	Leipzig (DE)	KRITIS-Spezialist (Kritische Infrastrukturen — gesetzliche Einstufung systemrelevanter Sektoren); C5-Testat angestrebt

5.5 Juristische Detailanalysen

Die Tabelle in 5.4 zeigt die Risikoeinstufung — dieser Abschnitt erklärt für die kritischen Fälle, **warum** die jeweilige US-Verbindung zum CLOUD-Act-Risiko führt. Die Logik folgt den drei Konstellationen aus Kapitel 2:

- **Konstellation A:** US-Mutter → EU-Tochter. Herausgabepflicht direkt durchsetzbar, kein Widerspruch möglich.
- **Konstellation B:** EU-Mutter → US-Tochter. EU-Mutter kann widersprechen, aber US-Tochter ist Druckmittel.
- **Konstellation C:** Schwestergesellschaften oder Konzernhebel über ein anderes Geschäftsfeld. Juristisch unklar, praktisch geringes Risiko wenn kein operativer Datenzugriff besteht.

> ***Hinweis Konstellationen ↔ Risikotypen (§5.4):*** *Die juristischen Konstellationen (A/B/C aus Kapitel 2) beschreiben die Rechtsbeziehung zwischen EU- und US-Entität. Die Risikotypen in der Tabelle §5.4 fassen die daraus resultierenden praktischen Risiken zusammen: Typ A-direkt = Konstellation A, Typ A-indirekt = Konstellation B, Typ B = kein Konstellation-Äquivalent (reine Technologieabhängigkeit), Typ C = Konstellation C.*

Hetzner — eigene US-Tochter als Druckmittel (Konstellation B)

Hetzner Online GmbH (Gunzenhausen/Bayern) ist ein deutsches Privatunternehmen mit C5-Testat seit Februar 2026. Auf den ersten Blick souverän. Aber: Hetzner betreibt **Hetzner US LLC** in Ashburn, Virginia — eine eigene US-Tochtergesellschaft für den US-Rechenzentrumsmarkt. Hetzner dokumentiert selbst: "Hetzner kann nicht damit dienen, keine Verbindung zu den USA zu haben."

Die juristische Konsequenz (Konstellation B): Hetzner Online GmbH (EU-Mutter) kann einer CLOUD-Act-Anfrage widersprechen und DSGVO Art. 48 geltend machen. Aber US-Behörden können die Hetzner US LLC unter Druck setzen — Geschäftslizenzen, Strafen, Betriebsaussetzung — als indirekten Hebel gegen die deutsche Mutter. Das ist strukturell risikoreicher als ein Anbieter ohne jede US-Präsenz, aber kein direkter Herausgabezwang.

Callista-Benchmark (Februar 2026): Hetzner liefert das 14,3-fache Preis-Leistungs-Verhältnis gegenüber AWS on-demand. Für Dev-Teams und unkritische Workloads weiterhin erste Wahl. Für KRITIS-relevante Gesundheitsdaten nach § 393 SGB V: plusserver oder EWERK Leipzig bevorzugen.

STACKIT / Schwarz Gruppe — Schwestergesellschaft ohne Konzernverbund (Konstellation C)

STACKIT (Schwarz Digits KG, Neckarsulm) ist die Cloud-Marke der Schwarz Gruppe. Zur Schwarz Gruppe gehören auch Lidl und Kaufland — mit über 200 Filialen an der US-Ostküste sowie PreZero

(Umweltdienstleistungssparte der Schwarz Gruppe) mit 430 US-Standorten. Diese US-Aktivitäten sind der Kern des Risikoverdachts.

Die entscheidende gesellschaftsrechtliche Besonderheit: Die Schwarz Gruppe ist **kein Konzern im handelsrechtlichen Sinne**. Lidl Stiftung, Schwarz Digits (STACKIT) und PreZero sind Schwestergesellschaften unter demselben Privateigentümer (Dieter Schwarz) — aber **gesellschaftsrechtlich nicht miteinander verbunden**. Es gibt keine Beherrschungs- oder Gewinnabführungsverträge. STACKIT ist nicht Tochter von Lidl — beide sind eigenständige Gesellschaften.

Warum das relevant ist: Der CLOUD Act knüpft an "possession, custody, or control" an — nicht an bloße Eigentümeridentität. US-Gerichte müssten nachweisen, dass Lidl US tatsächlich Kontrolle über STACKIT-Daten hat, was bei gesellschaftsrechtlicher Trennung und ohne operative Verbindung schwer zu begründen ist. STACKIT-CEO Bernd Wagner: *"Wir investieren nicht in den USA. Es ergibt keinen Sinn, denn somit würden wir sofort den Regularien des US Cloud Act unterliegen."*

Bewertung: STACKIT ist strukturell besser aufgestellt als Hetzner und IONOS (keine eigene US-Cloud-Tochter, keine US-Primärnotierung). Gegenüber der Open Telekom Cloud (OTC) / Deutsche Telekom ist STACKIT auf vergleichbarer Risikostufe: Beide sind Typ-C-Konstellationen, bei denen die US-Präsenz in einem anderen Geschäftsfeld liegt und keinen direkten Zugriff auf Cloud-Kundendaten hat — der Unterschied ist, dass die Schwarz-Gruppe-Verbindung informell (Eigentümerschaft) ist, während Deutsche Telekom AG formal die Muttergesellschaft von T-Mobile US ist. Die Unsicherheit liegt in der bislang ungeklärten Frage, ob US-Gerichte die Eigentümeridentität als "control" werten würden — juristisch nicht abschließend beantwortet, praktisch unwahrscheinlich solange STACKIT auf US-Investitionen verzichtet.

Arvato Systems — US-Softwareabhängigkeit ohne eigene US-Institution (Typ B)

Arvato ist der Sonderfall Typ B: keine eigene US-Tochter, keine US-Börsennotierung, kein US-Eigentümer — aber operative Abhängigkeit von US-Software. Arvato ist AWS Premier Partner und betreibt als Technologiepartner die Delos Cloud auf Azure-Basis. Das bedeutet: Die US-Unternehmen AWS und Microsoft haben über ihre Software-/Lizenzbeziehung mit Arvato einen potenziellen Ansatzpunkt.

Der CLOUD Act gilt für den US-Provider (AWS, Microsoft) — nicht für Arvato selbst. Arvato ist nicht zur Herausgabe verpflichtet. Aber: AWS oder Microsoft könnten ihrerseits verpflichtet werden, Zugang zu Daten zu verschaffen, die auf Arvato-Hardware mit AWS- oder Azure-Software laufen. Das Risiko liegt also auf der Software-Ebene, nicht auf der Arvato-Unternehmensebene.

Deutsche Telekom / Open Telekom Cloud — Telekomtochter als Konzernhebel (Konstellation C)

Deutsche Telekom AG (Bonn, DAX: DTE) ist ein deutsches Unternehmen — die NYSE-Notierung DTEGY ist ein American Depositary Receipt (ADR), kein primäres US-Listing. Die entscheidende US-Verbindung ist T-Mobile US Inc., eine börsennotierte US-Mobilfunktochtergesellschaft, an der Deutsche Telekom rund 48 % hält.

Warum das weniger riskant ist als zunächst sichtbar: T-Mobile US ist ein Telekommunikationsunternehmen. Es betreibt keine Cloud-Infrastruktur, hat keinen Zugriff auf Daten der Open Telekom Cloud und teilt keine IT-Systeme mit T-Systems (dem OTC-Betreiber). T-Mobile US und T-Systems sind Schwestergesellschaften unter derselben Konzernmutter — operativ vollständig getrennt.

Die CLOUD-Act-Mechanik in dieser Konstellation: US-Behörden könnten T-Mobile US nutzen, um Druck auf Deutsche Telekom AG auszuüben — und Deutsche Telekom AG könnte theoretisch zur Herausgabe von T-Systems/OTC-Daten angehalten werden, weil sie als Konzernmutter Kontrolle über T-Systems ausübt. Aber dieser Weg ist lang: (1) CLOUD-Act-Beschluss gegen T-Mobile US, (2) Übertragung auf Deutsche Telekom AG als Mutter, (3) Verpflichtung Deutsche Telekoms zur Weitergabe von T-Systems-Daten — gegen ausdrückliches DSGVO-Widerspruchsrecht. Kein direkter Datenzugriff, keine geteilte Infrastruktur.

Abgrenzung zu Hetzner / IONOS: Hetzner US LLC und IONOS Cloud Inc. sind US-Cloud-Betreiber im selben Sektor. Sie haben strukturell administrativen Zugriff auf Systeme, die zum selben Unternehmensverbund gehören. T-Mobile US hat das nicht. Deshalb ist Deutsche Telekom / OTC als **C — Konzernhebel** einzustufen,

nicht als A — indirekt.

OTC-Rechenzentren: Sachsen-Anhalt (Biere, 100.000 Server, 18 MW) + Magdeburg-Region; sowie eine Niederlande-Region. T-Systems betreibt 33 RZ weltweit, 7 im Eigenbetrieb — ausschließlich europäischer Standortbetrieb für OTC.

IONOS — US-Tochter trotz europäischer Börsennotierung (Konstellation B)

IONOS SE ist an der MDAX-notierten United Internet AG (DE) angebunden — auf den ersten Blick ein europäisches Unternehmen. Das Problem: IONOS betreibt **IONOS Cloud Inc.** in den USA als eigene US-Tochtergesellschaft.

Das BMI-Gutachten der Universität Köln stellt klar: Für die Anwendbarkeit des CLOUD Act reicht eine US-Niederlassung aus — unabhängig davon, wo die Mutter börsennotiert ist. IONOS US Inc. ist eine US-Person im Sinne des CLOUD Act. Über sie können US-Behörden Druck auf die europäische Mutter ausüben (Konstellation B). IONOS wirbt mit CLOUD-Act-Schutz für EU-Daten — diese Aussage ist formal nicht falsch (direkte Herausgabe wäre anfechtbar), unterschlägt aber den indirekten Druckmechanismus.

EWERK Leipzig — Private-Equity-Übernahme: Auswirkung auf CLOUD-Act-Bewertung

EWERK Leipzig hat 2024 mit der NORD Holding einen neuen Mehrheitsgesellschafter erhalten. Die relevante Frage für die CLOUD-Act-Bewertung: Ändert ein Private-Equity-Eigentümer das Risikoprofil?

NORD Holding: Deutsches Private-Equity-Unternehmen mit Sitz in Hannover, gegründet 1969, ~4 Mrd. EUR verwaltetem Vermögen, ausschließlich DACH-fokussiert (Deutschland, Österreich, Schweiz). Betrieb als "Evergreen Fund" aus eigener Bilanz ohne Laufzeitbeschränkung. Keine US-Börsennotierung, keine US-Niederlassungen, keine US-Investoren in der Struktur öffentlich erkennbar. Rechtsform: GmbH, Registrierung Amtsgericht Hannover.

CLOUD-Act-Konsequenz: Entscheidend ist nicht der PE-Eigentümer als solcher, sondern ob der Eigentümer "possession, custody, or control" über Daten im Sinne des CLOUD Act ausübt und ob dieser Eigentümer unter US-Jurisdiktion fällt. Beides ist bei NORD Holding nach aktuellem Kenntnisstand nicht der Fall. Die Übernahme ändert das CLOUD-Act-Risikoprofil von EWERK nicht.

BSI C5 — aktueller Stand: EWERK ist nach ISO 27001, ISO 20000 und ISAE 3402 Typ II zertifiziert — die unmittelbare Voraussetzung für eine C5-Zertifizierung ist damit geschaffen. Ein BSI C5 Typ 2 Testat für die Cloud-Infrastruktur ist nach Unternehmensangaben in Vorbereitung. Sobald dieses vorliegt, ist EWERK vollständig § 393 SGB V-konform für die Verarbeitung von Gesundheitsdaten in der Cloud. Zum Vergleich: STACKIT hat C5 Typ 2 bereits seit August 2024, plusserver seit längerer Zeit. Für Ausschreibungen ab Juli 2025 sollte der C5-Status im Vertrag explizit als Bedingung verankert und nach Vorliegen des Testats erneut geprüft werden. [Quelle: Energieforen Leipzig, EWERK Zertifizierungsseite; Trusted Cloud, EWERK Digital Profil]

Vorbehalt: PE-Eigentümer können Portfoliounternehmen weiterveräußern. Falls EWERK in Zukunft an einen US-kontrollierten Käufer verkauft werden sollte, würde sich das Risikoprofil ändern. Für GKVen und Kliniken, die EWERK als souveränen Anbieter einplanen, empfiehlt sich eine Change-of-Control-Klausel im AVV, die eine Neuprüfung bei Eigentümerwechsel vorsieht.

Oracle / Oracle Cerner — der unsichtbare Marktführer im Klinik-KIS

Oracle spielt im deutschen Gesundheitswesen eine strukturell wichtige, aber in der öffentlichen CLOUD-Act-Debatte völlig übersehene Rolle. Der Konzern ist in zwei Funktionen präsent, die beide relevant sind:

Funktion 1 — Krankenhausinformationssysteme (KIS): Oracle Cerner betreibt das KIS i.s.h.med, das in rund 250 deutschen Krankenhäusern eingesetzt wird — darunter viele Universitätsklinika und große kommunale Häuser. i.s.h.med ist das einzige vollständig in SAP IS-H integrierte Klinik-IT-System; es erfasst medizinische Daten von der Anamnese über die Diagnose bis zur Nachbehandlung. Oracle hat Cerner 2022 für 28 Milliarden US-Dollar übernommen. [Quelle: Wikipedia i.s.h.med; kma-online.de, April 2024]

Damit ist Oracle — ein US-Konzern mit Hauptsitz in Austin, Texas, NYSE: ORCL — der direkte Verarbeiter sensibelster klinischer Patientendaten in einem Viertel der deutschen Kliniken. Oracle unterliegt dem CLOUD Act uneingeschränkt: direkte US-Muttergesellschaft, NYSE-Notierung, US-Hauptsitz. Kein Konnektor zur TI, keine Middleware — Oracle Cerner ist der direkte Betreiber des klinischen Kernsystems.

Die Managed-Service-Frage — reduziert das Risiko, eliminiert es aber nicht: Viele Kliniken betreiben i.s.h.med nicht auf Oracle-Cloud-Infrastruktur, sondern auf eigenen Servern oder bei einem deutschen Rechenzentrumsbetreiber. Oracle Cerner übernimmt in diesem Fall den Managed Service — Administration, Updates, Second-Level-Support — ohne das Rechenzentrum selbst zu betreiben. Die naheliegende Annahme ist: Wenn die Server in Deutschland stehen und dem Klinikum gehören, ist das CLOUD-Act-Risiko gebannt.

Diese Annahme ist falsch. Der CLOUD Act knüpft an "possession, custody, or control" an — nicht an den Besitz der Hardware. Oracle Cerner hat als Managed-Service-Betreiber in der Regel administrativen Fernzugriff auf die Systeme: um Patches einzuspielen, Konfigurationen anzupassen, Fehler zu analysieren. Dieser Fernzugriff bedeutet "control" im Sinne des CLOUD Act. Es ist technisch irrelevant, wem der Server gehört — entscheidend ist, ob Oracle Cerner auf die Daten zugreifen kann. Und bei einem KIS-Managed-Service ist genau das der Fall, weil Support und Wartung eines Krankenhausinformationssystems ohne Klartextzugriff auf Patientendaten praktisch nicht möglich sind.

Die Differenzierung ist dennoch wichtig: Ein Managed Service ohne Cloud-Migration ist eine geringere Exposition als eine vollständige OCI-Migration, bei der Oracle nicht nur den Zugriff, sondern auch den physischen Besitz aller Daten hat. Bei einer OCI-Migration liegt alles — Speicher, Compute, Backup — bei einem US-Hyperscaler. Beim Managed Service liegt die Infrastruktur beim Klinikum oder bei einem deutschen Betreiber; Oracle hat "nur" den administrativen Zugang. Das ist ein gradueller Unterschied, kein kategorischer. Für die DSGVO-Bewertung bleibt in beiden Fällen ein TIA erforderlich (vgl. §17.4), und in beiden Fällen muss der Auftragsverarbeitungsvertrag die CLOUD-Act-Exposition adressieren (vgl. §17.5).

Für Kliniken, die heute i.s.h.med im Managed-Service-Modell betreiben und eine Entscheidung über die Zukunft treffen müssen, ergibt sich eine klare Reihenfolge: Die Migration auf OCI vertieft die Exposition. Der Verbleib im Managed-Service-Modell auf eigener Infrastruktur reduziert sie relativ, löst sie aber nicht. Nur der Wechsel auf ein europäisches KIS — Dedalus, CGM, NEXUS, Meierhofer — oder ein Betriebsmodell, bei dem Oracle keinen administrativen Klartextzugriff mehr hat, eliminiert das CLOUD-Act-Risiko strukturell.

Funktion 2 — Oracle Cloud Infrastructure (OCI) als geplanter Nachfolger: Oracle entwickelt eine cloud-basierte Nachfolgelösung für i.s.h.med auf der Oracle Cloud Infrastructure (OCI). Der Hintergrund: SAP hat die Branchenlösung IS-H, auf der i.s.h.med aufbaut, zum Ende 2027 abgekündigt (optional erweiterte Wartung bis 2030). Damit stehen bis zu 300 Kliniken vor einem KIS-Wechsel. [Quelle: DSAG-Aussage, kma-online.de, April 2024] Oracle positioniert OCI als die natürliche Migrationsplattform für bestehende i.s.h.med-Kunden.

Was OCI ist und wie Oracle die CLOUD-Act-Frage kommuniziert: OCI ist Oracles Hyperscaler-Cloud — direkt vergleichbar mit Azure oder AWS. Oracle betreibt in Frankfurt und Madrid sogenannte EU Sovereign Cloud Regionen, die physisch von der US-Infrastruktur getrennt sind und von EU-Ansässigen betrieben werden sollen. Oracle argumentiert, dass eine separate EU-Rechtseinheit eine CLOUD-Act-Anfrage wegen fehlender "possession, custody, or control" über EU-Daten ablehnen könne. [Quelle: Oracle Blog, "Oracle sovereign cloud solutions: Providing transparent review of data access requests", 2024]

CLOUD-Act-Bewertung für OCI EU Sovereign Cloud: Dieselbe Argumentation verfolgen auch Microsoft (Azure EU Data Boundary) und AWS (European Sovereign Cloud) — und die juristische Bewertung ist die gleiche: Oracle Corp. ist das US-Mutterunternehmen. Ob eine EU-Tochtergesellschaft tatsächlich vor einem US-Herausgabebeschluss schützt, ist rechtlich offen und nicht durch eine EU-Tochterstruktur allein auflösbar. Die Oracle EU Sovereign Cloud ist Risikotyp A (eigene US-Mutter) mit Operator-Modell-Argumentation — ähnlich wie Delos Cloud, aber ohne die BSI-CPR-Zertifizierung und ohne unabhängige staatliche Prüfung der Souveränitätsarchitektur.

Die strategische Bedeutung: Die SAP-IS-H-Abkündigung löst bis 2030 eine massive KIS-Migrationswelle aus. Oracle Cerner ist bereits in 250 deutschen Kliniken verankert und bietet den "natürlichsten" Migrationspfad auf

OCI an. Kliniken, die diesem Weg folgen, migrieren ihre sensibelsten Patientendaten von einem US-Primärsystem (i.s.h.med on-premise) auf eine US-Cloud (OCI) — ohne dass die CLOUD-Act-Exposition strukturell gelöst wird. Europäische KIS-Alternativen, die keine US-Cloud-Abhängigkeit haben: CompuGroup Medical (Medico, ~850 Installationen, DE), Dedalus (Orbis, ~830 Installationen, IT/FR), NEXUS (DE), Meierhofer (DE). Diese laufen auf europäisch kontrollierbarer Infrastruktur. [Quelle: rewion.com KIS-Marktübersicht, Stand 2022/2024]

Anbieter	C5	US-Börse / Eigentümer	US-Präsenz	Risikotyp	CLOUD-Act-Risiko	Empfehlung
Oracle Cerner (KIS i.s.h.med)	Nein	NYSE: ORCL	US-Hauptsitz Austin	**A — direkt**	[R] Hoch	Nicht für Gesundheitsdaten auf OCI
Oracle Cloud Infrastructure (OCI)	Nein (kein C5)	NYSE: ORCL	US-Muttergesellschaft	**A — direkt**	[R] Hoch	EU Sovereign Cloud-Argumentation offen

Sovereignty-Washing — warum Serverstandort nicht schützt

Das übergeordnete Muster: 25 CEOs europäischer Cloud-Anbieter warnten in einem offenen Brief an die EU-Kommission (CISPE, 17. März 2026) vor diesem Phänomen. US-Hyperscaler vermarkten EU-Rechenzentren als souveräne Lösung — aber der Serverstandort ändert nichts an der Jurisdiktion über den Provider. Die entscheidende Frage ist nicht "Wo stehen die Server?" sondern "Wer kontrolliert den Provider und unterliegt damit dem CLOUD Act?"

5.6 Frankreich — SecNumCloud-Ökosystem

Anbieter	Eigentümer	US-Präsenz	SecNumCloud	CLOUD Act	Health	Empfehlung
OVHcloud	OVH Groupe (FR, Euronext)	OVH US Corp.	[OK] Bare Metal Pod + IaaS (2026)	[R] US Corp. + Kanada-Urteil 2024	[OK] HDS	SNC-Tier für regulierte Workloads
3DS Outscale	Dassault Systèmes (FR)	Keine	[OK] 3.2 (Erster!)	[G] Sauber	[OK] HDS	Referenz FR Health
Cloud Temple	100% FR privat	Keine	[OK] IaaS + PaaS	[G] Sauber	[OK] HDS	FR KRITIS/Health
S3NS (Thales×Google)	Thales S.A. (FR)	Google = Lieferant	[OK] 3.2 Dez. 2025	[Y] Operator-Modell	—	Funktionsreichste SNC-Option; Vertex AI ab H2 2026
Scaleway	Iliad Group (FR)	Keine direkte	[OK] (in Prüfung)	[G] Weitgehend	—	Dev/KI/GPU; Mistral-Anbieter
NumSpot	Banque des Territoires et al. (FR, staatlich)	Keine	[OK] (via Outscale-Basis)	[G] Sauber	[OK] HDS	FR Public Health

OVHcloud-Vorbehalt: Kanada-Urteil 2024 — OVH-Kanada-Tochter musste europäische Serverdaten herausgeben. Zeigt strukturelles Restrisiko trotz EU-Hauptsitz. **S3NS:** Mechanismus erklärt in Kapitel 6 (Operator-Modell).

5.7 Weitere europäische Länder

Anbieter	Land/Eigentümer	US-Präsenz	Zertifizierung	CLOUD Act	Stärke
Exoscale	AT — A1/América Móvil	América Móvil (MX)	ISO 27001, SOC 2	[Y] Nicht-EU-Eigentum	Beste DBaaS-Breite (Kafka, OpenSearch, Grafana)
UpCloud	FI — privat	Keine	ISO 27001	[G] Sauber	Developer UX, 15 RZ weltweit

Anbieter	Land/Eigentümer	US-Präsenz	Zertifizierung	CLOUD Act	Stärke
Infomaniak	CH — privat	Keine	ISO 27001, CH-Recht	[G] Sauber	Ab 5,84 €/Monat; Schweizer Datenschutz (strenger als DSGVO)
Aruba Cloud	IT — Aruba SpA	Keine	ISO 27001, AgID	[G] Sauber	Größter IT-Anbieter, günstig
ELASTX	SE — privat	Keine	ISO 27001	[G] Sauber	OpenStack/Kubernetes, 100% erneuerbar
Cyso Cloud	NL — privat	Keine	ISO 27001	[G] Sauber	NL-Workloads, OpenStack

Exoscale-Vorbehalt: A1 gehört zu América Móvil (Carlos Slim, Mexiko) — kein direktes US-CLOUD-Act-Risiko, aber nicht-europäische Ultimateigentümerschaft.

5.8 Vollständige Zertifizierungsmatrix

Anbieter	BSI C5	SecNumCloud	ISO 27001	HDS	CLOUD Act	§ 393 SGB V
Oracle Cerner / OCI	—	—	—	—	[R] Direkt	[X] KIS-Migration kritisch prüfen
Microsoft Azure	[OK]	—	[OK]	—	[R] Direkt	[X] Nicht geeignet
AWS Germany	[OK]	—	[OK]	—	[R] Direkt	[X] Nicht geeignet
STACKIT	[OK] C5 Typ 2	—	[OK]	—	[Y] Unklar	Gut (Vorbehalt)
plusserver	[OK]	—	[OK]	—	[G] Sauber	**Beste DE-Option**
Open Telekom Cloud	[OK]	—	[OK]	—	[Y] Konzernhebel (C)	Mit Vorbehalt
Hetzner (EU-RZ)	[OK]	—	[OK]	—	[O] US Cloud-LLC	Dev/SMB
IONOS	[OK]	—	[OK]	—	[O] BMI-bestätigt (A-ind.)	Prüfung erforderlich
EWERK Leipzig	—	—	[OK]	—	[G] Sauber	Lokal KRITIS
Delos Cloud	BSI CPR	—	[OK]	—	[Y] Operator	M365-Org.
Arvato Systems	[OK]	—	[OK]	—	[R] Indirekt	US-Software-Risiko
OVHcloud (SNC)	[OK]	[OK]	[OK]	[OK]	[R] US Corp.	SNC-Tier
3DS Outscale	—	[OK] 3.2	[OK]	[OK]	[G] Sauber	**Referenz FR Health**
Cloud Temple	—	[OK] IaaS+PaaS	[OK]	[OK]	[G] Sauber	FR KRITIS
S3NS	—	[OK] 3.2	[OK]	—	[Y] Operator	Funktionsreich
Scaleway	—	[!] Prüfung	[OK]	—	[G] Weitgehend	Dev/KI/GPU
NumSpot	—	[OK] (Outscale)	[OK]	[OK]	[G] Sauber	FR Public Health
Exoscale	—	—	[OK]	—	[Y] MX-Eigentum	DBaaS-Stärke
UpCloud	—	—	[OK]	—	[G] Sauber	Dev/SMB
Infomaniak	—	—	[OK]	—	[G] Sauber	KMU
Aruba Cloud	—	—	[OK]	—	[G] Sauber	IT-Markt

5.9 Empfehlungen nach Anwendungsfall

> *Vollständige Entscheidungsmatrix mit Workload-Zuordnung, AVV-Klauseln und Migrationsstrategie:* ***Kapitel 17*** *(Handlungsempfehlungen).*

Tier 1 — ePA / KRITIS / § 393 Klasse 1: plusserver · EWERK Leipzig · 3DS Outscale · Cloud Temple

Tier 2 — Regulierte Enterprise-Workloads / Microsoft-Migration: STACKIT · Open Telekom Cloud (C — Konzernhebel) · Delos Cloud (+15%) · OVHcloud SNC-Tier · Scaleway (GPU/KI)

Tier 3 — Dev/Test, unkritische Workloads: Hetzner (EU-RZ) · IONOS · Infomaniak

6. Das Operator-Modell: US-Technologie unter EU-Kontrolle

6.1 Die Grundidee — und warum sie juristisch funktioniert

Frankreich hat mit S3NS (Thales × Google Cloud) einen Weg gefunden, der den scheinbaren Widerspruch auflöst: "Google Cloud kann SecNumCloud nicht erhalten" — und trotzdem trägt S3NS das Zertifikat.

Die Auflösung ist juristisch präzise: **Google LLC (Mountain View, CA)** kann SecNumCloud nie erhalten. Korrekt. Aber **S3NS SAS (Paris, Frankreich)** ist nicht Google. S3NS ist eine 100%-Thales-Tochter, die Google Cloud Technologie als Technologielizenz nutzt — wie ein Softwarehersteller, der eine Bibliothek einbindet. Google hat keine Eigentumsrechte, keine Stimmrechte, keine Kontrollbefugnis über S3NS und keinen Datenzugang.

Das Modell in der Struktur:

```
Thales S.A. (Paris, Frankreich, CAC 40)
        ↓ 100% Eigentum + vollständige Kontrolle
    S3NS SAS (Paris, Frankreich)
        ↓ Technologielizenz / API-Zugang
    Google Cloud Technologie (Compute Engine, Cloud Storage etc.)
```

ANSSI hat dieses Modell nach einem "in-depth risk assessment" als SecNumCloud-3.2-konform anerkannt — inklusive expliziter Validierung der Immunität gegen extraterritoriale Gesetze.

6.2 Die konkreten Schutzmaßnahmen im Operator-Modell

Was das Modell technisch und organisatorisch absichert:

Anforderung	Umsetzung
Eigentümer muss EU-Rechtsperson sein	S3NS = 100% Thales-Tochter, französisches Recht
Kein US-Unternehmen darf Kontrolle haben	Google hat Null Stimmrechte, kein Datenzugang
Ausschließlich EU-Personal im Betrieb	Nur S3NS-Mitarbeiter (Frankreich)
Quellcode-Kontrolle	Quarantänezone: alle Google-Updates werden von S3NS analysiert und validiert vor Deployment
CLOUD-Act-Immunität	Gilt gegen Google LLC, nicht gegen S3NS SAS
Schlüsselverwaltung	Kundenkontrollierte Schlüssel, nie bei Google

6.3 Das deutsche Pendant — Delos Cloud (SAP × Microsoft Azure)

Deutschland hat dasselbe Modell entwickelt, allerdings für Microsoft Azure statt Google Cloud, und mit SAP als Operator statt Thales:

Delos Cloud GmbH ist eine 100%-Tochter der SAP SE (Walldorf, DAX-notiert). Microsoft ist ausschließlich Technologielieferant — kein Eigentümer, kein Betreiber.

Die Kernanforderungen laut BSI Cloud Platform Requirements, die Delos erfüllt:

- Alle Daten der deutschen Verwaltung werden ausschließlich innerhalb Deutschlands verarbeitet
- Betrieb durch eine deutsche Betreibergesellschaft mit sicherheitsüberprüftem deutschem Personal
- Microsoft selbst kann in der Delos Cloud keinerlei Daten einsehen
- Updates werden erst vom BSI geprüft; das Funktionieren der Plattform ist auch bei Ablehnung bestimmter Updates gewährleistet
- Delos Cloud GmbH ist Eigentümerin der Infrastruktur, lizenziert und betreibt eigenständig

Der operative Betrieb erfolgt durch **Arvato Systems** (Bertelsmann-Tochter) — ein langjähriger Microsoft-Cloud-Partner mit Rechenzentren in Deutschland.

Preis der Souveränität: Die souveränen Microsoft-Dienste aus der Delos Cloud kosten **+15% auf die Microsoft-Listenpreise**. Das ist das messbare Kostenniveau für das Operator-Modell in Deutschland.

6.4 Weitere Operator-Modelle in Europa

Operator-Modell	Operator (EU)	US-Technologie	Zertifizierung	Markt
S3NS PREMI3NS	Thales (FR)	Google Cloud	SecNumCloud 3.2 [OK] (Dez. 2025)	FR public sector, enterprise
Delos Cloud	SAP SE (DE)	Microsoft Azure	BSI Cloud Platform Requirements	DE Verwaltung, KRITIS
Bleu	Orange + Capgemini (FR)	Microsoft Azure	SecNumCloud (in Qualifizierung)	FR public sector
T-Systems × Google	Deutsche Telekom (DE)	Google Cloud	BSI C5, Gaia-X	DE Verwaltung, Gesundheit

6.5 Kritische Bewertung — was das Modell löst und was nicht

Das Operator-Modell ist eine pragmatische Brücke zwischen Realitätsprinzip und Souveränitätsziel. Es ist kein Sovereignty-Washing — aber auch keine vollständige Souveränität.

Was gelöst ist:

- US-Behörden können nicht direkt an Microsoft/Google herantreten und Daten aus Delos/S3NS verlangen — der Operator ist eine EU-Rechtsperson ohne US-Jurisdiktion
- CLOUD Act trifft Google LLC und Microsoft Corp. — nicht Delos Cloud GmbH oder S3NS SAS
- Für Microsoft Office 365 und Azure-abhängige Organisationen, die nicht vollständig migrieren können: eine legitime Compliance-Lösung unter BSI-Aufsicht
- VS-NfD-eingestufte Verwaltungsdaten können auf Azure-Technologie verarbeitet werden — das war vorher nicht möglich

Was strukturell offen bleibt:

- Google/Microsoft liefern den Quellcode und die Software-Updates — das ist eine fundamentale Technologieabhängigkeit
- Wenn der US-Anbieter die Technologielizenz kündigt, läuft der Operator nicht mehr (strategisches Klumpenrisiko)
- Ob ein US-Gericht den Technologielieferanten zwingen könnte, eine Hintertür in einen Update einzubauen, der durch die Quarantänezone geht — juristisch offene Frage, praktisch nicht beobachtet
- Die Quarantänezone analysiert Updates auf bekannte Probleme — aber nicht auf theoretisch staatlich aufgezwungene versteckte Hintertüren

6.6 Das Souveränitätsspektrum — vier Stufen

```
FULL ISOLATION          OPERATOR MODEL          HYPERSCALER SOVEREIGN    SOVEREIGNTY WASHING
       ■                       ■                        ■                        ■
Cloud Temple (FR)         S3NS / Thales           AWS European Sovereign     AWS Frankfurt
3DS Outscale (FR)       Delos Cloud / SAP          Azure EU Boundary         Azure Deutschland
plusserver (DE)       T-Systems × Google           Google Workspace DE        Google Cloud DE
STACKIT (EU-RZ)       Bleu / Orange+Cap.
EWERK Leipzig (DE)

Eigentümer: EU          Eigentümer: EU           Eigentümer: US            Eigentümer: US
Technologie: EU/OSS     Technologie: US (lizenz)  Technologie: US           Technologie: US
CLOUD Act: kein         CLOUD Act: kein direkter  CLOUD Act: nur            CLOUD Act: direkt
Angriffspunkt           Angriff; Restfrage         Data Residency            angreifbar
```

Workload-Zuordnung und vollständige Entscheidungsmatrix: → **Kapitel 17** (Handlungsempfehlungen).

7. Das Hyperscaling-Problem: Wer kann tatsächlich skalieren?

7.1 Was Hyperscaling wirklich bedeutet

Echtes Hyperscaling hat drei Dimensionen:

- **Rohkapazität:** Millionen von Servern, globale Verfügbarkeit innerhalb von Sekunden auf Abruf
- **Service-Breite:** Nicht nur Compute/Storage, sondern hunderte spezialisierte Managed Services von KI bis IoT
- **Economies of Scale:** Hardwareeinkauf in Milliardenvolumen drückt Preise auf ein Niveau, das kein kleinerer Anbieter erreicht

7.2 Die Kapazitätslücke — ehrliche Zahlen

Hinweis zur Methodik: Physische Serverzahlen werden von Hyperscalern nicht veröffentlicht — alle Zahlen in der Spalte "GPU (H100-Äquivalente)" sind Schätzungen auf Basis von Nvidia-Umsatzdaten, Unternehmensangaben und unabhängigen Analysen (Epoch AI, LessWrong Research, Nov. 2024). Die GPU-Spalte ist für die KI-Bewertung relevanter als Serverzahlen, da GPUs die KI-Trainingsfähigkeit bestimmen.

Anbieter	RZ-Regionen / Standorte	Server (phys., geschätzt)	GPU (H100-Äquivalente, EOY 2024)	Investitionsvolumen	Services
AWS	38 Regionen, 121 AZs	~3,5 Mio.	**~400.000–600.000** (H100-Äq.)	7,8 Mrd. USD allein DE	~250 Services
Microsoft Azure	60+ Regionen	~3 Mio.	**~500.000** (H100-Äq., größte NVIDIA-Flotte)	~100 Mrd. USD/Jahr	~200 Services
Google Cloud	42 Regionen	~1,5 Mio.	**>1 Mio.** (H100-Äq. inkl. TPUs; davon ~300.000 NVIDIA H100)	—	~150 Services
Meta *(kein Cloud-Anbieter)*	Eigene RZ (USA)	k.A.	**~600.000** H100-Äq. (EOY 2024, Zuckerberg bestätigt)	—	—
xAI / Colossus *(kein Cloud)*	Memphis, Tennessee	—	**100.000 H100** (Cluster 1); Ziel 200.000 H200	—	—
Alibaba Cloud	36 Regionen	~1 Mio.	~100.000–200.000 (H100-Äq., Schätzung)	—	~100 Services
OVHcloud	4 EU-Regionen, 43 RZ	~350.000	k.A. (limitiert, keine GPU-Fokus-Strategie)	—	~50 Services
Open Telekom Cloud (T-Systems)	2 Regionen (DE+NL), 4 RZ	**~100.000** (Biere allein); 640.000 VMs	k.A. öffentlich (kein GPU-First-Anbieter)	—	~80 Services
STACKIT	4 operative RZ (DE+AT), Lübbenau ab 2027	Heute: ~15.000–25.000 (Schätzung) · Lübbenau ab 2027: **bis zu 100.000 GPUs**, 200 MW — Ausbau der Schwarz-Gruppe-Rechenleistung auf das **7-fache**	Heute: k.A. · **Ab 2027: bis zu 100.000 GPUs**	**11 Mrd. EUR** bis 2027	~40–60 Services
Hetzner	5 Standorte (DE/FI/US)	~100.000	k.A. (RTX-Pro-6000-Angebot, kein H100-Training)	—	~20 Services

Anbieter	RZ-Regionen / Standorte	Server (phys., geschätzt)	GPU (H100-Äquivalente, EOY 2024)	Investitionsvolumen	Services
plusserver	4 DE-Standorte	~20.000	k.A. (kein GPU-Cloud-Angebot)	—	~15 Services
Arvato Systems	3 eigene RZ Gütersloh + Colocation	k.A.	Nicht-Cloud-Betreiber — MSP (Managed Service Provider) auf Azure/AWS/GCP	—	MSP-Modell

Warum Meta und xAI in der Tabelle stehen — obwohl sie keine Cloud-Anbieter sind: Meta und xAI kaufen GPU-Kapazitäten in einer Größenordnung, die den gesamten europäischen Cloud-Markt in den Schatten stellt — und sie tun das ausschließlich für eigene KI-Modelle. Ende 2024 hatte Meta ein Portfolio mit einer Rechenleistung entsprechend fast 600.000 H100-Äquivalenten. xAI brachte den Colossus-Cluster mit 100.000 H100-GPUs in Memphis in 122 Tagen online. Diese Zahlen zeigen: STACKIT mit seinen geplanten 100.000 GPUs in Lübbenau ist für Europa ein Meilenstein — im globalen KI-Wettrüsten aber lediglich Aufholen.

Die GPU-Hierarchie in Zahlen (Epoch AI, Stand EOY 2024): Google: >1 Mio. H100-Äquivalente (inkl. TPUs) · Microsoft: ~500.000 H100-Äq. · Meta: ~600.000 H100-Äq. · AWS: ~400.000–600.000 H100-Äq. · STACKIT Lübbenau (ab 2027): 100.000 GPUs. Der Abstand ist erheblich — aber für die meisten GKV- und Klinik-Workloads irrelevant. Keine GKV mit 5 Millionen Versicherten braucht 600.000 GPUs.

Open Telekom Cloud — Kapazitätszahlen konkret: Die OTC verwaltet über 1 Exabyte Speicher, ermöglicht 640.000 virtuelle Maschinen mit über 4,5 Millionen GB RAM und mehr als 910.000 vCPUs. Das RZ in Biere: 20 IT-Räume, Platz für 100.000 Server, 18 Megawatt IT-Leistung. T-Systems betreibt 33 RZ weltweit — 7 im Eigenbetrieb, 26 im Colocation-Modus.

STACKIT — aktuelle Kapazität und GPU-Roadmap: Keine offiziellen Server-Zahlen. Rückrechnung aus dem Lübbenau-Faktor (7-fache Erhöhung) → schätzungsweise **15.000–25.000 physische Server** heute. Lübbenau ab 2027: 200 MW Anschlussleistung (vs. 18 MW in Biere), bis zu **100.000 GPUs** (Dell PowerEdge XE9680, NVIDIA Blackwell, 8 GPUs/Server), Direct Liquid Cooling. STACKIT wird kein Hyperscaler durch CPU-Server-Masse — sondern durch GPU-Dichte für KI-Workloads.

Arvato Systems — kein Cloud-Betreiber, sondern MSP: 3 eigene RZ in Gütersloh für Managed Services und SAP-Hosting. Kein eigenständiger Cloud-Anbieter — relevante Rolle ist der Betrieb der **Delos Cloud** als Betriebsdienstleister.

7.3 Service-Tiefe im Vergleich — gesundheitssektorrelevant

Die folgende Tabelle bewertet ausschließlich Services, die für GKVen, KVen und Kliniken tatsächlich relevant sind. Globale CDN für Streaming-Plattformen oder IoT-Hubs für Fahrzeugtelemetrie sind für den deutschen Gesundheitssektor strukturell irrelevant. Entscheidend sind: Collaboration, Identity, Datenbanken, Analytics, KI-Inferenz, Compliance-Tooling und Kerninfrastruktur.

Legende: [OK] Vorhanden und produktionsreif · [!] Vorhanden, aber eingeschränkt oder mit Mehraufwand · [X] Nicht vorhanden / kein souveräner Ersatz

A — Collaboration & Productivity (tiefstes Lock-in, höchstes CLOUD-Act-Risiko)

Service	US-Anbieter (direkt)	Operator-Modell	Souveräner EU-Ersatz
Office-Suite (Word, Excel, PowerPoint)	Microsoft 365 (MSFT)	Delos Cloud (+15%)	[OK] Euro-Office / Office.eu / LibreOffice
E-Mail & Kalender	Exchange Online (MSFT)	Delos Cloud	[OK] Open-Xchange + Thunderbird
Dokumentenmanagement / Intranet	SharePoint Online (MSFT)	Delos Cloud	[OK] Nextcloud Hub, OpenCloud 1.0, GoFAST
Videokonferenz & Chat	Microsoft Teams (MSFT)	Delos Cloud	[OK] OpenTalk, Jitsi, Matrix/Element

Service	US-Anbieter (direkt)	Operator-Modell	Souveräner EU-Ersatz
Identity / SSO / RBAC	Azure Entra ID (MSFT)	Delos Cloud	[OK] Keycloak, Univention Corporate Server
Endpoint-Management (MDM)	Microsoft Intune (MSFT)	Delos Cloud	[!] Ansible + FreeIPA (Mehraufwand)
E-Signatur	DocuSign (US), Adobe Sign (US)	—	[OK] Skribble (CH), D-Trust (BSI-akkreditiert)

B — Datenbanken & Data Warehouse (Analytics-Fundament für GKV-Scoring)

Service	US-Anbieter	Operator-Modell	Souveräner EU-Ersatz
MS SQL Server / Azure SQL	Microsoft (MSFT)	Delos Cloud	[OK] PostgreSQL, MariaDB (alle EU-Clouds)
Daten-Warehouse (Cloud-native)	Snowflake (NYSE: SNOW, US)	—	[!] DuckDB (lokal), Apache Doris, ClickHouse (EU-hosted)
Streaming / Event-Hub	AWS Kinesis, Azure Event Hub	—	[OK] Apache Kafka auf STACKIT / Exoscale
Managed NoSQL	DynamoDB, CosmosDB (MSFT)	—	[OK] MongoDB, Redis, CassandraDB auf STACKIT
Data Lake / Object Store	AWS S3, Azure Blob Storage	Delos Cloud	[OK] MinIO, Ceph, STACKIT/plusserver Object Storage
ETL / Datenpipelines	AWS Glue, Azure Data Factory	—	[OK] Apache Airflow, dbt (selbst-gehostet EU)

> ***Snowflake-Hinweis:*** *Snowflake Inc. (NYSE: SNOW) ist ein US-Unternehmen mit Hauptsitz in Bozeman/Montana und unterliegt direkt dem CLOUD Act. Daten in Snowflake-EU-Regionen (Frankfurt) sind strukturell nicht geschützt. Für GKV-Scoring-Daten und Morbi-RSA-Analysen: DuckDB on-premise oder ClickHouse auf STACKIT/plusserver sind produktionsreife Alternativen.*

> ***Qlik Cloud — C5 ≠ CLOUD-Act-Schutz:*** *Qlik (Hauptsitz King of Prussia, Pennsylvania, US) ist ein US-Unternehmen und unterliegt dem CLOUD Act als Kategorie A — unabhängig von Zertifizierungen. Ein C5-Testat, sofern Qlik Cloud eines erworben hat oder anstrebt, bescheinigt lediglich Informationssicherheit nach BSI-Mindestanforderungen — es schützt* ***nicht*** *gegen US-Behördenzugriff. Das ist die Kernaussage von Kapitel 5.3: "C5 belegt technische Sicherheit — nicht rechtliche Souveränität. Azure hat C5 und unterliegt dem CLOUD Act. plusserver hat C5 und unterliegt ihm strukturell nicht." Dasselbe gilt für Qlik Cloud. Ein C5-Testat als Eingangsbedingung nach § 393 SGB V für Patientendaten löst den CLOUD-Act-Konflikt nicht — es verschleiert ihn. Für GKV-Analytics und Versorgungssteuerungsdaten mit Patientenbezug: Qlik on-premise (selbst betriebene Instanz ohne US-Cloud-Verbindung) oder EU-souveräne BI-Alternativen (Metabase, Apache Superset, Grafana) auf STACKIT/plusserver.*

C — KI & Analytik (zunehmend kritisch für GKV-Versorgungsmanagement)

Service	US-Anbieter	Operator-Modell	Souveräner EU-Ersatz
LLM-Inferenz / generative KI	Azure OpenAI / AWS Bedrock (GPT-4, Claude)	S3NS (Google Vertex AI ab H2 2026)	[OK] vLLM + Mistral (lokal / STACKIT / Scaleway)
Mistral AI direkt	Mistral API (FR-Unternehmen, aber API-Infrastruktur prüfen)	—	[OK] Mistral-Modelle self-hosted via vLLM (bevorzugt)
BI / Dashboarding	Power BI / Microsoft Fabric (MSFT) · **Qlik Cloud (US, Thoma Bravo — privat)**	Delos Cloud (Power BI)	[OK] Metabase, Apache Superset, Grafana

Service	US-Anbieter	Operator-Modell	Souveräner EU-Ersatz
ML-Plattform / MLOps	Azure ML, AWS SageMaker	—	[!] MLflow + Kubernetes (selbst-gehostet)
Vektordatenbank (RAG)	Azure AI Search, Pinecone (US)	—	[OK] Qdrant (DE), Weaviate (NL), Chroma (self-hosted)
Embedding-Modelle	OpenAI text-embedding, AWS Titan	—	[OK] Sentence-Transformers lokal, Mistral Embed

> ***Mistral-Hinweis:*** *Mistral AI ist ein französisches Unternehmen (Paris, SAS) — kein US-CLOUD-Act-Risiko strukturell. Die Mistral-API läuft jedoch auf Scaleway-Infrastruktur. Für höchste Schutzklasse (ePA-Daten): Mistral-Modelle lokal über vLLM deployen, nicht via API. Für unkritische Workloads ist die Mistral-API akzeptabel.*

D — Infrastruktur & DevOps (Basis-Schicht)

Service	US-Anbieter	Souveräner EU-Ersatz
Compute / VM	EC2, Azure VM	[OK] STACKIT, plusserver, Hetzner
Managed Kubernetes	EKS, AKS	[OK] STACKIT SKE, plusserver managed K8s
Serverless / Functions	Lambda, Azure Functions	[!] STACKIT Functions (früh), Knative self-hosted
CI/CD & Versionskontrolle	GitHub, Azure DevOps	[OK] GitLab (self-hosted)
Monitoring & Observability	Azure Monitor, CloudWatch	[OK] Grafana + Prometheus + Loki + OpenSearch
SIEM / Security	Microsoft Sentinel (MSFT)	[OK] Wazuh, OpenSearch Security Analytics
Backup & DR	Azure Backup, AWS Backup	[OK] Veeam auf EU-Storage, Restic

E — Compliance & Gesundheitsspezifisch

Service	US-Anbieter	Souveräner EU-Ersatz
ePA-Infrastruktur	gematik-Pflicht: TI-Anbindung	[OK] nur zertifizierte TI-Anbieter (kein US-Hyperscaler direkt)
KIS (Krankenhausinformationssystem)	Oracle Health / Cerner (US!)	[!] CGM, iMedOne, SAP IS-H (DE/EU)
PVS (Praxisverwaltungssystem)	US-Abhängigkeit über KIS-Backend	[OK] Medatixx, Turbomed, CompuMed (DE)
Abrechnungssystem GKV	SAP IS-H, Eigensysteme	[OK] SAP on-premise oder EU-Cloud
Dokumentenarchiv / §630f BGB	SharePoint/Azure (MSFT)	[OK] OpenCloud, d.velop, Fabasoft (AT)

> ***Oracle Health / Cerner-Warnung:*** *Oracle Corporation (NYSE: ORCL) hat Cerner 2022 für 28 Mrd. USD übernommen. Cerner-Systeme (u.a. in UKL Dresden, UKL Freiburg geplant) laufen mittlerweile auf Oracle Cloud Infrastructure (OCI) — einem US-Cloud-Anbieter mit direktem CLOUD-Act-Risiko. Für Kliniken, die Cerner/Oracle Health evaluieren: OCI ist strukturell gleichwertig mit Azure aus CLOUD-Act-Perspektive.*

7.4 Was das für den Gesundheitssektor bedeutet

Keine GKV mit 5 Millionen Versicherten braucht 3,5 Millionen Server. STACKIT ist heute bereits ausreichend skaliert für GKV- und Klinik-Kernworkloads. Lücken bestehen bei Data Warehouse (Snowflake-Ebene), MLOps-Plattformen und Endpoint-Management — nicht bei Kapazität.

Die vier größten blinden Flecken der aktuellen Souveränitätsdebatte im Gesundheitswesen: 1. **Snowflake** für GKV-Analytics — NYSE: SNOW, US-Hauptsitz, direktes CLOUD-Act-Risiko trotz Frankfurter Region 2. **Oracle**

Health / Cerner auf OCI für Kliniken — NYSE: ORCL, strukturell gleichwertig mit Azure aus CLOUD-Act-Perspektive 3. **Qlik Cloud** für GKV-BI und Versorgungssteuerung — US-Unternehmen (PA, Thoma Bravo), Kategorie A; Qlik Cloud läuft auf AWS und hat EU-Regionen in Frankfurt, Irland, Paris, London und Mailand — die Frankfurt-Region ändert die US-Jurisdiktion nicht; BSI C5-Testat noch nicht erteilt (Stand April 2026), schützt ohnehin nicht gegen CLOUD Act 4. **KI-Dienste** (Azure OpenAI, Google Gemini, AWS Bedrock) — verarbeiten Patientendaten zwangsläufig im Klartext; clientseitige Verschlüsselung unmöglich; cloudbasierte Integrationsplattformen (Zapier, Power Automate) als versteckte Datenflüsse. Ausführlich analysiert in §7.5.

Die ersten drei werden in der Praxis kaum als CLOUD-Act-Risiko diskutiert — obwohl sie tägliche Kernsysteme für Gesundheitsdaten betreiben. Der vierte wächst am schnellsten.

7.5 KI-Anbieter und Integrationsplattformen — der blinde Fleck bei Klartextverarbeitung

Die Tabelle in §7.3 C zeigt die Anbieter-Landschaft für KI-Services. Dieser Abschnitt behandelt ein spezifischeres Problem: **KI-Dienste verarbeiten Eingabedaten zwangsläufig im Klartext.** Verschlüsselung hilft nicht (vgl. §13.4) — ein LLM muss den Prompt lesen, ein Sprachmodell muss das Audio hören, ein Zusammenfassungsmodell muss den Text verstehen. Das unterscheidet KI-Services fundamental von Speicher- oder Compute-Diensten, bei denen clientseitige Verschlüsselung die Exposition begrenzen kann.

Gesundheitsspezifische KI-Anwendungsfälle und ihre CLOUD-Act-Exposition

Im Gesundheitswesen entstehen gerade vier KI-Anwendungsmuster, die alle Klartextverarbeitung **sensibler Patientendaten** erfordern:

1. Transkription und Zusammenfassung von Arzt-Patienten-Gesprächen. Ambient-Listening-Systeme wie Nuance DAX (Microsoft/MSFT), Nabla (FR), oder Google-Gemini-basierte Lösungen zeichnen das Gespräch auf und erzeugen automatisch eine strukturierte Dokumentation. Die Audiodaten — Stimme des Patienten, Symptombeschreibungen, Diagnosen — werden an den KI-Dienst übertragen und dort im Klartext verarbeitet. Bei US-Anbietern sind diese Rohdaten CLOUD-Act-exponiert.

2. Automatisierte Arztbriefe. LLMs generieren Entlassungsbriefe, Befundberichte oder Überweisungsschreiben auf Basis der Patientenakte. Die Eingabe umfasst Diagnosen, Medikation, Verlaufsdaten — die sensibelsten Daten im Gesundheitswesen. Wenn der LLM-Service bei einem US-Anbieter läuft, liegen diese Daten während der Verarbeitung im Klartext auf US-kontrollierter Infrastruktur.

3. E-Mail- und Dokumentenzusammenfassung. Microsoft Copilot, Google Gemini oder vergleichbare Assistenten fassen E-Mails, Aktenvermerke und Dokumente zusammen. Im GKV-Kontext können diese E-Mails Versichertendaten, Leistungsanträge oder MDK-Gutachten enthalten. Die KI liest den vollständigen Inhalt — HYOK ist nicht möglich (vgl. §13.4).

4. KI-gestützte Kodierung und Abrechnung. ICD-10-Kodierung, DRG-Gruppierung oder Morbi-RSA-Prüfungen auf Basis von KI erfordern die Übermittlung klinischer Informationen an den KI-Dienst. Systeme wie 3M/Solventum (US), ID Berlin (DE) oder DeepL-basierte Übersetzungsdienste für mehrsprachige Patientenakten verarbeiten jeweils Patientendaten im Klartext.

CLOUD-Act-Risikobewertung der großen KI-Anbieter

Anbieter	Eigentümer	Infrastruktur	CLOUD-Act-Risiko	Gesundheitseinsatz
OpenAI (GPT-4o, o3)	US (Microsoft-Partnerschaft)	Azure (MSFT)	[R] Direkt — US-Unternehmen auf US-Infrastruktur	Azure OpenAI Service in KVNO-KI-Plattform (TED 98706-2026)
Google Gemini	NYSE: GOOGL	Google Cloud (US)	[R] Direkt	Ambient Clinical Intelligence in Pilotprojekten
Anthropic (Claude)	US (Amazon-Beteiligung)	AWS / GCP	[R] Direkt — US-Unternehmen	Enterprise-API für Dokumentenanalyse

Anbieter	Eigentümer	Infrastruktur	CLOUD-Act-Risiko	Gesundheitseinsatz
Microsoft Copilot	NYSE: MSFT	Azure (US)	[R] Direkt	M365-Integration in Kliniken/GKVen
Nuance DAX (Microsoft)	NYSE: MSFT (Übernahme 2022, 18,8 Mrd. USD)	Azure (US)	[R] Direkt	Marktführer klinische Sprachdokumentation
DeepSeek	CN (Hangzhou)	China-basiert	[R] Nicht CLOUD Act, aber CN-Datengesetze	Open-Source-Modelle lokal deploybar
Mistral AI	FR (Paris, SAS)	Scaleway (FR)	[G] EU-souverän	Self-hosted oder API; bevorzugte EU-Option
Aleph Alpha (Luminous)	DE (Heidelberg)	IONOS / STACKIT	[G] EU-souverän (DE)	BW-Verwaltung; Gesundheitssektor noch begrenzt
Kimi (Moonshot AI)	CN (Peking)	China-basiert	[R] Nicht CLOUD Act, aber CN-Datengesetze	Kimi 2.5 — leistungsfähig, aber chinesische Jurisdiktion
OpenEuroLLM	EU-Konsortium (13 Partner)	EuroHPC (LUMI, Leonardo)	[G] EU-souverän	Forschung; produktiver Einsatz ab 2026

Integrationsplattformen — der versteckte Datenfluss

Neben den KI-Anbietern selbst entsteht ein zweites, oft übersehenes Risiko durch **cloudbasierte Integrationsplattformen**:

Plattform	Eigentümer	CLOUD-Act-Risiko	Typischer Einsatz im Gesundheitswesen
Zapier	US (San Francisco)	[R] Direkt	Automatisierung: "Wenn neue E-Mail mit Befund, dann an KI-Zusammenfassung"
Make (Integromat)	CZ (Prag)	[G] EU-souverän	Workflow-Automatisierung, EU-Alternative zu Zapier
Microsoft Power Automate	NYSE: MSFT	[R] Direkt	M365-Workflows: Dokumentenfreigabe, Benachrichtigungen mit Patientendaten
n8n	DE (Berlin)	[G] EU-souverän (self-hosted möglich)	Open-Source-Automatisierung; self-hosted auf EU-Infrastruktur bevorzugt
IFTTT	US (San Francisco)	[R] Direkt	Consumer-Automatisierung, vereinzelt in Praxis-IT

Das Problem: Integrationsplattformen sind **Datendrehscheiben**. Sie lesen, transformieren und weiterleiten Daten zwischen Systemen — häufig einschließlich Patientendaten, Termindetails, Befunde, Abrechnungsinformationen. Eine Zapier-Automatisierung, die E-Mails mit Befunden an eine GPT-Zusammenfassung weiterleitet, erzeugt eine **doppelte CLOUD-Act-Exposition**: einmal bei Zapier (US), einmal bei OpenAI (US). n8n (self-hosted auf EU-Infrastruktur) + Mistral (self-hosted oder Scaleway) ist die souveräne Alternative für denselben Workflow.

Kernaussage — warum KI der vierte blinde Fleck ist

Die ersten drei blinden Flecken (Snowflake, Oracle Health, Qlik Cloud — §7.4) betreffen klassische Datenhaltung und Analytics. Der vierte blinde Fleck ist gravierender: **KI-Dienste verarbeiten die sensibelsten Daten im Gesundheitswesen — Arzt-Patienten-Gespräche, Diagnosen, Behandlungsverläufe — zwangsläufig im Klartext.** Clientseitige Verschlüsselung, die bei Datenspeichern funktioniert, versagt hier strukturell. Wer eine Transkriptions-KI oder einen Arztbrief-Generator auf Azure OpenAI, Google Gemini oder AWS Bedrock betreibt, übergibt die unverschlüsselten Rohdaten an eine CLOUD-Act-exponierte Infrastruktur.

Die souveräne Alternative existiert: Mistral-Modelle (oder vergleichbare Open-Source-LLMs) lassen sich über vLLM auf STACKIT, plusserver oder eigenem GPU-Cluster betreiben — vollständig innerhalb EU-Jurisdiktion, ohne API-Calls an US-Anbieter. Für Sprachtranskription: Whisper (OpenAI, aber Open-Source-Modell, lokal deploybar) auf eigener GPU. Für Integrationsplattformen: n8n (self-hosted, Berlin) statt Zapier. Der Funktionsumfang ist für 80 % der Gesundheits-KI-Anwendungsfälle ausreichend — und wächst mit jeder Mistral/Llama-Generation.

Vier Fallbeispiele — das Spektrum von [R] bis [G]

Die Theorie wird greifbar an konkreten Produkten, die heute im deutschen Gesundheitswesen eingesetzt werden oder werden sollen:

Plaud AI (CN/US) — [R] Dreifache Exposition. Plaud ist ein chinesisches Unternehmen (Shenzhen), das KI-gestützte Aufnahmegeräte für Arzt-Patienten-Gespräche vermarktet. Die Audiodaten werden zur Transkription an AWS US West (Oregon) übertragen und dort über OpenAI Whisper V3 und GPT verarbeitet. Plaud wirbt mit GDPR-Compliance, SOC 2 und HIPAA — verschweigt aber die strukturelle Dreifachexposition: chinesischer Eigentümer (CN-Datengesetze), US-Cloud-Infrastruktur (AWS Oregon, CLOUD Act) und US-KI-Backend (OpenAI). "Zero Data Retention" beim LLM-Provider bedeutet: nicht gespeichert nach Verarbeitung — aber während der Verarbeitung liegt die Stimme des Patienten im Klartext auf US-Servern. Für Gesundheitsdaten nach § 393 SGB V: nicht geeignet.

Tandem Health (SE) — [Y] EU-Firma mit US-KI-Backend. Tandem Health (Stockholm, $50 Mio. Funding) ist ein schwedisches Unternehmen, das KI-gestützte Dokumentation für Kliniken anbietet — aktuell expandierend nach Deutschland (Partnerschaft mit Eterno). Tandem nutzt OpenAI Whisper für Transkription und GPT-4 für Zusammenfassung. Audio wird nach Transkription gelöscht, keine Modeltraining auf Patientendaten (ISO 27001, ISO 13485, GDPR). Alle Daten sollen "ausschließlich in europäischen Rechenzentren" verarbeitet werden. Die offene Frage: Ob die OpenAI-Modelle via Azure OpenAI EU (Microsoft-Jurisdiktion, vgl. §5.3) oder über die direkte OpenAI-API (US-Server) angebunden sind, ist nicht öffentlich dokumentiert. Im besten Fall (Azure EU): Microsoft-CLOUD-Act-Restrisiko wie bei den KI-Brokern. Im schlechtesten Fall (direkte API): US-Serververarbeitung.

Doctolib (FR/AWS) — [Y] Strukturelles Restrisiko trotz Verschlüsselung. Doctolib (Paris, bereits in §12.5 bewertet) hostet auf AWS Frankfurt und Paris, hat BSI C5 Typ 2 seit 2025 und verschlüsselt Gesundheitsdaten zusätzlich auf Applikationsebene (AES-256, HSM-Schlüsseltrennung über HashiCorp). Ein französisches Gericht wertete dies 2021 als ausreichend. Aber: AWS (NASDAQ: AMZN) unterliegt dem CLOUD Act, HashiCorp (NYSE: HCP) ebenfalls — Serverstandort Frankfurt ändert die Jurisdiktion über den Provider nicht. Die Applikationsverschlüsselung schützt ruhende Daten, aber Doctolibs SaaS-Funktionen (Terminbuchung, Patientenkommunikation, Videosprechstunde) erfordern Klartextverarbeitung im laufenden Betrieb. C5 Typ 2 belegt technische Sicherheit — nicht CLOUD-Act-Immunität.

Averbis (DE) — [Y] Souveräne NLP, aber Azure OpenAI für Arztbriefe. Averbis (Freiburg, Spin-off Universitätsklinikum 2007) bietet zwei Produkte mit fundamental unterschiedlichem Risikoprofil: **Health Discovery** (NLP/Informations-Extraktion) läuft als eigene Engine on-premise im Krankenhaus-Netzwerk — strukturell souverän, keine US-Abhängigkeit. **Medical Summary** (automatische Arztbrief-Generierung) nutzt jedoch **Azure OpenAI in der EU Datazone**, wie das Architekturdiagramm von Averbis selbst zeigt: Patientendaten (PID, Diagnosen, Laborwerte, Medikation) fließen aus dem Krankenhaus-Netzwerk an Azure OpenAI, wo sie "temporär verarbeitet" werden. Das ist exakt das Muster, das §5.3 beschreibt: Azure EU-Region ändert nichts an der Microsoft-Jurisdiktion. CLOUD Act greift über die Unternehmensstruktur, nicht den Serverstandort. Für die reine NLP-Extraktion (Health Discovery on-premise) bleibt Averbis souverän. Für die generative KI-Funktion (Medical Summary) gilt dasselbe Restrisiko wie bei allen Azure-OpenAI-basierten Diensten.

Anbieter	Sitz	KI-Backend	Infrastruktur	Risiko	Eignung § 393 Klasse 1
Plaud AI	CN (Shenzhen)	OpenAI Whisper + GPT (US)	AWS Oregon (US)	[R] Dreifach (CN + US-Cloud + US-KI)	[X] Nicht geeignet

Anbieter	Sitz	KI-Backend	Infrastruktur	Risiko	Eignung § 393 Klasse 1
Tandem Health	SE (Stockholm)	OpenAI Whisper + GPT-4	"EU-Rechenzentren" (Details offen)	[Y] EU-Firma, aber OpenAI-Abhängigkeit	[!] Nur wenn Azure EU + Risikoakzeptanz
Recare Voice	DE (Berlin)	Nicht offengelegt	EU (ISO 27001, C5 Typ 2)	[Y] DE-Firma, EU-Hosting, aber KI-Backend unklar	[!] KI-Modell-Transparenz einfordern
Doctolib	FR (Paris)	Eigene Plattform	AWS Frankfurt/Paris (C5 Typ 2)	[Y] FR-Firma auf US-Infra, verschlüsselt	[!] Verschlüsselung reduziert, eliminiert nicht
myScribe	DE (Mannheim)	"Eigenes NLP" laut Website — KI-Backend nicht verifiziert	KIS-Add-on (HL7-FHIR)	[Y] DE-Firma, KIS-Integration, aber KI-Modell unklar	[!] KI-Backend vertraglich klären
Averbis	DE (Freiburg)	Health Discovery: eigene NLP; Medical Summary: **Azure OpenAI** (EU Datazone)	On-Premise NLP + Azure OpenAI extern	[Y] NLP souverän, aber Arztbrief-KI auf Azure OpenAI	[!] Medical Summary: Microsoft-CLOUD-Act-Risiko
hAIppokrates (Greenbay)	DE (Leipzig)	GPT + Whisper **lokal on-premise**	UKL-eigenes Rechenzentrum	[G] Vollständig souverän — kein externer API-Call	[OK] Alle Patientendaten bleiben im Klinikum

Recare Voice — das Transparenzproblem. Recare Deutschland GmbH (Berlin, €37 Mio. Funding, DNV als größter Anteilseigner) bietet mit Recare Voice KI-gestützte Echtzeit-Dokumentation von Patientengesprächen für über 1.000 Krankenhäuser. Die Plattform ist ISO 27001- und BSI-C5-Typ-2-zertifiziert, verarbeitet Daten in Europa und wirbt mit "Zero Knowledge"-Architektur. Das Problem: **Welches Sprachmodell die Transkription und Zusammenfassung antreibt, ist nicht öffentlich dokumentiert.** Wenn Recare im Backend OpenAI Whisper oder GPT nutzt (direkt oder via Azure), gelten dieselben Vorbehalte wie bei Tandem Health. Wenn ein eigenes oder EU-gehostetes Modell verwendet wird, wäre das Risikoprofil deutlich besser. Für Kliniken, die Recare Voice evaluieren: Die Frage "Welches KI-Modell verarbeitet unsere Patientengespräche, und auf welcher Infrastruktur?" muss vertraglich beantwortet sein — nicht auf der Marketingseite.

myScribe — KIS-Integration, aber KI-Backend unklar. myScribe GmbH (Mannheim, gegründet von der Ärztin Ira Stoll am Universitätsklinikum Heidelberg) generiert mehrseitige Arztbriefe aus Visite-Notizen, Laborbefunden, Bildgebung, Diagnosen und Medikation über HL7-FHIR-Schnittstellen zum KIS. Die Website behauptet ein "eigenentwickeltes NLP-Modell" — aber ein Startup mit ~14 Mitarbeitenden, das mehrseitige Fließtext-Arztbriefe in Sekundenbruchteilen generiert, setzt mit hoher Wahrscheinlichkeit ein großes Sprachmodell (GPT, Claude oder vergleichbar) als Backend ein. **Welches Modell die Textgenerierung antreibt und auf welcher Infrastruktur es läuft, ist nicht öffentlich dokumentiert.** Für Kliniken gilt dieselbe Empfehlung wie bei Recare Voice: Das KI-Backend muss vertraglich offengelegt sein, bevor Patientendaten verarbeitet werden. Wenn myScribe im Hintergrund Azure OpenAI nutzt, gelten dieselben Vorbehalte wie bei Averbis Medical Summary.

hAIppokrates (Greenbay Healthcare, Leipzig) — [G] Der Beweis, dass es geht. hAIppokrates ist ein KI-System für Arztbrief-Generierung und Transkription von Arzt-Patienten-Gesprächen, das **vollständig on-premise im Rechenzentrum des Universitätsklinikums Leipzig (UKL)** betrieben wird. Die Architektur: GPT als Sprachmodell und OpenAI Whisper als Transkriptionsengine laufen lokal auf klinikeigener Hardware — kein API-Call an OpenAI, kein Azure, kein externer Cloud-Dienst. Alle Patientendaten (Diagnosen, Medikation, Gesprächsaufnahmen, Laborwerte) sind dem lokalen Modell verfügbar, verlassen aber zu keinem Zeitpunkt das Krankenhaus-Netzwerk. Das System wurde von der Greenbay Healthcare GmbH (Leipzig) in Zusammenarbeit mit 4K Analytics GmbH und dem UKL entwickelt. Nach einer erfolgreichen Pilotphase mit über 100 Nutzern befindet sich hAIppokrates im Roll-out.

Warum das wichtig ist: hAIppokrates widerlegt die verbreitete Annahme, dass generative KI im Gesundheitswesen zwangsläufig US-Cloud-Infrastruktur erfordert. GPT-Modelle und Whisper sind als

Open-Source- oder Open-Weight-Modelle verfügbar und lokal deploybar — die Infrastruktur (GPU-Server im eigenen RZ) ist die Investition, nicht die Modellverfügbarkeit. Was das UKL Leipzig vormacht, können andere Kliniken und GKVen nachbauen: **Souveräne generative KI für Gesundheitsdaten ist kein Zukunftsversprechen — sie läuft produktiv in einem deutschen Universitätsklinikum.**

> ***Transparenzhinweis:*** *Greenbay Healthcare GmbH und 4K Analytics GmbH (Herausgeber dieses Dokuments) gehören zum selben Unternehmensverbund. Die Bewertung folgt denselben Kriterien wie bei allen anderen Anbietern: Eigentümerschaft, Infrastruktur-Standort, KI-Backend, Datenfluss. Die On-Premise-Architektur des UKL Leipzig ist durch die IT-Abteilung des UKL verifizierbar.*

> ***Das Muster:*** *Plaud demonstriert das Worst-Case: CN-Firma sendet Arzt-Patienten-Audio an US-Server und US-KI. Averbis zeigt die* ***typische Hybridlösung****: eigene NLP souverän, generative KI auf Azure OpenAI. myScribe und Recare Voice zeigen das* ***Transparenzproblem****: deutsche Firmen, die ihr KI-Backend nicht offenlegen. hAIppokrates am UKL Leipzig zeigt den* ***souveränen Weg****: GPT und Whisper lokal on-premise, alle Patientendaten im Klinik-Netzwerk, kein US-Cloud-Kontakt. Der Unterschied ist nicht das Modell — sondern wo es läuft.*

Vibecoding-Plattformen — KI-Entwicklung mit doppelter Bindung

Ein wachsender Trend im Gesundheitswesen: Fachabteilungen und IT-Teams nutzen KI-gestützte Entwicklungsplattformen ("Vibecoding"), um interne Tools, Dashboards oder Patientenportale per natürlichsprachigem Prompt zu erstellen — ohne klassische Softwareentwicklung. Das CLOUD-Act-Problem ist hier **doppelt**:

Erstens — die KI im Hintergrund. Vibecoding-Plattformen nutzen große Sprachmodelle (typischerweise GPT-4o, Claude oder Gemini) als Code-Generatoren. Jeder Prompt — "Erstelle eine Anwendung, die Patientendaten aus unserem KIS lädt und eine Übersicht nach ICD-10-Diagnosen erstellt" — wird an den KI-Dienst übertragen und dort im Klartext verarbeitet. Die Prompts enthalten Geschäftslogik, Datenstrukturen, API-Schlüssel, und beschreiben im Detail, wie die Organisation Patientendaten verarbeitet. Bei US-KI-Anbietern sind diese Prompts CLOUD-Act-exponiert.

Zweitens — die Plattform als Laufzeitumgebung. Der entscheidende Unterschied zu klassischen KI-Assistenten: Vibecoding-Plattformen sind darauf ausgelegt, dass die erstellten Anwendungen **auf der Plattform gehostet bleiben** — nicht exportiert und selbst betrieben werden. Lovable, Bolt, Replit und v0 bieten integrierten Hosting-Service: Die Anwendung wird auf der Plattform entwickelt, getestet und produktiv betrieben. Wenn diese Anwendung Patientendaten verarbeitet, liegen die Daten dauerhaft auf der Plattform-Infrastruktur — und unterliegen der Jurisdiktion des Plattformbetreibers.

Plattform	Eigentümer	KI-Backend	Hosting	CLOUD-Act-Risiko
Lovable	SE (Stockholm)	GPT-4o / Claude (US)	Plattform-hosted (AWS/Vercel)	[Y] EU-Eigentümer, aber US-KI + US-Hosting-Infrastruktur
Bolt.new (StackBlitz)	US (San Francisco)	GPT-4o / Claude (US)	StackBlitz Cloud (US)	[R] Direkt — US-Unternehmen, US-KI, US-Hosting
Replit	US (San Francisco)	Eigene + GPT-4o (US)	Replit Cloud (GCP, US)	[R] Direkt — US-Unternehmen auf Google Cloud
v0 (Vercel)	US (San Francisco)	GPT-4o (US)	Vercel Edge (AWS, US)	[R] Direkt — US-Unternehmen, US-Infrastruktur
Cursor	US (San Francisco)	GPT-4o / Claude (US)	Lokale IDE, aber Prompts an US-KI	[O] Code bleibt lokal, Prompts an US-Cloud

Plattform	Eigentümer	KI-Backend	Hosting	CLOUD-Act-Risiko
GitHub Copilot	US (Microsoft/GitHub)	GPT-4o (US)	Cloud-basiert (Azure)	[R] Direkt — Microsoft-Tochter
Windsurf (Codeium)	US (Mountain View)	Eigene Modelle (US)	Cloud-basiert	[R] Direkt — US-Unternehmen

Das Muster: Bei Lovable (schwedischer Eigentümer) entsteht der Eindruck eines EU-Produkts. Aber die KI-Verarbeitung läuft über US-Modelle (OpenAI/Anthropic), und das Hosting der fertigen Anwendungen erfolgt typischerweise auf AWS oder Vercel — beides US-Infrastruktur. Der EU-Eigentümer ändert nichts an der US-Jurisdiktion über die Datenverarbeitung. Bei Bolt, Replit und v0 ist die Kette durchgängig US: US-Unternehmen → US-KI → US-Hosting.

Warum das im Gesundheitswesen relevant ist: Der Vibecoding-Trend senkt die Hürde für Fachanwendungen drastisch. Eine GKV-IT-Abteilung kann in Stunden ein internes Analysetool bauen, das Versichertendaten visualisiert. Eine Klinik-Verwaltung erstellt ein Patientenportal per Prompt. Das Problem: Wenn diese Anwendungen auf der Plattform verbleiben und Patientendaten verarbeiten, entsteht eine dauerhafte CLOUD-Act-Exposition, die weder durch C5 noch durch die DSGVO-Einwilligung des Patienten gedeckt ist.

Base44 (Wix): Eine Sonderstellung nimmt Base44 ein — ein Vibecoding-Tool, das 2025 von Wix (NASDAQ: WIX, Israel/US) übernommen wurde. Base44 wählt automatisch zwischen Claude Sonnet und Gemini 2.5 Pro, bietet integriertes Hosting mit Datenbank und Authentifizierung. Die gesamte Anwendung verbleibt auf der Plattform. Da Wix an der NASDAQ gelistet und US-kontrolliert ist, gilt für Base44-gehostete Anwendungen mit Patientendaten dasselbe Risiko wie für andere US-Plattformen — unabhängig davon, wo die Server stehen.

Die souveräne Alternative: Für die Entwicklungsphase können Open-Source-KI-Assistenten (Mistral Codestral, StarCoder, lokal via Continue.dev oder Tabby) auf eigener Infrastruktur genutzt werden. Entscheidend ist die Trennung: KI-gestütztes Entwickeln auf EU-Infrastruktur, Hosting der fertigen Anwendung auf EU-Infrastruktur (STACKIT, plusserver, eigenes RZ). Die Plattform-Bequemlichkeit von Lovable oder Replit geht verloren — aber die Datenhoheit bleibt gewahrt. Für unkritische Anwendungen ohne Patientendaten (interne Dashboards, öffentliche Informationsseiten) ist das Risiko geringer, aber auch hier sollte die Plattformwahl dokumentiert werden.

KI-Broker — das DSGVO-Versprechen und seine Grenzen

Ein wachsender Markt deutscher und europäischer Anbieter verspricht "DSGVO-konforme KI" für Unternehmen: sogenannte KI-Broker oder KI-Gateways, die als Zwischenschicht zwischen der Organisation und den großen Sprachmodellen (OpenAI, Claude, Gemini) fungieren. Das Versprechen klingt überzeugend: **EU-gehostet, ISO 27001-zertifiziert, DSGVO-konform — und trotzdem GPT-4o, Claude und Gemini nutzen.** Für den Gesundheitssektor ist dieses Versprechen kritisch zu hinterfragen.

Das Grundproblem: Ein KI-Broker kann die eigene Plattform DSGVO-konform betreiben — Nutzerauthentifizierung, Audit-Logs, Datenverarbeitung in der EU. Aber wenn der Prompt mit Patientendaten an ein US-Sprachmodell weitergeleitet wird, verlässt er die EU-Jurisdiktion — zumindest für die Dauer der Verarbeitung. Die Optionen der Broker:

1. **Direkte OpenAI-API (US-Server):** Prompt geht an OpenAI in den USA. "Zero Data Retention" (OpenAI speichert nichts nach Verarbeitung) — aber während der Verarbeitung liegen die Daten im Klartext auf US-Infrastruktur und sind CLOUD-Act-exponiert. 2. **Azure OpenAI (EU-Region, z.B. Schweden/Frankfurt):** Prompt bleibt physisch in der EU, aber Azure ist ein Microsoft-Dienst (MSFT) — CLOUD Act greift über die Unternehmensstruktur, nicht den Serverstandort (vgl. §1.1). 3. **Self-hosted Modelle (Mistral, Llama):** Kein US-Anbieter involviert — die einzige Option ohne CLOUD-Act-Exposition. Aber nicht alle Broker bieten das an, und die Modellqualität ist für manche Anwendungsfälle noch eingeschränkt.

Die meisten KI-Broker nutzen Option 1 oder 2 — und kommunizieren das als "DSGVO-konform", weil sie einen Auftragsverarbeitungsvertrag (AVV) mit OpenAI/Microsoft haben und das DPF als Rechtsgrundlage anführen. Für den Gesundheitssektor ist das aus denselben Gründen unzureichend, die §1.2 und §9 dokumentieren: Das

DPF ist anfechtbar (Schrems III), der AVV schützt nicht vor CLOUD-Act-Herausgabepflichten, und "Zero Data Retention" bedeutet "nicht gespeichert" — nicht "nicht verarbeitet".

KI-Broker / Gateway	Sitz	KI-Backend	Hosting	CLOUD-Act-Risiko des KI-Backends
Langdock	DE (Berlin)	OpenAI, Claude, Mistral, Aleph Alpha	EU (ISO 27001, SOC 2)	[Y] EU-Plattform, aber Prompts an US-Modelle (je nach Konfiguration)
DeutschlandGPT	DE (Berlin)	GPT-4o, Claude, Gemini, Mistral, Llama	Open Telekom Cloud (DE, C5)	[Y] DE-Hosting, aber GPT/Claude-Prompts via Azure/API an US-Modelle
meinGPT	DE	OpenAI (Azure EU), Claude, Mistral	DE-hosted	[Y] Azure OpenAI EU = Microsoft-Jurisdiktion
Plotdesk	DE	GPT-4o via Azure OpenAI (EU)	EU	[Y] Explizit Azure OpenAI — Microsoft-CLOUD-Act-Risiko bleibt
Omnifact	DE	Diverse; Privacy Filter™ maskiert Daten vor KI-Übergabe	EU	[Y] Maskierung reduziert Exposition, löst Grundproblem nicht (s.u.)
Neuroflash	DE (Hamburg)	GPT-4o, eigene Modelle	EU	[Y] OpenAI-Abhängigkeit für Kernfunktionen
kamium	DE	ChatGPT, Gemini, Claude, Perplexity	Eigener Azure-Tenant (EU)	[Y] Azure = Microsoft-Jurisdiktion
Dust.tt	FR (Paris)	OpenAI, Claude, Mistral, Gemini	EU/US (wählbar, SOC 2)	[Y] EU-Hosting wählbar, aber US-Modelle verarbeiten Prompts
nexos.ai	LT (Vilnius)	200+ Modelle (OpenAI, Claude, Mistral…)	EU (ISO 27001, SOC 2)	[Y] EU-Gateway, US-Modelle im Backend

Omnifact-Sonderfall — und warum Maskierung kein Souveränitätsersatz ist: Omnifact bietet als einziger Broker in dieser Übersicht einen "Privacy Filter", der sensible Daten (Namen, Diagnosen, Versichertennummern) **vor** der Übergabe an das KI-Modell maskiert. Die Rücktransformation erfolgt lokal. Das klingt nach Lösung — bei genauerer Analyse bleiben jedoch fünf strukturelle Probleme:

1. **Kontextuelle Re-Identifizierbarkeit.** Medizinische Daten sind strukturell identifizierend. "43-jährige Patientin, bilaterale Mastektomie 2024, BRCA1-positiv, Olaparib-Therapie" ist auch ohne Namen einem überschaubaren Personenkreis zuordenbar — insbesondere in Kombination mit Zeitstempel, behandelnder Einrichtung oder Diagnosesequenz. Je seltener die Erkrankung, desto geringer die Anonymisierungswirkung. 2. **Maskierungslücken.** Kein regelbasierter oder KI-gestützter Filter erkennt alle sensiblen Informationen zuverlässig. Medizinischer Freitext enthält unstrukturierte Angaben, Abkürzungen, kontextabhängige Sensitivität ("Ehemann positiv getestet" ist ohne medizinischen Kontext harmlos, im HIV-Kontext hochsensibel). Wenn der Filter eine Information übersieht, gehen ungeschützte Patientendaten an das US-Modell. 3. **Funktionale Grenze.** Ein Arztbrief-Generator, der den klinischen Kontext benötigt, funktioniert mit maskierten Daten nur eingeschränkt oder gar nicht. "Patient [MASKIERT], Diagnose [MASKIERT], Therapie [MASKIERT]" kann kein Modell zu einem sinnvollen Arztbrief verarbeiten. Je aggressiver die Maskierung, desto nutzloser die KI-Ausgabe — je weniger maskiert wird, desto größer die Exposition. 4. **Wer führt die Maskierung durch?** Wenn der Privacy Filter selbst ein KI-Modell nutzt, um sensible Daten zu erkennen, sieht dieses Modell die vollständigen Rohdaten. Die Frage verschiebt sich nur: Auf welcher Infrastruktur und bei welchem Anbieter läuft der Maskierungsfilter? 5. **Pseudonymisierung ≠ Anonymisierung.** Maskierte Daten sind pseudonymisiert, nicht anonymisiert im DSGVO-Sinne (Art. 4 Nr. 5). Pseudonymisierte Daten bleiben personenbezogene Daten — mit allen DSGVO-Pflichten inklusive Art. 48. Die CLOUD-Act-Exposition wird reduziert, nicht eliminiert.

Omnifacts Ansatz ist der beste unter den Brokern — aber "besser als die anderen" ist nicht dasselbe wie "ausreichend für Gesundheitsdaten". Für unkritische Workloads (Klasse 2–3) ist Maskierung ein pragmatischer Teilschutz. Für Klasse-1-Daten (ePA, Diagnosen, Medikation) bleibt das Urteil: Nur vollständig EU-gehostete

Modelle ohne US-Anbieter-Beteiligung bieten strukturellen Schutz.

Kernaussage für den Gesundheitssektor: "DSGVO-konformer KI-Broker" ist kein Souveränitätsnachweis. Ein Broker kann DSGVO-konform betrieben werden und gleichzeitig Patientendaten an CLOUD-Act-exponierte Infrastruktur weiterleiten. Für Gesundheitsdaten nach § 393 SGB V Klasse 1 (ePA, Diagnosedaten, Medikation) gilt: Nur KI-Modelle, die vollständig auf EU-Infrastruktur ohne US-Anbieter-Beteiligung laufen (Mistral self-hosted, Aleph Alpha auf STACKIT/IONOS, OpenEuroLLM auf EuroHPC), bieten strukturellen CLOUD-Act-Schutz. KI-Broker mit US-Backend-Modellen sind für unkritische Workloads (Klasse 2–3) akzeptabel — für Patientendaten nicht.

8. Der vollständige EU-Plattformstack: US-Hyperscaler ersetzen

8.1 Das eigentliche Problem — nicht eine Datenbank, sondern ein Ökosystem

Ein US-Hyperscaler-Stack ist kein einzelner Dienst, sondern ein Ökosystem aus 15–20 miteinander integrierten Schichten — am deutlichsten bei Azure/M365, aber strukturell vergleichbar bei AWS und Google Workspace. Wer nur seine CPU auf EU-Cloud verschiebt, aber E-Mails bei Exchange Online, Dateien bei SharePoint und Identitäten bei Azure Entra ID lässt, hat keine Cloud-Souveränität. Das gilt sinngemäß auch für Organisationen auf AWS (WorkMail, WorkDocs, IAM Identity Center) oder Google Workspace (Gmail, Drive, Cloud Identity). Kapitel 7.3 zeigt für jede dieser Schichten den souveränen EU-Ersatz. Kapitel 8 zeigt, dass dieser Ersatz in der Praxis funktioniert und wie er als Gesamtarchitektur aussieht.

8.2 Der Praxisbeweis: Schleswig-Holstein

Das überzeugendste Argument gegen "das ist nicht praxistauglich" ist ein laufendes Produktivsystem auf Bundesland-Ebene. Schleswig-Holstein (30.000 Mitarbeitende, 9 Ministerien, 20 Behörden) hat migriert: Microsoft Office → LibreOffice (80% abgeschlossen), Exchange → Open-Xchange + Thunderbird (40.000 Accounts, abgeschlossen), SharePoint → Nextcloud (laufend), Teams → Jitsi/OpenTalk (abgeschlossen), Active Directory → Univention Corporate Server (in Umsetzung).

Das finanzielle Ergebnis: **€15 Millionen jährliche Einsparungen** bei €9 Millionen Migrationsinvestition — positiver ROI ab Jahr 1.

Was bleibt schwierig: Komplexe VBA-Makros, proprietäre Excel-Formeln und tief integrierte Fachverfahren (KIS, GKV-Primärsysteme, SAP) haben keine 1:1-Entsprechung. Schleswig-Holsteins 80/20-Regel ist realistisch: 80% voller Open-Source-Betrieb, 20% verbleibende Abhängigkeit — mit dem Ziel, auch diese schrittweise abzulösen. Für Organisationen, die heute nicht vollständig migrieren können: das Operator-Modell (Delos Cloud) ist die Brücke.

8.3 Die vollständige souveräne Zielarchitektur

```
IDENTITÄT &amp; ZUGANG (Zero-Trust)
  Keycloak (Open Source, Red Hat) ← ersetzt Azure AD/Entra ID
  Univention Corporate Server     ← ersetzt Active Directory
  FreeIPA                         ← Linux-Integration

COLLABORATION &amp; OFFICE
  Nextcloud Hub / Euro-Office     ← ersetzt M365 / SharePoint / OneDrive
  Open-Xchange + Thunderbird      ← ersetzt Exchange / Outlook
  OpenTalk / Jitsi / Matrix       ← ersetzt Teams

INFRASTRUKTUR (EU-Cloud)
  STACKIT / plusserver (IaaS)     ← ersetzt Azure Compute
  MinIO / Ceph (Objektspeicher)   ← ersetzt Azure Blob Storage
  PostgreSQL / MariaDB            ← ersetzt Azure SQL / CosmosDB
  Kubernetes (self-managed)       ← ersetzt AKS

KI &amp; ANALYTICS
  vLLM + Mistral (lokal/STACKIT)  ← ersetzt Azure OpenAI / Copilot
  Metabase / Apache Superset      ← ersetzt Power BI / Fabric
  Grafana + Prometheus            ← ersetzt Azure Monitor

CI/CD &amp; DEVOPS
  GitLab (self-hosted)            ← ersetzt Azure DevOps / GitHub

SECURITY &amp; COMPLIANCE
  OpenSearch / Wazuh (SIEM)       ← ersetzt Microsoft Sentinel
  Veeam auf EU-Storage            ← Backup / DR
```

Gesamtbewertung: Dieser Stack ist heute technisch vollständig produktionsreif. Der Engpass ist nicht die Technologie — es ist Betriebspersonal, Integrationskompetenz und Change Management. Schleswig-Holstein

zeigt, dass es geht. Die Kosten sind mit einem ROI von Jahr 1 darstellbar. Der strategische Vorteil: dauerhafte Unabhängigkeit von US-Lizenzpreisen, US-Recht und US-Plattformentscheidungen.

9. Rechtliche Abkommen zwischen EU und USA: Lösung oder Illusion?

Wer die vorangegangenen Kapitel gelesen hat, stellt die naheliegende Gegenfrage: *Wenn EU-Infrastruktur so wichtig ist — warum löst die EU das Problem nicht einfach politisch? Ein Abkommen mit den USA, das klare Regeln für Datenzugriff schafft?*

Diese Frage ist legitim. Es gibt sogar zwei solcher Rahmwerke, die genau das versuchen. Beide scheitern — aus verschiedenen Gründen.

9.1 Das Data Privacy Framework — die dritte Runde

Das Data Privacy Framework (DPF, seit Juli 2023) ist das dritte EU-US-Datentransferabkommen. Seine Vorgänger wurden vom EuGH gekippt:

Abkommen	Gekippt durch	Grund
Safe Harbor (2000–2015)	EuGH Schrems I	NSA/PRISM unvereinbar mit EU-Datenschutzniveau
Privacy Shield (2016–2020)	EuGH Schrems II	FISA § 702 + EO 12.333: Massenüberwachung ohne Verhältnismäßigkeit, kein Rechtsschutz für EU-Bürger
Data Privacy Framework (2023–?)	Schrems III (anhängig)	Strukturell dieselben Schwachstellen

Das DPF beruht nicht auf einem Gesetz, sondern auf einer **Presidential Executive Order** (Biden, EO 14086) — die durch einen gegenteiligen Präsidialerlass jederzeit aufgehoben werden kann. Drei strukturelle Schwachstellen machen es anfällig:

PCLOB-Ausfall: Der EuGH hatte in Schrems II die fehlende unabhängige Aufsicht als Nichtigkeitsgrund benannt. Das DPF präsentierte den Privacy and Civil Liberties Oversight Board (PCLOB) als diese Aufsicht. Die Trump-Administration entließ am 27. Januar 2025 alle drei demokratischen Mitglieder — der PCLOB ist seither nicht mehr handlungsfähig (kein Quorum). Gericht ordnete Wiedereinstellung an; Regierung legte Berufung ein. Die exakt von Schrems II diagnostizierte Schwäche ist erneut eingetreten.

DPRC-Legitimität: Der neu eingeführte Data Protection Review Court sitzt innerhalb der Exekutive. Seine Mitglieder werden vom Präsidenten ernannt und abberufen. Er erfüllt die EuGH-Anforderung an einen "unabhängigen Rechtsbehelf" nach Einschätzung europäischer Datenschutzrechtler nicht.

FISA § 702 unverändert: Das Grundproblem — anlasslose Massenüberwachung ohne richterliche Einzelfallprüfung — wurde durch das DPF nicht adressiert. EO 14086 schränkt FISA § 702 nicht ein. Schrems III greift genau diesen Punkt auf.

> *Für GKVen und Kliniken: Keine Infrastrukturentscheidung, die auf der Dauerhaftigkeit des DPF basiert, ist über 5–10 Jahre strategisch belastbar. Das Muster ist eindeutig — seitdem es das erste Abkommen gab, hat die EU drei Mal gewählt und dreimal ist ein Gericht befragt worden.*

9.2 Das Executive Agreement — die CLOUD-Act-eigene Lösung

Der CLOUD Act hat eine zweite Lösungsoption **explizit eingebaut**: bilaterale Executive Agreements zwischen den USA und qualifizierten ausländischen Regierungen. Ziel: rechtlich gesicherter Datenzugriff für Strafverfolgungszwecke — ohne das DSGVO/CLOUD-Act-Dilemma.

Großbritannien hat es getan: Am 3. Oktober 2019 schloss das UK ein bilaterales Abkommen mit den USA. Es schafft eine DSGVO-Art.-48-kompatible Rechtsgrundlage für Herausgaben in konkreten Strafermittlungen. Der

Nachteil: keine vorherige richterliche Genehmigung von Auskunftsersuchen — das europäische Datenschutzniveau wird also nicht vollständig eingehalten.

Die EU verhandelt seit Juni 2019 — ohne Ergebnis. Stand April 2026: fast sieben Jahre im Verhandlungsmodus, kein Abkommen.

9.3 Was ein Abkommen lösen würde — und was nicht

Was gelöst wäre	Was weiterhin offen bliebe
[OK] DSGVO Art. 48 — Rechtsgrundlage für Herausgabe in konkreten Strafsachen	[X] FISA § 702 — Massenüberwachung ohne Einzelfallprüfung
[OK] Rechtssicherheit für Anbieter (kein Dilemma DSGVO vs. CLOUD Act)	[X] National Security Letters — kein Richter, kein Verdacht, Schweigegebot
[OK] Strafverfolgung bei Schwerkriminalität legitim ermöglicht	[X] Wirtschaftsspionage — kein Abkommen verhindert das strukturell
[OK] Vergleichbar mit UK-Abkommen 2019	[X] Schrems III — EuGH könnte trotzdem kippen wenn FISA § 702 unangetastet bleibt

9.4 Warum kein Abkommen zustande kommt

Ein Abkommen, das den EuGH überlebt, müsste richterliche Einzelfallprüfung, Verhältnismäßigkeit, Zweckbindung auf schwere Straftaten, Benachrichtigungsrechte für Betroffene und keine NSL ohne Richter verlangen. Genau das akzeptieren NSA, CIA und DOJ strukturell nicht — es würde ihre operative Effizienz erheblich einschränken.

Das Dilemma in einem Satz: Die USA wollen Datenzugriff ohne richterliche Kontrolle. Europa will richterliche Kontrolle ohne Ausnahmen. Dazwischen liegt kein Abkommen — sondern Geopolitik.

9.5 Fazit: Nicht warten — bauen

Selbst wenn ein Executive Agreement 2026/2027 zustande käme: FISA § 702 bliebe unangetastet, Massenüberwachung wäre weiter möglich, der EuGH könnte es kippen (Schrems III), und für Gesundheitsdaten der höchsten Schutzklasse wäre es nicht ausreichend.

Das DPF und ein mögliches Executive Agreement sind Ergänzungen — kein Ersatz für EU-souveräne Infrastruktur. Wer sieben Jahre auf ein Abkommen gewartet hat, das nicht kommt, sollte aufgehört haben zu warten.

10. Big Tech Lobbyarbeit in Europa und Deutschland

10.1 Das Ausmaß — Zahlen aus dem EU-Transparenzregister

Die Tech-Branche hat ihre Ausgaben für EU-Lobbyarbeit auf ein **Rekordniveau von 151 Millionen Euro** gesteigert — ein Anstieg um 33,6% seit 2023 und um 55,6% seit 2021. Das ist der höchste jemals gemessene Lobbyetat des Technologiesektors in Brüssel.

Zum Vergleich: Die Top-7-Autobauer in Europa gaben 2019 insgesamt 7,9 Millionen Euro für Lobbyarbeit aus — weniger als ein Siebzehntel der Tech-Lobby.

Unternehmen	EU-Lobbyausgaben jährlich
Meta	10 Mio. €
Microsoft	7 Mio. €
Apple	7 Mio. €
Amazon	7 Mio. €
Google	4,5 Mio. €
GAFAM gesamt	**~35,5 Mio. €**

890 Digital-Lobbyisten arbeiten in Vollzeit in Brüssel — das übersteigt die Zahl der 720 Sitze im Europäischen Parlament. 437 von ihnen haben Lobbyausweise mit nahezu uneingeschränktem Parlamentszugang. Im ersten Halbjahr 2025: durchschnittlich drei Lobbytreffen pro Tag mit EU-Entscheidungsträgern.

10.2 Konkrete Lobbymethoden

1. Direkte Politikbeeinflussung (Nachweis)

Google schickte am 16. August 2025 ein Lobbypapier an die Bundesregierung — mit dem Antrag, das Auskunftsrecht von DSGVO-Betroffenen einzuschränken, Begründung: "disproportionate effort" für Unternehmen. Die Bundesregierung verwendete exakt dieselbe Formulierung in ihrem Positionspapier für die EU-Kommission. Der geleakte Entwurf des Digital Omnibus enthält genau diese Einschränkung. Das ist kein Zufall — das ist dokumentierter Lobbyerfolg.

2. Konferenz-Sponsoring

Hauptsponsoren der CPDP-Konferenz 2025 (weltführende Datenschutzkonferenz): Google, TikTok, Microsoft, Apple und Uber. Sie organisieren eigene Panels, haben privilegierten Zugang zum Programm und garantierte Sichtbarkeit — bei einer Konferenz, die Datenschutzziele vertreten soll.

3. Think-Tank-Netzwerke

Big Tech arbeitet intensiv mit scheinbar unabhängigen Denkfabriken zusammen. Die Verbindungen sind oft nicht öffentlich einsehbar — das erweckt den Eindruck breiter gesellschaftlicher Unterstützung für Deregulierungspositionen ohne erkennbare Konzernverbindung.

4. Taktische Allianz mit Rechtspopulisten — neue Qualität seit 2024

Meta und andere Tech-Konzerne haben Treffen mit rechtspopulistischen und rechtsextremen EU-Parlamentsfraktionen signifikant intensiviert. Hintergrund: antiregulatorische Positionen finden dort fruchtbaren Boden. Eine taktische Allianz zwischen Finanzstärke und politischen Kräften, die europäische Schutzstandards als Innovationsbremse darstellen — das ist eine neue Qualität der Einflussnahme.

5. Wahlkampf-Lobbying

Amazon und Google betrieben rund um die Bundestagswahl aktiv Lobbyarbeit, um den Datenschutz zu schwächen und "Datennutzung" zu fördern.

10.3 Deutschland im Besonderen

GAFAM wendete in Berlin 8,8 Millionen Euro für Lobbyarbeit auf. Amazon waren im Februar 2024 die EU-Lobbyausweise entzogen worden — trotzdem trafen sich EU-Abgeordnete weiterhin mit Amazon-Mitarbeitern.

10.4 Was Big Tech konkret verhindert hat

Das Digital Omnibus Paket (EU-Kommission, November 2025) enthält auf Vorschlag Deutschlands Einschränkungen des DSGVO-Auskunftsrechts — Wortlaut übereinstimmend mit Google-Lobbypapier vom August 2025.

> ***Fazit Lobbyarbeit:*** *Big Tech gibt 19-mal mehr für EU-Lobbyarbeit aus als die Autoindustrie. Die DSGVO gilt — aber ihre Durchsetzung und Weiterentwicklung wird durch diese Finanzasymmetrie systematisch beeinflusst.*

11. Die Berater-Falle: US-Strategieberatungen als verdeckte Cloud-Multiplikatoren

Es gibt eine Akteurskategorie in der CLOUD-Act-Debatte, die in keiner öffentlichen Diskussion vorkommt — obwohl sie für die tatsächliche Infrastrukturentscheidung der meisten großen deutschen Gesundheitsinstitutionen mindestens so relevant ist wie Lobbying oder Regulierung: die amerikanischen Strategie- und IT-Beratungen. Dieser Abschnitt erklärt den Mechanismus, belegt ihn mit öffentlich dokumentierten Fakten und leitet daraus praktische Konsequenzen für die Beschaffungspraxis ab.

11.1 Wer berät das deutsche Gesundheitswesen?

Die Digitalisierungsstrategie der meisten großen gesetzlichen Krankenversicherungen, Kassenärztlichen Vereinigungen und Universitätsklinika wird nicht intern entwickelt — sie wird eingekauft. Die wichtigsten externen Berater im deutschen Gesundheits-IT-Markt kommen aus zwei Gruppen:

MBB — die drei großen Strategieberatungen: McKinsey & Company (gegründet 1926, Hauptsitz New York/Düsseldorf, ~38.000 Mitarbeitende, privat), Boston Consulting Group — BCG (gegründet 1963, Hauptsitz Boston, ~40.000 Mitarbeitende, privat), Bain & Company (gegründet 1973, Hauptsitz Boston, privat). Diese Häuser beraten auf CEO- und Vorstandsebene: Fusionsstrategie, Konsolidierungsroadmaps, IT-Kostenstrategien, Digitalisierungsprogramme. Sie empfehlen keine Einzelprodukte, aber sie setzen die strategischen Rahmenbedingungen und Bewertungsmaßstäbe, aus denen nachgelagerte Technologieentscheidungen folgen.

Big Four und IT-Beratungen: Deloitte (New York, ~460.000 Mitarbeitende, privates Netzwerk), PwC (London/New York, ~370.000 Mitarbeitende), EY Ernst & Young (London/New York, ~395.000 Mitarbeitende), KPMG (Amsterdam/New York, ~265.000 Mitarbeitende). Accenture (Dublin/New York, NYSE: ACN, ~800.000 Mitarbeitende). IBM Consulting (Armonk/New York, NYSE: IBM). Diese Häuser übernehmen die Umsetzungsebene: Systemintegration, IT-Architekturdesign, Ausschreibungsunterstützung, Cloud-Migrationsprojekte, Implementierung.

Alle genannten Firmen — bis auf Roland Berger (München, privat, europäisch) und Arthur D. Little (Boston/Paris, privat) — sind US-amerikanische Unternehmen oder haben ihre strategische Muttergesellschaft in den USA. Sie unterliegen damit selbst dem CLOUD Act. Ihre Beratungsunterlagen, Strategiedokumente, Datenanalysen und Kommunikationsinhalte über ihre Kunden könnten im Rahmen des CLOUD Act von US-Behörden angefordert werden.

11.2 Das strukturelle Interessenproblem — belegte Partnerschaften

Das eigentliche Problem liegt nicht in der US-Jurisdiktion der Berater, sondern in ihrer gleichzeitigen kommerziellen Abhängigkeit von denselben US-Hyperscalern, die sie ihren Kunden empfehlen — oder empfehlen könnten. Die folgenden Partnerschaften sind öffentlich dokumentiert:

Accenture und Microsoft — das tiefste Geflecht:

Avanade wurde im April 2000 als Joint Venture von Andersen Consulting (heute Accenture) und Microsoft gegründet und ist heute mehrheitlich im Besitz von Accenture. Avanade beschäftigt 50.000 Mitarbeitende in 26 Ländern und implementiert ausschließlich Microsoft-Technologien. [Quelle: Avanade Wikipedia / avanade.com, 2024] Das Unternehmen wurde 2019 von Accenture und Microsoft zur "Accenture Microsoft Business Group" weiterentwickelt — einer Gruppe mit über 65.000 Microsoft-zertifizierten Mitarbeitenden aus Accenture und Avanade. [Quelle: Accenture/Microsoft Pressemitteilung, Microsoft Source Blog, November 2024]

Im November 2024 investierten Accenture, Avanade und Microsoft gemeinsam in eine "Copilot Business Transformation Practice" mit 5.000 spezialisierten Fachkräften und mehr als 50.000 Copilot-geschulten Profis. [Quelle: Microsoft Source, 14. November 2024] Accenture wurde 16-mal als Microsofts Global Alliance Systems Integrator Partner of the Year ausgezeichnet und erhielt 2024 Partner-of-the-Year-Auszeichnungen in Retail & Consumer Goods, Automotive sowie Media & Telecom. [Quelle:

accenture.com/us-en/services/ecosystem-partners/microsoft]

Microsoft zahlt zertifizierten Partnerberatungen im Rahmen des "Microsoft AI Cloud Partner Program" strukturierte Anreize. Dokumentiert ist: Für Microsoft 365 E3-Workloads können Partner bis zu 120.000 Dollar pro Kunde verdienen. Microsoft erhöhte seine FY25-Investitionen in das Partnerprogramm um über 150 Millionen Dollar für Azure-Migrationen, mit einer 50-prozentigen Steigerung der Co-Investment-Programme. [Quelle: Maven Collective Marketing, "Microsoft Fiscal Year 2025 Updates", Oktober 2024; Redmond Channel Partner, Juli 2024]

KPMG und Microsoft — 2 Milliarden Dollar Commitment:

Im Juli 2023 schloss KPMG eine 5-Jahres-Partnerschaft mit Microsoft ab, in der KPMG 2 Milliarden Dollar in Microsoft Cloud und Azure OpenAI Services investiert. KPMG erwartete daraus ein inkrementelles Wachstumspotenzial von über 12 Milliarden Dollar. Die Partnerschaft integriert Azure OpenAI in KPMGs Audit-Plattform "KPMG Clara" sowie in Steuerberatungsleistungen. KPMG wurde von Microsoft als "Supplier of the Year" und 2023 als "Global Defense and Intelligence Partner of the Year" ausgezeichnet. [Quelle: VentureBeat, "KPMG to invest $2 billion in AI in expanded partnership with Microsoft", Juli 2023; SiliconAngle, Juli 2023; KPMG Microsoft Alliance Page, kpmg.com]

Im November 2024 schloss KPMG zusätzlich eine 100-Millionen-Dollar-Partnerschaft mit Google Cloud — ein Beispiel dafür, wie Beratungshäuser parallel mit mehreren konkurrierenden Hyperscalern kommerzielle Bindungen eingehen. [Quelle: CFO Dive, "KPMG inks $100M Google Cloud deal", November 2024]

McKinsey und Amazon Web Services — die Amazon McKinsey Group:

Im Januar 2026 gründeten McKinsey & Company und Amazon Web Services (AWS) offiziell die "Amazon McKinsey Group" (AMG) — eine integrierte Kooperationsstruktur, die McKinseys Strategie-Expertise mit AWS-Cloud- und KI-Diensten in einem gemeinsamen Liefermodell verbindet. AMG zielt auf Transformationen mit einem Milliarden-Dollar-Geschäftsimpact. Das kommerzielle Modell ist explizit an Ergebnisse gekoppelt; McKinsey und AWS-Teams arbeiten gemeinsam an der Kundenimplementierung. [Quelle: McKinsey "Amazon McKinsey Group" Pressemitteilung, 22. Januar 2026; TechInformed, 23. Januar 2026; Fortune, 23. Januar 2026]

McKinsey ist offiziell registrierter Beratungspartner im AWS Partner Network (partners.amazonaws.com) und hat seit 2019 eine strategische Allianz mit AWS, die 2022 und 2026 weiter ausgebaut wurde. [Quelle: McKinsey & Company, "AWS & McKinsey", mckinsey.com/about-us/overview/alliances-and-acquisitions/aws]

OpenAI Frontier Alliance — gemeinsame KI-Agenda:

Am 23. Februar 2026 gründete OpenAI die "Frontier Alliances" — mehrjährige exklusive Partnerschaften mit BCG, McKinsey, Accenture und Capgemini. Die Partner erhalten Vorabzugang zu noch nicht veröffentlichten Modellen, dediziertes Engineering-Support von OpenAIs Forward Deployed Engineers und Co-Entwicklungsrechte. Jede Partnerorganisation baut dedizierte "Practice Groups" auf, die auf OpenAI-Technologie zertifiziert sind. [Quelle: OpenAI, "Introducing Frontier Alliances", openai.com, 23. Februar 2026; CNBC, TechCrunch, Fortune, 23. Februar 2026]

OpenAI Frontier läuft auf Azure — Microsoft ist der exklusive Cloud-Partner von OpenAI. Eine Empfehlung für OpenAI-basierte KI-Infrastruktur durch einen Frontier Alliance Partner ist damit strukturell eine Empfehlung für Azure-Infrastruktur. [Quelle: Microsoft/OpenAI Partnership, öffentlich dokumentiert]

Oracle — der übersehene Vierte:

Oracle (NYSE: ORCL, Austin/Texas) ist im deutschen Gesundheitswesen in einer einzigartigen Doppelposition: Erstens als KIS-Anbieter (i.s.h.med via Oracle Cerner, ~250 deutsche Kliniken), zweitens als Cloud-Anbieter (Oracle Cloud Infrastructure / OCI), auf den Oracle bestehende Kunden im Zuge der SAP-IS-H-Abkündigung migrieren will. Oracle ist damit nicht primär ein Beratungsunternehmen, aber funktional ein Systemanbieter, der eine laufende Migrationswelle aktiv steuert — und dabei dieselbe Cloud-Lock-in-Logik erzeugt wie Accenture oder IBM im Beratungskontext. Ausführliche CLOUD-Act-Bewertung von Oracle: §5.5.

IBM — die doppelte Rolle in Deutschland:

IBM ist gleichzeitig Beratungsunternehmen (IBM Consulting), Cloud-Anbieter (IBM Cloud), KI-Plattformanbieter (WatsonX) und — in Deutschland — ein zentraler Infrastrukturbetreiber der Telematikinfrastruktur: IBM ist als Identity Provider Services-Anbieter für die TI zugelassen (Zulassung durch gematik Dezember 2023) und hat den Rezeptserver-Fachdienst entwickelt. [Quelle: Apotheke Wirtschaft, Heft 16/2025, "Rien ne va plus — ohne die Riesen im Hintergrund läuft in der TI gar nichts"] IBM hat damit eine einzigartige Dreifachrolle: strategischer Berater, Technologieanbieter und Betreiber gesundheitsrelevanter Basisinfrastruktur.

11.3 Der Mechanismus: Warum das Modell systemische Präferenz für US-Hyperscaler erzeugt

Ein Berater der Kategorie Accenture oder Deloitte, der eine GKV beim Aufbau einer Cloud-Infrastruktur begleitet, verdient auf mehrfachen Ebenen:

Ebene 1 — Beratungshonorar: Das klassische Tagessatz-Modell (typisch für Senior-Profile großer Häuser: 2.500–6.000 Euro/Tag). Dieser Teil ist unabhängig von der Technologieauswahl.

Ebene 2 — Partnerschaftsincentives des Cloud-Anbieters: Microsoft, AWS und Google zahlen zertifizierten Beratungspartnern strukturierte Anreize für Migrations-Projekte, die sie begleiten. Diese sind öffentlich im Grundsatz, in den genauen Sätzen aber nicht vollständig transparent. Dokumentiert sind: Bis zu 120.000 Dollar pro Kunde für bestimmte M365-Workloads, 50-prozentige Steigerung der Azure Migrate & Modernize Co-Investment-Mittel auf über 150 Millionen Dollar für FY25. [Quelle: Maven Collective Marketing, "Microsoft Fiscal Year 2025 Updates", Oktober 2024] Der Mechanismus ist strukturell bekannt: Ein Beratungshaus, das einen Kunden zu Azure migriert, löst Incentivezahlungen aus, die unabhängig vom Beratungshonorar fließen.

Ebene 3 — Implementierungsfolgeaufträge: Wer die Migrationsstrategie entwirft, begleitet in der Regel auch die Umsetzung — zu separaten Honoraren. Je komplexer der gewählte Stack, desto größer der Implementierungsaufwand, desto mehr Folgeaufträge. Ein proprietärer Azure-Stack (mit Azure Active Directory, Azure SQL, Azure Functions, Copilot) bindet mehr Implementierungs- und Betriebsaufwand als eine standardisierte Open-Source-Lösung auf EU-Cloud.

Der resultierende Effekt ist nicht durch böse Absicht erklärbar — er ist durch das Geschäftsmodell strukturell erzeugt. Consulting-Häuser mit tiefen Microsoft- oder AWS-Partnerschaften haben systematisch weniger finanziellen Anreiz, EU-souveräne Alternativen gleichwertig zu evaluieren. Das ist keine Spekulation — es ist Geschäftsmodell-Logik.

Eine Studie zu Interessenkonflikten im Beratungskontext beschreibt das Grundmuster: "A lot of consultants get a commission or fee from third parties for bringing them new business. This creates an environment where the consultant is biased towards using or recommending the services of such third parties." [Quelle: Atelier & Avenue, "The 4 unacceptable Conflicts of Interest of classic consultancies & agencies", 2019]

11.4 Was das für eine GKV oder ein Klinikum konkret bedeutet

Eine GKV oder ein Universitätsklinikum, das McKinsey, Accenture oder Deloitte mit der Entwicklung seiner Digitalisierungsstrategie oder Cloud-Migrationsstrategie beauftragt, erhält eine Empfehlung von einem Unternehmen, das:

Erstens selbst dem CLOUD Act unterliegt. Die Beratungsunterlagen, Strategiedokumente und Kommunikation, die Accenture oder McKinsey im Auftrag der GKV erstellt, liegen auf deren eigenen Systemen — die als US-Unternehmen dem CLOUD Act unterworfen sind. Enthält dieses Material sensible Daten der GKV (Versichertenstatistiken, IT-Architekturpläne, interne Sicherheitsbewertungen), unterliegen auch diese dem potenziellen US-Zugriff.

Zweitens dokumentierte kommerzielle Partnerschaften mit den US-Hyperscalern unterhält, deren Dienste im Rahmen des Projekts evaluiert werden. Diese Partnerschaften sind nicht verborgen — sie sind öffentlich als Wettbewerbsvorteile vermarktet. Aber sie sind im Beratungsvertrag üblicherweise nicht als Interessenkonflikt deklariert.

Drittens eigene finanzielle Anreize hat, dass der Klient einen großen US-Hyperscaler-Stack wählt — sowohl durch Partnerprovisionen als auch durch Folgeauftragspotenzial.

Das bedeutet nicht, dass jede Empfehlung aus dieser Konstellation falsch ist. Aber es bedeutet, dass eine GKV oder ein Klinikverbund die Unabhängigkeit des Beraters aktiv prüfen muss — genauso wie sie den CLOUD-Act-Status des empfohlenen Cloud-Anbieters prüfen sollte.

11.5 Praktische Leitfragen für die Beraterauswahl

Für jede Beauftragung einer externen Beratung im Kontext von Cloud-Infrastruktur und Digitalisierungsstrategie sollten folgende Fragen gestellt und schriftlich beantwortet werden:

Zur Unabhängigkeit des Beraters:

- Hat die Beratungsfirma Partnerschaftsverträge, Zertifizierungsprogramme oder Incentive-Vereinbarungen mit Microsoft, AWS, Google oder anderen Cloud-Anbietern, die im Projekt evaluiert werden?
- Erhält die Beratungsfirma direkte oder indirekte Vergütungen (Provisionen, Migration-Incentives, Co-Marketing-Budgets, Deal-Registration-Fees) von Cloud-Anbietern bei Kundenmigrationen?
- Unterliegt die Beratungsfirma selbst dem CLOUD Act — und welche Daten der GKV landen auf deren US-kontrollierten Systemen?

Zur Qualität der Empfehlung:

- Wurden beim Cloud-Anbietervergleich EU-souveräne Alternativen (STACKIT, plusserver, 3DS Outscale, Cloud Temple etc.) mit gleichem methodischen Aufwand evaluiert?
- Wer hat die Evaluation der EU-Alternativen durchgeführt — und welche Qualifikationen hat das Beraterteam für EU-Cloud-Anbieter?
- Wurde eine Datentransfer-Folgenabschätzung (TIA, §17.4) für den empfohlenen Anbieter erstellt und dem Auftraggeber übergeben?
- Ist das CLOUD-Act-Risiko des empfohlenen Anbieters explizit im schriftlichen Beratungsergebnis adressiert?

Zur Vertragssituation:

- Enthält der Beratungsvertrag eine Offenlegungspflicht für Interessenkonflikte gegenüber Dritten — insbesondere gegenüber Cloud-Anbietern?
- Gibt es Klauseln, die Provisionszahlungen oder sonstige Vergütungen von Technologieanbietern an den Berater, die im Zusammenhang mit diesem Projekt entstehen, offenlegungspflichtig oder unzulässig machen?

Europäische und strukturell unabhängigere Beratungsalternativen:

Firma	Sitz	Struktur	CLOUD-Act-Status
Roland Berger	München	Privat, europäisch	[G] Kein US-Bezug nachweisbar
Arthur D. Little	Paris/Boston	Privat, unabhängig	[Y] US-Gründung, aber europäisch kontrolliert
BearingPoint	Frankfurt	Privat, europäisch	[G] Kein US-Bezug
Sopra Steria	Paris	Euronext-börsennotiert, FR	[G] Europäisch
adesso	Dortmund	MDAX, Gesundheits-IT	[G] Deutsch
Capgemini	Paris	Euronext CAC 40	[Y] US-Partnerstrukturen vorhanden

Capgemini ist Gründungsmitglied der OpenAI Frontier Alliance — und damit trotz europäischer Börsennotierung ebenfalls kommerziell mit US-KI-Infrastruktur verbunden. [Quelle: OpenAI, "Introducing Frontier Alliances", Februar 2026]

12. Marktbeispiele: Wie Gesundheitsinstitutionen in die US-Cloud geraten

Die abstrakten Rechtskonflikte aus den Kapiteln 1–11 materialisieren sich in konkreten Beschaffungsentscheidungen. Die folgenden Fälle illustrieren die fünf strukturellen Eintrittspfade: SAP-Migrationsdruck, KIS-Neuausschreibung, IT-Outsourcing, Übernahme durch US-Konzerne, SaaS-Plattformdominanz. Alle sind öffentlich dokumentiert.

12.1 Eintrittspfad 1: GKV-Rechenzentren — das Cloud-Outsourcing läuft über Intermediäre

GKV-Kernsysteme laufen nicht bei den Kassen selbst — sie liegen bei spezialisierten GKV-Rechenzentren: **BITMARCK** (>80 % aller GKV), **Kubus IT** (AOK Bayern/Plus), **ITSC** (norddeutsche Kassen), **gkv informatik**, **ITSCare** (Baden-Württemberg, Hessen, Rheinland-Pfalz/Saarland) und **MOBIL ISC**. Diese RZ sind die eigentlichen Infrastrukturentscheider — und sie migrieren gerade in Richtung Cloud. Das CLOUD-Act-Risiko entsteht nicht in der Kassensoftware selbst, sondern in der Hosting-Schicht darunter.

ITSCare — kasseneigenes RZ für 7,5 Millionen Versicherte: ITSCare ist eine 2007 gegründete IT-Gesellschaft mit den Gesellschaftern AOK Baden-Württemberg, AOK Hessen und AOK Rheinland-Pfalz/Saarland. Mit ~700 Mitarbeitenden und Sitz Frankfurt/Stuttgart verarbeitet ITSCare die Sozialdaten von über 7,5 Millionen Versicherten — Netzwerke, Hardware, Software, Telekommunikation, Rechenzentrum aus einer Hand. Als 100%-Tochter der drei AOKs ist ITSCare strukturell günstig positioniert: kein US-Eigentümer, kein US-Börsenmarkt. Die Stellenprofile zeigen allerdings eine hybride On-Premise/Cloud-Architektur im Aufbau — die Frage ist, welche Public-Cloud-Dienste dabei zum Einsatz kommen. CLOUD-Act-Risiko: strukturell gering solange keine US-Hyperscaler als Primärinfrastruktur gewählt werden.

Techniker Krankenkasse — Inhouse-IT-Strategie als bewusstes Gegenmodell: Die TK (Hamburg, ~12 Millionen Versicherte, größte deutsche GKV) betreibt ihre IT mit ~600 internen Mitarbeitenden weitgehend inhouse. Von der IT-Strategie und IT-Architektur bis zum 7×24 active-active Rechenzentrumsbetrieb liegt alles im Verantwortungsbereich der internen IT-Abteilung. Das ist eine bewusste strategische Entscheidung. CIO Aude Vik (seit Januar 2024) formulierte im TK-Geschäftsbericht 2023 direkt: Cloud-Technologie als Krankenkasse zu nutzen erfordert besondere Vorsichtsmaßnahmen, um sensible Daten vor unbefugtem Zugriff zu schützen. Die TK nutzt Cloud-Techniken selektiv — aber Kernsysteme und Kerndaten bleiben on-premise in eigenen Rechenzentren. IBM Cloud Private wurde 2018 für die eGA-Entwicklung eingesetzt — Private Cloud im eigenen RZ, kein US-Public-Cloud-Exposé. CLOUD-Act-Risiko: strukturell gering bei konsequenter Fortsetzung dieser Strategie.

Kubus IT → **Arvato Systems** → **Google Cloud** (Negativbeispiel, belegt): Kubus IT migrierte sein On-Premise-RZ vollständig zu Arvato Systems für ~17.500 IT-Nutzer. Arvato bietet dabei Google Cloud als Hyperscaler-Option an. Auf dem Google Cloud Summit München 2024 präsentierte Arvato den Kubus-Fall als Beleg für "souveräne GKV-Cloud mit Google". Google Cloud ist CLOUD-Act-Kategorie A — Serverstandort schützt nicht. [Quelle: Arvato Systems Referenz "Cloud migration for kubus IT"]

ITSC → **OVHcloud** (Positivbeispiel, belegt): Das ITSC migriert mit adesso zu OVHcloud-Rechenzentren in Deutschland und Frankreich. Budget siebenstellig, Start Mai 2024. OVHcloud ist französisch, keine US-Börsennotierung. [Quelle: e-health-com.de, "adesso wird Cloud-Transformationspartner für das ITSC"]

gkv informatik → **T-Systems**: Teile der gkv-informatik-Infrastruktur wurden zu T-Systems ausgelagert — als AWS-Partner und Azure-Reseller tief in US-Hyperscaler eingebettet. CLOUD-Act-Risiko entsteht dort, wo GKV-Workloads auf US-Diensten laufen.

Die SAP-Zeitbombe: Alle AOK-Systeme laufen auf `oscare®` (SAP-basiert). Die nächste Migration — SAP S/4HANA Cloud auf Azure oder AWS — wäre ein direkter CLOUD-Act-Eintrittspfad. Mit dem "BITMARCK all in ONE"-Programm und dem govdigital-Beitritt (Oktober 2024) stellt sich dieselbe Frage für BITMARCK. [Quelle:

govdigital.de Oktober 2024; BITMARCK-Kundentag 2025]

12.2 Eintrittspfad 2: KVen — Azure als etablierte Infrastruktur (belegt durch TED-Ausschreibung)

Die 17 deutschen Kassenärztlichen Vereinigungen verwalten die ambulante Versorgung von 75 Millionen gesetzlich Versicherten — Honorarabrechnungen, Zulassungsregister, Qualitätsdaten, Praxisnetze. KVWL (Westfalen-Lippe, >16.000 Mitglieder) und KVNO (Nordrhein, 19.500 Mitglieder, ~9,5 Mio. Versicherte) betreiben ihre IT gemeinsam über die **KV-IT GmbH** in Düsseldorf/Dortmund. [Quelle: kvno.de/kv-it-gmbh]

Der Beleg — TED-Ausschreibung 98706-2026 (11. Februar 2026): Die KVNO schrieb unter der Kennung X-KVNO-2025-0023 die "Entwicklung und Betrieb einer KI-Plattform als PaaS-Lösung sowie diverser KI Use Cases" aus. Der Ausschreibungstext ist eindeutig:

> *"Die KI-Plattform wird als Cloud-PaaS-Lösung auf der Azure Cloud der KVNO vom Auftragnehmer bereitgestellt und langfristig im Auftrag der KVNO betrieben."*

Azure ist damit nicht als Option formuliert, sondern als gegebene, bereits bestehende Infrastruktur der KVNO. Der Auftragnehmer soll auf dieser Azure-Umgebung aufbauen — nicht eine neue Cloud-Infrastruktur auswählen. [Quelle: TED 98706-2026, EU-Amtsblatt S 29/2026]

Was die Ausschreibung außerdem zeigt:

- Eignungskriterien verlangen **BSI C5 Typ 2-Testate** für Container-Orchestrierung und KI-Dienste — technische Sicherheit wird adressiert
- DSGVO-, BDSG-, EU-KI-VO- und SGB-V-Konformität ist explizite Anforderung
- Der **CLOUD Act** als Risikodimension taucht in der Ausschreibung nicht auf — strukturell nicht adressiert
- Mindestlaufzeit 36 Monate, zweimal verlängerbar um je 12 Monate → langfristige Azure-Bindung

CLOUD-Act-Bewertung: Microsoft (NYSE: MSFT) ist CLOUD-Act-Kategorie A — direkte US-Exposition. Die Azure-Infrastruktur der KVNO verarbeitet Honorardaten, die implizit Diagnose- und Leistungsinformationen zu Arzt-Patienten-Beziehungen enthalten. C5 und DSGVO-Konformität adressieren technische Sicherheit und datenschutzrechtliche Verarbeitung — nicht die Frage, ob US-Behörden auf die Infrastruktur zugreifen könnten. Das ist das strukturelle Problem: Die KVNO kauft C5-konformen Betrieb ein, aber C5 ≠ CLOUD-Act-Immunität (→ Kapitel 5.3).

Das strukturelle KV-Muster: Als Körperschaften des öffentlichen Rechts sind KVen EU-ausschreibungspflichtig. Vergabekriterien wie "2 vergleichbare Referenzprojekte mit Cloud-PaaS auf Azure" schreiben Microsoft strukturell fest — nicht durch bösen Willen, sondern weil Azure der de-facto-Standard ist, gegen den Referenzen gemessen werden. Ein Umstieg würde einen aktiven Beschluss erfordern, Azure als Referenzplattform zu ersetzen.

12.3 Eintrittspfad 3: MDK — Souveräne Branchenlösung auf EWERK-Infrastruktur (Positivbeispiel)

Die **MDK-Gemeinschaft** (15 Medizinische Dienste bundesweit, über 9.000 Mitarbeiter) entschied sich 2018 nach einem europaweiten Vergabeverfahren für ein Konsortium aus **HBSN AG**, **EWERK RZ GmbH** (Leipzig) und **MOBIL ISC GmbH** für den Betrieb ihrer gemeinsamen Branchenlösung. [Quelle: zaronews.world, Pressemitteilung HBSN, Juni 2018]

Das Modell: Homogenisierung der IT aller 15 Medizinischen Dienste auf einer gemeinsamen Plattform — betrieben von EWERK Leipzig, einem deutschen IT-Dienstleister ohne US-Eigentümer und ohne US-Börsennotierung. EWERK betreibt eigene Rechenzentren in Leipzig (ISO 27001, ISAE 3402 Typ II, ISO 20000), nutzt Nutanix-Hyperkonvergenzinfrastruktur und bietet IaaS/PaaS für KRITIS-relevante Kunden im Gesundheitswesen, öffentlicher Verwaltung und Energieversorgung.

CLOUD-Act-Bewertung: Soweit öffentlich erkennbar, läuft die MDK-Branchenlösung auf eigener EWERK-Infrastruktur ohne US-Hyperscaler als primäre Plattform. EWERK (NORD Holding als Mehrheitseigentümer, deutsches PE) hat keine US-Jurisdiktion. Das MDK-Modell ist ein funktionierender Gegenfall zur US-Hyperscaler-Dominanz im Gesundheitswesen — entstanden nicht durch politische Vision, sondern durch eine sachgerecht formulierte Ausschreibung.

12.4 Eintrittspfad 4: KIS-Neuausschreibung — Charité und der Epic-Präzedenzfall

Die Charité (Berlin, 950.000 Patienten/Jahr, Europas größtes Universitätsklinikum) wählte im Dezember 2025 **Epic Systems** (Verona, Wisconsin, US-Privatunternehmen) als KIS-Anbieter — 200 Mio. EUR über zehn Jahre, Implementierung bis Ende 2029. Der Auslöser war erzwungen: SAP kündigt IS-H 2027 ab (Verlängerung bis 2030 zu erhöhten Kosten). [Quelle: Charité Pressemitteilung Dezember 2025]

Epic ist CLOUD-Act-Kategorie A — direkte US-Exposition unabhängig vom Datenstandort. Die Charité betont DSGVO-Konformität und Datenstandort Deutschland/EU, was notwendig aber nicht hinreichend ist. Die Entscheidung ist ein Signal: Mehr als 200 weitere IS-H-Kliniken stehen vor derselben Migration.

Das Gegenbeispiel — Charité × Schwarz Digits: Dieselbe Charité gründete im März 2026 mit Schwarz Digits (der Digitalsparte der Schwarz Gruppe, zu der auch STACKIT gehört) die "Schwarz Charité Health Data GmbH". Ziel: medizinische Daten sicher vernetzen und als Grundlage für KI-Anwendungen nutzen — auf STACKIT als Infrastrukturbasis. Das Joint Venture zeigt, dass die Charité den CLOUD-Act-Konflikt sieht: Für das KIS hat sie sich für Epic entschieden (Marktdruck durch IS-H-Abkündigung), für die Forschungsdatenplattform bewusst für einen europäischen Cloud-Anbieter. Zwei parallele Infrastrukturentscheidungen derselben Institution — eine US-exponiert, eine souverän.

12.5 Eintrittspfad 5: US-Konzernübernahmen und SaaS-Plattformen

DAVASO/IQVIA — Rezeptabrechnung unter US-Jurisdiktion: DAVASO (Leipzig) verarbeitet >50 % aller deutschen Apothekenrezepte (450 Mio./Jahr, ~22 Mrd. EUR). 2021 übernahm IQVIA (NYSE: IQV, Durham, North Carolina) DAVASO vollständig. Das Bundeskartellamt genehmigte nach Prüfung gemeinsam mit BMG, BAS und BfDI. CLOUD-Act-Konsequenz: IQVIA ist Kategorie A — Abrechnungsdaten von Millionen Kassenpatienten laufen durch ein US-Unternehmen. Die DSGVO schützt vor *kommerzieller* Weiternutzung — nicht vor US-Behördenzugriff. Seit 2025: IQVIA Health System Services (IQVIA HSS). [Quelle: Apotheke Adhoc, März 2026]

Doctolib — 20 Millionen Nutzer, AWS-Infrastruktur: Doctolib (Paris, FR) dominiert die Online-Terminbuchung in deutschen Arztpraxen. Die Plattform verarbeitet den vollständigen Patientenstammdatensatz jeder angeschlossenen Praxis — auch ohne App-Nutzung der Patienten. Infrastruktur: AWS Frankfurt (primär) und Paris (Spiegelung), explizit in der Datenschutzdokumentation dokumentiert. AWS ist Kategorie A. BSI C5 Typ 2 seit Juli 2025 — bescheinigt Informationssicherheit, nicht Abwesenheit von US-Behördenzugriff. [Quelle: Doctolib Datenschutzhinweise; HNO Nachrichten Dezember 2025]

12.6 Forschungsinfrastruktur — souverän wo möglich, heterogen in der Breite

FDZ Gesundheit (BfArM) — Positivbeispiel mit Vorbehalt: Das Forschungsdatenzentrum beim BfArM (Betrieb seit Oktober 2025) verwaltet GKV-Abrechnungsdaten von 73 Millionen Versicherten (2009–2023) in gesicherten virtuellen Analyseräumen. Daten verlassen den BfArM-Server nicht. Infrastruktur: deutsche Bundesbehörde, aufgebaut mit Bechtle (DE), SAP (DE) und Capgemini (FR). CLOUD-Act-Risiko strukturell gering — kritischer Punkt: externe Cloud-Tools von Forschenden im Analyseraum. [Quelle: BMG Pressemitteilung Oktober 2025]

MII/DIZ — föderale Heterogenität: Die Datenintegrationszentren der Medizininformatik-Initiative sind ohne einheitliche Cloud-Strategie entstanden. Einige DIZ betreiben souverän on-premise, andere auf Azure oder AWS. Dieselbe FHIR-basierte Dateninfrastruktur kann im selben Netzwerk auf EU-souveräner und auf US-exponierter Infrastruktur laufen — ohne dass dies für außenstehende Stellen transparent ist.

12.7 KIS-Markt: Überblick nach SAP IS-H-Abkündigung

Anbieter	Eigentümer	CLOUD-Act	Installationen DE	Segment
Dedalus/Orbis	IT — Ardian PE (FR)	[G] EU-souverän	821	Akut (Marktführer)
Oracle Cerner i.s.h.med	NYSE: ORCL (US)	[R] Kat. A	~250	Akut (SAP-gebunden)
NEXUS AG	DE (börsennotiert)	[G] EU-souverän	326	Akut/Psychiatrie
CGM Clinical	DE (CVC-PE 28 %)	[Y] PE-Vorbehalt	~350 Akut	Akut + Reha ~900 ges.
Meierhofer M-KIS	DE/AT privat	[G] EU-souverän	~260 (DACH)	Akut + Reha
iMedOne (Telekom)	DAX: DTE / T-Systems (C — Konzernhebel)	[Y] Strukturell	~240	Akut
Epic	US (privat)	[R] Kat. A	1 (Charité ab 2027)	Akut — im Aufbau
Mesalvo	DE privat	[G] EU-souverän	~100–150	Akut, wachsend

12.8 Eintrittspfad 6: Telematikinfrastruktur — souverän in der Governance, exponiert im Betrieb

Die Telematikinfrastruktur (TI) ist das digitale Nervensystem des deutschen Gesundheitswesens: Sie verbindet alle Leistungserbringer in einem gemeinsamen Sicherheitsnetz und transportiert ePA (elektronische Patientenakte), E-Rezept, elektronische Arbeitsunfähigkeitsbescheinigung (eAU) und Versichertenstammdaten. Die gematik GmbH, die die TI reguliert und weiterentwickelt, steht zu 51 Prozent im Eigentum des Bundesministeriums für Gesundheit — sie ist keine US-Gesellschaft und unterliegt keiner US-Jurisdiktion. Soweit zur guten Nachricht.

Die schlechte: Im operativen Betrieb der TI sind US-Unternehmen tief verankert.

IBM betreibt zwei Kerndienste. IBM (Hauptsitz Armonk, New York — vollständig CLOUD-Act-exponiert) hat 2020 den Ausschreibungsgewinn für den Rezeptserver-Fachdienst erhalten und wurde im Dezember 2023 von der gematik als Identity-Provider-Anbieter zugelassen. IBM hat damit gleichzeitig Zugang zu Authentifizierungsinfrastruktur und zum zentralen eRezept-Transaktionsdienst. Die gematik betonte bei der Vergabe, der Betreiber könne Gesundheitsdaten "nicht auslesen". Das ist für Inhaltsdaten korrekt — aber CLOUD Act erfasst auch Metadaten, Verbindungsprotokolle und Systemzugriffe, nicht nur Klartextinhalte. [Quelle: Apotheke Wirtschaft, Heft 16/2025]

Arvato Systems (Bertelsmann) trägt die Sicherheitsinfrastruktur. Arvato Systems betreibt den zentralen Verzeichnisdienst, die KIM-Dienste (Kommunikation im Medizinwesen) und die übergreifende TI-Sicherheitsarchitektur. Arvato ist eine Tochter der deutschen Bertelsmann SE — formal kein US-Unternehmen. Das CLOUD-Act-Risiko ist deutlich geringer als bei IBM, aber nicht null, sofern Bertelsmann US-Tochtergesellschaften mit Datenzugang unterhält.

TI 2.0 öffnet neue Einfallstore. Unter TI 2.0 ersetzen cloudbasierte TI-Gateways die bisherigen Hardware-Konnektoren: Praxen und Kliniken mieten TI-Zugang als Managed Service von zertifizierten Anbietern. Wer diese Gateway-Betreiber sein werden und ob darunter US-Konzerne zugelassen werden, ist regulatorisch noch nicht abschließend definiert. Hier entsteht mit der Umstellung ein strukturell neues CLOUD-Act-Einfallstor. Die regulatorischen Auswirkungen von TI 2.0 werden in §18.1 vertieft.

Risikomatrix TI:

TI-Komponente	Betreiber	CLOUD-Act-Risiko
Regulierung / Governance	gematik GmbH (BMG 51 %)	[G] Keines
Rezeptserver-Fachdienst	IBM (US)	[R] Real
Identity Provider	IBM (US, seit Dez. 2023)	[R] Real
Verzeichnisdienst / KIM	Arvato Systems (DE/Bertelsmann)	[Y] Gering–mittel
Datenverschlüsselung	Ende-zu-Ende	[G] Strukturell geschützt
TI-Gateway-Betreiber (TI 2.0)	Noch offen	[Y] Regulatorisch ungeklärt

Fazit: Die TI ist kein US-Cloud-Problem im klassischen Sinne — ihre Governance und Verschlüsselung sind konzeptionell souverän. Aber IBM als CLOUD-Act-exponierter Betreiber von Rezeptserver und Identity Provider ist eine strukturelle Schwachstelle, die in der öffentlichen Debatte kaum thematisiert wird.

12.9 Sechs Eintrittspfade — Zusammenfassung

Pfad	Mechanismus	Lösungsansatz
GKV-Outsourcing	RZ migriert zu Intermediär → US-Hyperscaler	EU-souveräne Cloud im AVV vorschreiben (OVHcloud-Modell)
KV-IT-Abhängigkeit	KV-Gemeinschaftsgesellschaft auf M365/Azure	Ausschreibungsgestaltung mit CLOUD-Act-Kriterium
KIS-Neuausschreibung	IS-H-Abkündigung → Epic/OCI-Migration	Dedalus/NEXUS als EU-Alternativen stärken
US-Übernahme	DAVASO/IQVIA — Übernahme nach Kartellprüfung	Nicht rückgängig zu machen; AVV-Schutzmechanismen
SaaS-Plattform	Doctolib auf AWS — C5 schützt nicht vor CLOUD Act	EU-Alternative fördern oder Migration zu EU-Anbietern
Telematikinfrastruktur	IBM betreibt TI-Kerndienste (Rezeptserver, IdP)	Nicht auflösbar — TI ist gesetzlich verpflichtend; Restrisiko dokumentieren

13. Clientseitige Verschlüsselung: Teilschutz, kein Allheilmittel

13.1 Die Grundidee

Wenn ein US-Anbieter nur verschlüsselte Daten sieht und nie die Schlüssel besitzt, kann er einer CLOUD-Act-Anordnung technisch nicht nachkommen — er hat schlicht keine lesbaren Daten. Das ist richtig — aber nur unter bestimmten Bedingungen.

13.2 Die drei Verschlüsselungsmodelle

Modell	Beschreibung	Schutz vs. CLOUD Act
Provider-Managed Keys (Standard)	Anbieter verschlüsselt mit eigenen Schlüsseln. Kann jederzeit entschlüsseln.	[X] Kein Schutz
BYOK (Bring Your Own Key)	Kunde generiert eigene Schlüssel, übergibt sie dem Anbieter-KMS. Anbieter verwaltet Schlüssel in eigenem System.	[!] Schwacher Schutz — Anbieter hat technisch Zugriff
HYOK (Hold Your Own Key)	Schlüssel bleiben ausschließlich beim Kunden in eigenem HSM. Anbieter empfängt nur verschlüsselte Daten. Anbieter kann technisch **nicht** entschlüsseln.	[OK] Struktureller Schutz

Der kritische Unterschied BYOK vs. HYOK:

Beim BYOK speichert der Cloud-Anbieter die Schlüssel in seinem eigenen Key Management System — er hat unter Umständen technisch Zugriff. Law Enforcement kann den Anbieter zwingen, BYOK-Schlüssel zur Entschlüsselung einzusetzen. Der CLOUD Act schreibt Providern nicht explizit vor, Daten entschlüsseln zu müssen — **verbietet es aber auch nicht**. Beim HYOK liegen Schlüssel nie in der Umgebung des Anbieters — die Anforderung ist technisch nicht ausführbar.

13.3 Wo HYOK funktioniert

HYOK schützt strukturell vor CLOUD-Act-Zugriff bei:

- Statischen Datenspeichern (Archivdaten, Backup, Objektspeicher)
- File-Storage (Dokumente, Bilder, PDFs auf US-Cloud-Infrastruktur)
- Eigener Software mit Client-Anbindung (Anwendungslogik läuft lokal, nur verschlüsselte Blobs in der Cloud)
- Backup-Lösungen (Verschlüsselung vor Upload, Schlüssel on-premise)

13.4 Wo HYOK nicht funktioniert — die entscheidende Grenze

Anwendungsfall	Warum HYOK nicht hilft
Microsoft 365 / SharePoint	Suchindex, Co-Authoring, Teams-KI benötigen unverschlüsselten Inhalt server-seitig
E-Mail (Exchange Online / Gmail)	Spam-Filter, Virenscanner, Regelverarbeitung, KI-Zusammenfassungen laufen auf unverschlüsselten Inhalten
KI / LLM-Services (Azure OpenAI, AWS Bedrock)	KI-Modell muss Prompt lesen — verschlüsselte Prompts kann kein Modell verarbeiten
SaaS-Anwendungen (Salesforce, SAP Cloud)	Jede SaaS-Funktion (Suche, Filter, Analyse) erfordert Klartextdaten im Provider-Speicher
Real-time Analytics / BI (Qlik Cloud, Power BI)	Aggregation, Filterung, Visualisierung erfordern Klartextdaten

Das Grundprinzip: **Ein System kann nur verarbeiten, was es lesen kann.** HYOK ist Schutz für ruhende Daten (Data at Rest), nicht für verarbeitete Daten (Data in Use).

13.5 Gesundheitssektor-Matrix

Workload	HYOK-Schutz möglich?	Empfehlung
ePA-Datenspeicherung (statisch)	[OK] Ja	HYOK auf EU-Infrastruktur
Patientendaten-Archiv	[OK] Ja	HYOK + EU-Anbieter
KIS-Software (Krankenhausinformationssystem)	[!] Nur wenn lokal	On-Premise oder EU-Anbieter
Telemedizin-Plattform	[X] Nein	Nur EU-souveräne Anbieter
KI-gestützte Diagnostik (US-LLM)	[X] Nein	On-Premise vLLM auf eigenem GPU-Cluster
SharePoint/Teams für Klinik	[X] Nein	Nextcloud auf STACKIT/Hetzner
Buchhaltung/ERP auf US-SaaS	[X] Nein	SAP on-premise oder EU-ERP

14. Bewertungsschema und Länderranking

Das Bewertungsschema in diesem Kapitel dient als analytisches Werkzeug, um die Datensouveränitätslage verschiedener Weltregionen vergleichbar zu machen. Es liegt dem Globalen Vergleich in Kapitel 15 zugrunde.

14.1 Das Bewertungsschema — 5 Dimensionen, 0–2 Punkte

Die Bewertung erfolgt entlang fünf Dimensionen, die zusammen das Souveränitätsprofil einer Region beschreiben. Jede Dimension wird mit 0 (nicht vorhanden), 1 (Ansatz vorhanden, unvollständig) oder 2 (strukturell verankert und durchgesetzt) bewertet. Maximalpunktzahl: 10/10. Ein hoher Score bedeutet nicht zwingend Rechtsstaatlichkeit — China führt das Ranking durch staatliche Kontrolle, nicht durch Grundrechtsschutz.

Dimension	0 Punkte	1 Punkt	2 Punkte
Recht	Kein Datenschutzgesetz	Gesetz vorhanden, kaum Durchsetzung	Gesetz + aktive Sanktionen
Infrastruktur	Keine eigenen RZ	Eigene RZ im Aufbau, Hyperscaler dominant	Funktionsfähige eigene Cloud-Infrastruktur
Anbieter	Nur US-Hyperscaler	Lokale Anbieter vorhanden, klein	Skalierbare lokale Alternativen ohne US-Exposure
Politik	Kein Bewusstsein	Strategiepapiere, keine Umsetzung	Staatliche Investitionen, Beschaffungsvorgaben
Technik	Proprietäre US-Abhängigkeit auf allen Ebenen	Teils Open Source, teils US-Stack	Eigener Stack auf Open Source, eigene Hardware

14.2 Gesamtranking

Das Ranking zeigt neun Weltregionen nach Gesamtpunktzahl. Die Sortierung nach Punktzahl ist bewusst provokant: Sie macht deutlich, dass Datensouveränität und Datenschutz zwei verschiedene Ziele sind. Regionen, die Datensouveränität durch staatliche Abschottung erreichen (China, Russland), schützen keine individuellen Grundrechte — sie kontrollieren Daten zugunsten des Staates. Europa hingegen hat die stärksten Datenschutzregeln weltweit, aber die schwächste Umsetzung in der eigenen Infrastruktur. Die Scoring-Logik macht dieses Paradox sichtbar.

Region	Recht	Infra	Anbieter	Politik	Technik	Gesamt	Kurzbewertung
CN China	2	2	2	2	2	**10/10**	Souverän — aber autoritär
RU Russland	2	2	2	2	1	**9/10**	Sanktionsgetrieben, vollständig abgeschottet
SAAE Arab. Staaten	2	2	1	2	1	**8/10**	Petrodollar-finanziert, US-Restrisiko
IN Indien	2	1	1	2	1	**7/10**	Regulierung mit echtem Biss
JP Japan	1	2	2	2	1	**7/10**	Staatlich finanziert, strukturiert
EU Europa	2	1	1	1	1	**6/10**	Beste Regeln, schwächste Umsetzung

Region	Recht	Infra	Anbieter	Politik	Technik	Gesamt	Kurzbewertung
BR Brasilien/Südamerika	1	1	1	1	1	**5/10**	Ansätze ohne Eigenaufbau
IL Israel	1	1	1	1	0	**4/10**	Starke Tech, delegierte Souveränität
AF Afrika	1	0	0	1	1	**3/10**	Wille ohne Infrastruktur

14.3 Das globale Muster

Die ausführliche Einordnung je Region folgt in Kapitel 15. Vorab das Kernparadox: Die Region mit der stärksten Datensouveränität ist nicht zwingend die mit dem stärksten Datenschutz — China und Russland führen das Ranking durch staatliche Kontrolle, nicht durch Grundrechtsschutz. Europa belegt Platz 4 mit den besten Regeln weltweit und der schwächsten Umsetzung in der eigenen Beschaffungspraxis.

15. Globaler Vergleich: Wie Regionen dem CLOUD Act entkommen

15.1 Das globale Problem in einem Satz

Alle Regionen der Welt stehen vor demselben Problem: Wer Daten bei einem US-Unternehmen speichert — egal ob der Server in Frankfurt, Mumbai oder Nairobi steht — kann von US-Behörden zur Herausgabe gezwungen werden. Die Reaktion weltweit ist dieselbe: raus aus der US-Abhängigkeit. Wie weit jede Region dabei ist, unterscheidet sich dramatisch.

15.2 China — vollständige Abschottung durch Industriepolitik

Strategie: Staatlich koordinierte nationale Champions, eigene Chips, eigene Protokolle.

- **Markt:** Alibaba Cloud (36%), Huawei Cloud (19%), Tencent Cloud, Baidu AI Cloud — zusammen 75%+ des Inlandsmarkts. AWS/Azure operieren nur über lizenzierte chinesische Partner.
- **Hardware:** Huawei entwickelt eigene Chips (Kunpeng, Ascend) — nach US-Exportverboten erzwungen, jetzt strukturell souverän
- **Open Source:** China Mobile baut Public Cloud auf OpenStack-Basis, gemeinsam mit Huawei und Ministry of Industry standardisiert
- **Staatliche Koordination:** SOEs als Pflicht-Anbieter für Behördendaten; "Made in China 2025" als industriepolitisches Programm

Caveat: China entkommt dem US CLOUD Act — aber unterliegt vollständig dem chinesischen Geheimdienstzugriff. Es ist kein Datenschutz, sondern ein Kontrollwechsel.

15.3 Russland — sanktionsgetriebene Vollabschottung

Strategie: Erzwungene Lokalisierung durch Sanktionen, eigene proprietäre Cloud-Stacks.

- **Gesetz:** Datenlokalisierungsgesetz 2015 + extraterritoriale Anwendung seit 2022 auf alle Unternehmen mit russischen Nutzern, unabhängig vom Firmensitz
- **Pflichtregister:** Seit Februar 2025 kein ausländischer Hosting-Anbieter ohne Roskomnadzor-Eintragung — bis März 2025 kein einziger ausländischer Antrag
- **Anbieter:** Yandex Cloud (30%+ Marktanteil), SberCloud, Rostelecom — 85%+ nationaler Markt
- **Technik:** Sber migriert 2025 von Kubernetes auf eigenen Container-Orchestrator. Sovereign Internet Law: eigenes DNS als Alternative zum globalen System
- **Marktgröße:** 3,1 Mrd. USD 2025, projiziert 7,4 Mrd. USD 2033

Caveat: Russland entkommt dem CLOUD Act — ist aber dem FSB-Geheimdienstzugriff vollständig ausgesetzt. Kein Gewinn für Datenschutz.

15.4 Arabische Staaten — Petrodollar-finanzierte Souveränität

Strategie: US-Anbieter lokal erzwingen, eigene Regeln setzen, mit Finanzmacht durchsetzen.

- **Saudi-Arabien:** 18-Milliarden-Dollar-Rechenzentrum-Strategie. Alle drei großen US-Hyperscaler haben lokale Zonen gebaut. PDPL mit Datenlokalisierungspflicht.
- **UAE:** OneCloud — vollständig innerhalb der Landesgrenzen betriebene souveräne Hyperscale-Plattform auf Oracle Alloy. UAE Digital Government Strategy 2025.
- **Sonderkonditionen:** Arabische Staaten zwingen US-Anbieter zu lokalen Servern, lokalem Personal, lokaler Schlüsselverwaltung und Sonderklauseln, die eigene Gesetze über US-Nutzungsbedingungen stellen.
- **Restrisiko:** Für Verteidigung und kritische Infrastruktur bleibt CLOUD-Act-Risiko strukturell bestehen.

Caveat: Sovereignty-Washing auf Hochglanz — aber mit echter Finanzkraft dahinter.

15.5 Israel — das lehrreichste Negativbeispiel

Strategie: Volle Abhängigkeit von Google und Amazon — mit vertraglich erkauften Sonderklauseln.

- **Project Nimbus:** 1,2-Milliarden-Dollar-Vertrag mit Google und Amazon für Cloud-Services für Regierung, Verteidigungsapparat und IDF. Lokale Rechenzentren in Israel.
- **Sonderklausel 1:** Vertrag verbietet Google und Amazon explizit, Israel den Dienst zu verweigern — auch wenn israelische Nutzung gegen Nutzungsbedingungen verstößt.
- **Wink-Mechanismus:** Israel bestand auf versteckten Signalen in Zahlungstransaktionen, die geheim anzeigen, wenn ausländische Gerichte Datenzugriff verlangen. Google und Amazon stimmten zu. Microsoft weigerte sich und verlor den Auftrag.
- **Was schiefging:** Microsoft sperrte Azure-Zugang für Geheimdiensteinheit 8200 — ein Knopfdruck in Redmond, der buchstäblich eine Datenkammer in Tel Aviv abdunkelte. Lokale Server bedeuten keine lokale Kontrolle.

Zitat Israel Democracy Institute: *"Israel kann von Datensouveränität sprechen, aber sobald Daten auf Microsoft Azure, AWS oder Google Cloud liegen, liegt das Schicksal dieser Daten in den Händen der Unternehmen, nicht des Staates."*

Caveat: Israel hat eine der stärksten Cyber-Tech-Industrien der Welt — und hat seine Staatssouveränität dennoch bewusst an zwei US-Konzerne ausgelagert.

15.6 Indien — Regulierung mit echtem Biss

Strategie: Datenlokalisierung durch Gesetz mit echter Sanktionierung.

- **DPDP Act 2023:** Pflicht zur Datenspeicherung in Indien für sensible Kategorien
- **RBI-Sanktionen:** American Express gesperrt (2021), Mastercard blockiert (2021) — wegen Datenspeicherung außerhalb Indiens. Das ist echter Biss.
- **Staatliche Cloud:** NIC Cloud für Behörden. RBI baut 2025/26 eigene Financial Services Cloud für alle Banken.
- **Problem:** Indien erzeugt 20% der weltweiten Daten — hat aber weniger als 2% der globalen RZ-Kapazität.

15.7 Japan — staatlich finanziertes Drei-Souveränitäten-Modell

Strategie: Klare Architektur-Vorgabe + 500 Mio. USD Staatsförderung.

- **Drei Souveränitäten (NTT DATA):** Data Sovereignty (Verschlüsselung), System Sovereignty (Software-Spezifikationen, Quellcode), Operational Sovereignty (japanisches Personal, lokale Schlüssel)
- **ESPA:** ca. 500 Mio. USD für souveräne Cloud- und KI-Rechenkapazitäten
- **Government Cloud:** Sakura Internet baut den Government Cloud — japanisches Unternehmen, japanische RZ, japanisches Personal
- **Industriekonzerne:** NTT und Fujitsu bauen souveräne Plattformen für regulierte Industrien

15.8 Brasilien & Südamerika — Ansätze ohne Eigenaufbau

- LGPD (Brasiliens DSGVO) seit 2020 — Regulierung vorhanden, Durchsetzung schwächer als Indien
- AWS São Paulo: lokale Region, aber US-Anbieter
- Heimische Anbieter: kaum skalierbar; Rest Südamerikas weitgehend auf US-Hyperscaler angewiesen

15.9 Afrika — Wille ohne Infrastruktur

- 223 Rechenzentren auf 54 Länder verteilt (Mitte 2025). Südafrika 56, Kenia 19, Nigeria 17
- Nigeria: 17 RZ in Lagos, Stromnetz liefert im Schnitt 4 Stunden täglich — Dieselgeneratoren erforderlich
- Afrika erzeugt 18% der Weltbevölkerung, aber weniger als 4% der globalen KI-Trainingsdaten
- Strategischer Ausweg: Shared Digital Infrastructure — regionale RZ-Pools statt Einzelkämpfer je Land

15.10 Das globale Muster — ein Satz je Region

• **China & Russland:** Souverän — aber wegen staatlicher Kontrolle, nicht Datenschutz. Kein Modell für Europa.

• **Arabische Staaten:** Kaufen Souveränität mit Petrodollar — zwingen US-Anbieter zu lokalen Servern, Schlüsseln, Regeln.

• **Indien & Japan:** Machen es richtig — Regulierung mit Biss plus staatliche Finanzierung eigener Infrastruktur.

• **Europa:** Hat die besten Regeln der Welt — und kauft trotzdem bei US-Hyperscalern ein. Das ist der europäische Widerspruch.

• **Israel:** Das lehrreichste Negativbeispiel — stärkste Cyber-Nation, schwächste Cloud-Souveränität. Microsoft konnte buchstäblich das Licht ausknipsen.

• **Brasilien & Afrika:** Wollen — können noch nicht. Infrastruktur fehlt.

16. Aufsichts- und Regulierungslandschaft: Wer den Rahmen setzt — und wer nicht durchsetzt

§1.2.2 dokumentiert das Vollzugsdefizit: Kein einziges Bußgeld gegen eine Gesundheitsinstitution wegen US-Cloud-Nutzung ist öffentlich bekannt. Dieses Kapitel zeigt, warum. Die regulatorische Zuständigkeit für Cloud und KI im Gesundheitswesen ist auf mehr als ein Dutzend Institutionen verteilt — keine davon deckt das Gesamtbild ab. Das CLOUD-Act-Problem fällt systematisch zwischen die Zuständigkeiten.

16.1 Wer ist zuständig — und wofür nicht

Institution	Zuständigkeit im Kontext Cloud/KI	Was sie nicht prüft
BfDI (Bundesbeauftragter für den Datenschutz)	DSGVO-Aufsicht über Bundesbehörden; KI-Handreichung Dezember 2025	Keine Fachaufsicht über GKVen oder Kliniken; keine Sanktionskompetenz gegen US-Anbieter
16 Landesaufsichtsbehörden	DSGVO-Aufsicht über Landesbehörden, Unikliniken, landesunmittelbare GKVen	Kein koordiniertes Enforcement; DSK-Beschlüsse nicht rechtsverbindlich; keine Jurisdiktionsprüfung
BAS (Bundesamt für Soziale Sicherung)	Rechts- und Fachaufsicht über bundesunmittelbare GKVen (TK, Barmer, DAK, AOK BV u.a.); Digitalausschuss seit 2020; Rundschreiben "Cloud-basierte IT-Lösungen in der Sozialversicherung" (2017/2018, aktualisiert); Selbstverpflichtende KI-Leitlinien im BMAS-Netzwerk; betreut Kassen-Sondervereinbarung mit Microsoft	Kein DSGVO-Enforcement — das bleibt beim BfDI; Cloud-Rundschreiben fokussiert Datenortung (EU/EWR) und AVV, nicht Jurisdiktionsprüfung; keine öffentliche CLOUD-Act-Bewertung
BMG (Bundesgesundheitsministerium)	Gesetzgebung: DigiG/§ 393 SGB V (2024), GDNG (2024), GeDIG (Entwurf 2026); C5-Äquivalenzverordnung (RefE Januar 2025); Digitalisierungsstrategie "Gemeinsam Digital" (Update Februar 2026: KI-Dokumentation in 70% der Einrichtungen bis 2028); GDAG — gematik wird Gesundheits-Digitalagentur mit Durchsetzungsbefugnissen	Reguliert Rahmenbedingungen, nicht Einzelfälle; § 393 adressiert IT-Sicherheit (C5), nicht Jurisdiktion; US-Anbieter nicht ausgeschlossen wenn DPF-zertifiziert + C5 + DE-Niederlassung; AWS hat Lobbytätigkeit zu § 393 im Lobbyregister (RV0008560) eingetragen
gematik	TI-Betrieb; Zulassung von TI-Komponenten, TI-Gateways, ePA-Anbietern; C5-Testat-Liste (INA-Portal); TI 2.0 ZETA/Zero Trust (quelloffen seit Dezember 2025); Impulspapier "KI im Gesundheitswesen" (Juli 2025): FHIR-Starter-Projekt, KI für Datenstrukturierung; wird unter GDAG zur Digitalagentur mit Durchsetzungsbefugnissen	Keine DSGVO-Aufsicht; keine Jurisdiktionsprüfung bei Zulassungen; TI-Gateway-Zulassung prüft Sicherheit, nicht CLOUD-Act-Exposition; Datensouveränität als Designprinzip formuliert, aber kein Ausschluss US-basierter Gateway-Betreiber
G-BA (Gemeinsamer Bundesausschuss)	Höchstes Beschlussgremium der gemeinsamen Selbstverwaltung; DiGA-Aufnahme (BfArM zuständig); Richtlinien für Versorgung	Keine Cloud- oder KI-spezifische Regulierung; keine Datenschutzaufsicht
BfArM	DiGA-Zulassung; Datensicherheitsanforderungen (mit BSI) für digitale Gesundheitsanwendungen ab 01.01.2025	Prüft Funktionstauglichkeit und Datensicherheit, nicht Cloud-Jurisdiktion des Herstellers
BSI	IT-Sicherheit: C5-Testat, C5:2026, BSI-TR Gesundheitsanwendungen; Souveränitätskriterien angekündigt (mit ANSSI, separates Dokument)	C5 prüft Informationssicherheit, **nicht** Jurisdiktion — das ist die dokumentierte Lücke aus §1.1

Institution	Zuständigkeit im Kontext Cloud/KI	Was sie nicht prüft
KBV (Kassenärztliche Bundesvereinigung)	IT-Sicherheitsrichtlinie nach § 390 SGB V (verpflichtend ab Oktober 2025); Cloud-Apps nur mit C5-Testat nach § 393; Microsoft-Cloud-Sync muss deaktiviert werden; PraxisWissen "KI in Praxen" (Mai 2025): KI = Cloud-Anwendung mit C5-Pflicht, Arzt behält Entscheidungshoheit, Patienteneinwilligung bei KI-Transkription	Cloud-Anbieterjurisdiktion nicht adressiert; Deaktivierung Microsoft-Cloud-Sync ist stärkste praktische Einschränkung, aber begründet mit Datensicherheit, nicht CLOUD Act
DKG (Deutsche Krankenhausgesellschaft)	Positionspapier "KI im Krankenhaus" (Oktober 2025): fordert Cloud-Betrieb für KI als Notwendigkeit; KHZG-2.0-Finanzierung	Interessenvertretung, keine Aufsicht; fordert regulatorische Klarstellung, setzt sie nicht selbst
GKV-Spitzenverband	Digitalstrategie (Dezember 2025): KI-gestützte ePA-Analyse, FDZ-Datennutzung; digitales Primärversorgungssystem	Interessenvertretung der Kassen; keine Aufsichtsfunktion; Cloud-Souveränität kein dokumentierter Schwerpunkt
PKV-Verband	Digitalisierungsstrategie für private Krankenversicherungen	Keine öffentliche Cloud- oder KI-Positionierung bekannt; PKV unterliegt nicht § 393 SGB V
MD Bund (Medizinischer Dienst)	Qualitätsprüfungen; KI-Grundregeln (MD Sachsen-Anhalt, 2025): nur geschlossene Systeme, keine kommerziellen KI-Modelle, abschließende Entscheidung beim Menschen	Keine Cloud-Regulierung; KI-Grundregeln nur intern; keine Aufsicht über andere Institutionen

16.2 Datenschutzaufsicht — Flickenteppich bei Microsoft 365 / Azure

Die Positionierung aller deutschen Datenschutzaufsichtsbehörden zu Microsoft 365 / Azure (Stand April 2026):

Behörde	Zuständigkeit	Position Microsoft 365 / Azure	Tendenz
BfDI (Bund)	Bundesbehörden, bundesweite GKVen (BAS)	2022: Rundschreiben an alle Bundesministerien mit Bedenken; kein förmliches Verbot	[!] Kritisch, keine Sanktionen
BAS	Bundesunmittelbare GKVen (AOK Bund, Barmer, TK, DAK u.a.)	Keine eigene Microsoft-Positionierung öffentlich bekannt; orientiert sich an BfDI	[!] Unklar
Bayern BayLDA (privat)	Private Unternehmen, GKVen mit Landesaufsicht	DSK-Gesamtbewertung 2022 "zu undifferenziert" — kein Verbot; Freistaat verhandelt Rahmenvertrag M365 für gesamte Verwaltung (Stand 2025)	[Y] Pragmatisch, Einzelfallprüfung
Bayern BayLfD (öffentlich)	Landesbehörden, Unikliniken BY	Lehnte M365 an Schulen ab (2021); Einzelfallverbot auf Beschwerde; kein generelles Verbot	[!] Kritisch, aber kein Generalverbot
Baden-Württemberg LfDI	Landesbehörden, Unikliniken BW	M365 2021 abgelehnt für Schulen; 2022 Ausstiegsgebot; digitaler Arbeitsplatz Lehrkräfte mit M365 gestartet April 2024 — faktische Kehrtwende	[Y] Kritisch→pragmatisch
Berlin BlnBDI	Landesbehörden, Unikliniken BE	2020: "nicht möglich"; Copilot an Berliner Schulen 2024 eingeführt ohne DSB-Einbindung (Tagesspiegel) — faktischer Widerspruch zur eigenen Position	[!] Kritisch, Umsetzung widersprüchlich
Brandenburg LDA	Landesbehörden, Unikliniken BB	Beteiligt an EDSA-Kontrollaktion 2024; keine spezifische M365-Positionierung öffentlich bekannt	[!] Unklar

Behörde	Zuständigkeit	Position Microsoft 365 / Azure	Tendenz
Bremen LfDI	Landesbehörden	2023/24 Tätigkeitsbericht: iCloud-Nutzung als rechtswidrig eingestuft; M365 mit Bedenken	[!] Kritisch
Hamburg HmbBfDI	Landesbehörden, Polizei	Signalisierte 2024 Abweichung von Niedersachsen-Modell; Microsoft Teams für Polizei Hamburg trotzdem im Einsatz	[R] Kritisch, aber kein Verbot durchgesetzt
Hessen HBDI	Landesbehörden, Unikliniken HE	Nov. 2025: 137-seitiger Bericht — "Microsoft 365 kann datenschutzkonform genutzt werden" unter Bedingungen; Verhandlungen mit Microsoft direkt	[G] Positiv (mit Auflagen)
Mecklenburg-Vorpommern LfDI	Landesbehörden	Beteiligt an EDSA-Kontrollaktion 2024; keine eigene M365-Positionierung öffentlich bekannt	[!] Unklar
Niedersachsen LfD	Landesbehörden, Unikliniken NI	April/Mai 2024: Microsoft Teams Vereinbarung als "akzeptabel" bewertet; Rollout 13.500 Arbeitsplätze	[G] Positiv (Vorreiter)
NRW LDI	Landesbehörden, Unikliniken NW, KVNO/KVWL	Mai 2024: "Keine Informationen vor, die Überarbeitung bieten würden" — kritisch zu neuem Outlook; kein Verbot	[!] Kritisch, kein Verbot
Rheinland-Pfalz LfDI	Landesbehörden, Unikliniken RP	Beteiligt an EDSA-Kontrollaktion 2024; keine eigene M365-Positionierung öffentlich bekannt	[!] Unklar
Saarland LfDI	Landesbehörden	DSK-Gesamtbewertung 2022 nicht geteilt; signalisierte 2024 Abweichung vom Niedersachsen-Modell	[Y] Pragmatisch
Sachsen DSB	Landesbehörden, Unikliniken SN (UKL Dresden!)	Keine spezifische M365-Positionierung öffentlich bekannt	[!] Unklar
Sachsen-Anhalt LfDI	Landesbehörden, Unikliniken SA	Keine spezifische M365-Positionierung öffentlich bekannt	[!] Unklar
Schleswig-Holstein ULD	Landesbehörden	Mai 2024: "Teile die Ansicht des EDPS, dass Zwecke nicht transparent genug sind"; bisher keine geänderte Bewertung; SH setzt parallel auf Open-Source-Stack	[R] Kritisch
Thüringen TLfDI	Landesbehörden, Unikliniken TH	Keine spezifische M365-Positionierung öffentlich bekannt	[!] Unklar
Vergabekammer München	Vergaberechtlich (nicht Datenschutz)	Feb. 2023: Pauschaler Azure-Ausschluss unzulässig — Einzelfallprüfung geboten	[Y] Pragmatisch (vergaberechtlich)

Bedeutung für das Gesundheitswesen: Unikliniken unterstehen ihrer Landesaufsicht — ein Klinikum in Hessen oder Bayern hat strukturell mehr Spielraum für Azure als eines in Hamburg oder Schleswig-Holstein. GKVen unterstehen je nach Kassengröße dem BAS oder Landesaufsichten. Der BAS hat keine eigene öffentliche Microsoft-Positionierung — bundesunmittelbare Kassen wie Barmer oder TK operieren faktisch in einem Vakuum.

Das Fazit: Wer bei der "richtigen" Aufsichtsbehörde sitzt, bekommt Azure genehmigt oder zumindest toleriert. Wer Pech hat, bekommt eine Mahnung ohne Konsequenz. **STACKIT und EU-souveräne Alternativen werden primär dort gewählt, wo die Aufsicht Druck macht (Hamburg, Schleswig-Holstein) oder die Ausschreibungsgestaltung es erzwingt.** Das Enforcement-Gap ist das eigentliche strukturelle Problem: Die Regelungslücke existiert — aber sie hat keinen einheitlichen Preis.

16.3 DSK- und Landesaufsichts-Hinweise zu Cloud und KI im Gesundheitswesen

Die Microsoft-365-Tabelle bildet nur eine Dimension ab: die Haltung zu einem bestimmten Produkt. Parallel dazu haben DSK und einzelne Landesaufsichtsbehörden zwischen 2023 und 2026 konkrete Orientierungshilfen, Beschlüsse und Prüfaktionen veröffentlicht, die **Cloud-Nutzung für Gesundheitsdaten** und **KI-Anwendungen mit Cloud-Infrastruktur** direkt adressieren. Für Gesundheitsinstitutionen sind diese Dokumente handlungsrelevanter — sie definieren, was Aufsichtsbehörden bei einer Prüfung tatsächlich verlangen.

Dokument	Herausgeber	Datum	Kernaussage für Gesundheitsinstitutionen
Positionspapier cloudbasierte digitale Gesundheitsanwendungen	DSK	06.11.2023	Cloud-Funktionen standardmäßig deaktiviert (Privacy by Default); Nutzung ohne Benutzerkonto möglich, es sei denn Cloud ist therapeutisch zwingend; BSI-TR "Anforderungen an Anwendungen im Gesundheitswesen" als Maßstab
Orientierungshilfe KI-Systeme (TOM für Entwicklung und Betrieb)	DSK (KI-Taskforce + AG KI)	Mai/Juni 2025	Erste koordinierte KI-Orientierungshilfe aller Aufsichtsbehörden; Risikoanalyse für LLMs als Kernstück; auch pseudonymisierte Eingaben = personenbezogene Daten; DSFA nach Art. 35 DSGVO erforderlich; 3 Phasen: Konzeption → Implementierung → Betrieb
Entschließung Confidential Cloud Computing	DSK	16.06.2025	Cloud-Betreiber behalten "umfassenden physischen und technischen Zugriff" — Marketingversprechen halten "regelmäßig einer Prüfung nicht stand"; Vertraulichkeit nur gegeben wenn Betreiber **keinerlei** Zugriff auf Entschlüsselungsschlüssel hat; Confidential Computing = ein Baustein, kein Allheilmittel
Positionspapier Terminverwaltung Heilberufspraxen	DSK	16.06.2025	Patientenstammdaten dürfen nicht pauschal an Cloud-Termindienstleister übermittelt werden; nur Minimum für konkreten Termin; zeitnahe Löschung
KI-Handreichung Bundesverwaltung ("KI in Behörden — Datenschutz von Anfang an mitdenken")	BfDI	22.12.2025	Leitfaden für Bundesbehörden inkl. bundesunmittelbare GKVen; Fokus LLMs und cloud-basierte KI-Dienste; Datenschutz ab Konzeptionsphase

Dokument	Herausgeber	Datum	Kernaussage für Gesundheitsinstitutionen
Diskussionspapier "Rechtsgrundlagen Datenschutz + KI" (v2.0)	LfDI Baden-Württemberg	17.10.2024	Rechtsgrundlage für jede KI-Phase separat erforderlich; cloud-basierte KI = eigene Rechtsgrundlage wenn Nutzerdaten Modell verbessern; EHDS-VO für sekundäre Gesundheitsdatennutzung referenziert
Checkliste "Datenschutz und KI" + Flyer "Next-Level-Bausteine für KI"	BayLDA	2024/2025	AI-as-a-Service = Auftragsverarbeitung (Art. 28 DSGVO); Drittlandstransfer bei US-Anbietern prüfen; Halluzinationen und Bias in DSFA einbeziehen
Aktive KI-Prüfung im Gesundheitswesen (Auskunftsersuchen nach Art. 58 Abs. 1 lit. a DSGVO)	LfDI Rheinland-Pfalz	März 2026	**Erste dokumentierte Enforcement-Aktion KI + Gesundheitswesen:** Prüft KI-Telefonanlagen, KI-Dokumentenmanagement, KI-Websites in Arztpraxen; verlangt vollständiges Verzeichnis aller KI-Tools inkl. Einsatzzweck und zugrundeliegende Modelle; fehlende Dokumentation = Verstoß gegen Rechenschaftspflicht
Positionspapier "Kriterien für Souveräne Clouds"	DSK	11.05.2023	Souveräne Cloud nur wenn Verantwortlicher Datenschutzpflichten "wirksam, überprüfbar und dauerhaft" erfüllen kann; Drittlandszugriffsrisiko muss **ausgeschlossen** sein; Open-Source-Basis empfohlen; offene Standards und Exportmöglichkeiten
Empfehlungen zu KI-Anbietern außerhalb der EU (inkl. koordiniertes Verfahren gegen DeepSeek)	LfDI Baden-Württemberg	2025	Warnung vor KI-Anbietern ohne Art.-27-DSGVO-Vertreter in der EU; koordinierte Verfahren gegen DeepSeek eingeleitet; Drittstaatentransfer bei KI-as-a-Service systematisch prüfen
Orientierungshilfe Gesundheits datennutzungsgesetz (GDNG)	BayLfD	Januar 2026	Orientierungshilfe zu §§ 5 und 6 GDNG und EHDS; Muster-Einwilligung nach § 6; Living Document mit regelmäßigen Updates
Leitfaden Datenschutz in der medizinischen Forschung (mit DGIM)	HBDI	Dezember 2025	Vier konkrete Use Cases aus der medizinischen Forschung; Pseudonymisierung über Treuhandstelle; föderierte Datenmodelle; Living Document

Dokument	Herausgeber	Datum	Kernaussage für Gesundheitsinstitutionen
CEF Cloud-Nutzung öffentlicher Stellen	EDPB (7 deutsche Landesbehörden beteiligt)	2023 (Bericht)	Koordinierte Prüfung der Cloud-Nutzung durch öffentliche Stellen inkl. Gesundheitswesen; nur 32 von 86 geprüften Stellen hatten vor Cloud-Einsatz eine DSFA durchgeführt; Ergebnisbericht mit Empfehlungen zu Auftragsverarbeitung und Drittlandstransfer

16.4 Das Gesamtbild — warum niemand das CLOUD-Act-Problem "besitzt"

Die Tabelle in §16.1 zeigt das strukturelle Problem: Die CLOUD-Act-Exposition von Gesundheitsdaten fällt zwischen alle Zuständigkeiten.

Das BSI prüft Informationssicherheit — nicht Jurisdiktion. C5 zertifiziert Azure, obwohl Azure dem CLOUD Act unterliegt. Das BSI weiß das, hat Souveränitätskriterien deshalb als separates Dokument angekündigt, aber noch nicht veröffentlicht.

Das BMG hat mit § 393 SGB V die Cloud-Nutzung erlaubt und C5 als Mindeststandard festgelegt — ohne die Jurisdiktionsfrage zu adressieren. Das GeDIG (Entwurf 2026) erweitert den Datenpool (ePA-Ausbau, FDZ-Ausleitung), adressiert aber ebenfalls nicht, auf welcher Infrastruktur diese Daten verarbeitet werden dürfen.

Das BAS beaufsichtigt die bundesunmittelbaren GKVen (TK, Barmer, DAK — zusammen > 30 Mio. Versicherte). Es hat ein Rundschreiben zu Cloud-IT-Lösungen (2017/2018, aktualisiert), das Datenortung (EU/EWR) und Auftragsverarbeitungsverträge regelt — aber keine Jurisdiktionsprüfung verlangt. Der BAS-Digitalausschuss betreut eine Sondervereinbarung mit Microsoft für die Sozialversicherungsträger und berät Kassen zu KI und Automatisierung. Aber eine CLOUD-Act-Bewertung gehört nicht zum dokumentierten Prüfprogramm. Das BAS reguliert, **ob** die Cloud in der EU steht — nicht **wer** per Gesetz auf die Daten zugreifen kann.

Die gematik vergibt TI-Gateway-Zulassungen, die bestimmen, über welchen Anbieter Praxen und Kliniken künftig ihre TI-Anbindung beziehen. Ob ein TI-Gateway-Betreiber dem CLOUD Act unterliegt, ist kein Zulassungskriterium. Die TI-2.0-Architektur (ZETA/Zero Trust, seit Dezember 2025 quelloffen auf GitHub) ist ein Sicherheitskonzept — kein Souveränitätskonzept.

Die Datenschutzaufsichtsbehörden könnten das Problem adressieren — und tun es punktuell (Rheinland-Pfalz März 2026). Aber DSK-Beschlüsse sind nicht rechtsverbindlich, Prüfungen erfolgen anlassbezogen, und die 16 Landesaufsichten plus BfDI kommen zu unterschiedlichen Ergebnissen (§16.2). Die DSK hat mit dem Positionspapier "Kriterien für Souveräne Clouds" (Mai 2023) klar formuliert, dass Drittlandszugriffsrisiken **ausgeschlossen** sein müssen — aber dieses Papier hat keine Bindungswirkung und wird in Vergabeverfahren regelmäßig nicht herangezogen.

Die Selbstverwaltung (KBV, DKG, GKV-Spitzenverband) vertritt Interessen, hat aber keine Aufsichtsfunktion. Die DKG fordert in ihrem KI-Positionspapier (Oktober 2025) explizit Cloud-Betrieb als Notwendigkeit für KI — ohne die Jurisdiktionsfrage zu stellen. Der GKV-Spitzenverband fordert in seiner Digitalstrategie (Dezember 2025) KI-gestützte ePA-Analyse — ohne Cloud-Souveränität als Anforderung zu definieren.

Das Ergebnis: Jede Institution erfüllt ihren Auftrag korrekt — aber niemand ist dafür zuständig, die Frage zu stellen: "Unterliegt der Cloud-Anbieter, bei dem wir Gesundheitsdaten von 74 Millionen GKV-Versicherten verarbeiten, einer US-Herausgabepflicht?" Das BSI sagt: "Nicht mein Prüfgegenstand." Das BMG sagt: "C5 regelt die Sicherheit." Das BAS sagt: nichts Öffentliches. Die gematik sagt: "Wir prüfen Sicherheit, nicht Jurisdiktion." Die Datenschutzaufsicht sagt: "Problematisch" — und verhängt kein Bußgeld.

Dieses Muster — regulatorische Vollständigkeit bei gleichzeitiger Zuständigkeitslücke für das Kernrisiko — ist der institutionelle Grund für das Vollzugsdefizit aus §1.2.2. Es ist kein Versagen einzelner Behörden, sondern ein Systemdesign, das die CLOUD-Act-Frage strukturell unsichtbar macht.

16.5 Was das für Gesundheitsinstitutionen konkret bedeutet

1. **Cloud-Gesundheitsanwendungen** unterliegen seit dem DSK-Beschluss November 2023 konkreten Anforderungen an Privacy by Default — Cloud-Funktionen müssen deaktivierbar sein. Jede GKV oder Klinik, die eine Cloud-basierte Gesundheitsanwendung einführt (z.B. DiGA-ähnliche Apps, Patientenportale), muss diese Anforderungen nachweisen können.

2. **KI-Anwendungen** mit Cloud-Backend erfordern seit der DSK-Orientierungshilfe Mai/Juni 2025 eine eigene DSFA — insbesondere für LLMs. Das betrifft direkt die KI-Anwendungsfälle aus §7.5: Arztbrief-Generierung, Transkription, Kodierung. Wer Azure OpenAI, Google Gemini oder AWS Bedrock für Gesundheitsdaten nutzt, muss eine DSFA vorlegen, die explizit die Klartextverarbeitung und den Drittlandstransfer adressiert.

3. **Confidential Cloud Computing** schützt laut DSK-Entschließung Juni 2025 **nicht** vor Provider-Zugriff — das bestätigt die CLOUD-Act-Analyse aus §1 und §13: Technische Maßnahmen allein lösen das Jurisdiktionsproblem nicht.

4. **Rheinland-Pfalz macht ernst:** Die Art.-58-Auskunftsersuchen des LfDI Rheinland-Pfalz ab März 2026 sind die erste dokumentierte anlassbezogene Prüfung von KI im Gesundheitswesen durch eine Landesaufsicht. Gesundheitsinstitutionen müssen ein vollständiges Verzeichnis aller eingesetzten KI-Tools vorhalten — inklusive der zugrundeliegenden Modelle und deren Infrastruktur. Wer nicht dokumentieren kann, welches Modell seine Arztbrief-KI antreibt und wo es läuft, riskiert einen Rechenschaftspflicht-Verstoß nach Art. 5 Abs. 2 DSGVO.

5. **BfDI-Handreichung** (Dezember 2025) gilt für alle bundesunmittelbaren Stellen — das schließt die großen bundesunmittelbaren GKVen (Barmer, TK, DAK, AOK-Bundesverband) ein, die bislang im "Vakuum" operierten (s.o.). Für diese Kassen ist die BfDI-Handreichung die erste konkrete Erwartungshaltung des Bundesbeauftragten zu KI und Cloud.

17. DSGVO-Handlungsempfehlungen

§16 zeigt: Keine Institution ist dafür zuständig, die CLOUD-Act-Exposition als Ganzes zu prüfen. Die Datenschutzaufsicht ist fragmentiert (§16.2), die DSK-Beschlüsse sind nicht rechtsverbindlich (§16.3), und Gesundheitsregulierer wie BMG, BAS und gematik adressieren IT-Sicherheit, nicht Jurisdiktion (§16.1). Diese Lücke fällt auf die einzelne Gesundheitsinstitution zurück. Die folgenden Empfehlungen berücksichtigen deshalb nicht nur die DSGVO-Anforderungen, sondern auch die konkreten Erwartungen der Aufsichtsbehörden — insbesondere die DSK-Orientierungshilfe KI (§16.3), die KBV-IT-Sicherheitsrichtlinie (ab Oktober 2025), die BfDI-KI-Handreichung (Dezember 2025) und die ersten Enforcement-Aktionen (LfDI Rheinland-Pfalz, März 2026).

17.1 Sofortmaßnahmen — Priorität hoch

#	Maßnahme	Was konkret zu tun ist
1	Anbieter-Kontrollanalyse	(a) US-Börsennotierung? (b) US-Muttergesellschaft? (c) US-Niederlassung — auch Tochter oder Schwester? Wenn eine Frage Ja: CLOUD-Act-Risiko real — unabhängig von Serverstandort, AVV und SCCs.
2	Datenklassifizierung	Klasse 1 (ePA, Diagnosedaten, Medikation) → Full-Isolation-Anbieter oder Operator-Modell mit BSI CPR. Klasse 2 (interne Kommunikation, Analytics) → EU-Anbieter akzeptabel. Klasse 3 (öffentliche Daten) → keine Einschränkung.
3	C5-Testat neu einordnen	Auch C5:2026 (April 2026, 168 Kriterien) belegt **technische Sicherheit**, nicht rechtliche Souveränität. Azure hat C5 und unterliegt dem CLOUD Act. plusserver/STACKIT haben C5 und unterliegen ihm strukturell nicht. Delos Cloud hat BSI Cloud Platform Requirements — strenger als C5. BSI und ANSSI haben im November 2025 gemeinsame Souveränitätskriterien angekündigt — bis zu deren Veröffentlichung bleibt C5 allein kein Souveränitätsnachweis.
4	DPF nicht als Schutzschild	Das Data Privacy Framework basiert auf einem Präsidialerlass. PCLOB-Aufsicht ausgehöhlt seit Jan. 2025. Schrems III läuft. Keine Infrastrukturentscheidungen auf DPF-Dauerhaftigkeit bauen.
5	Operator-Modell prüfen	Für Organisationen tief in Microsoft 365 oder Azure integriert: Delos Cloud GmbH (SAP-Tochter) als souveräner Betreiber von Azure-Technologie prüfen. BSI Cloud Platform Requirements erfüllt, VS-NfD-fähig. Preisaufschlag: +15% auf Microsoft-Listenpreise.

#	Maßnahme	Was konkret zu tun ist
6	KI-Inventar erstellen	Vollständiges Verzeichnis aller eingesetzten KI-Tools — inklusive Einsatzzweck, zugrundeliegende Modelle und deren Infrastruktur. Seit März 2026 verlangt der LfDI Rheinland-Pfalz genau diese Dokumentation per Art.-58-Auskunftsersuchen (§16.3). Fehlende Dokumentation = Rechenschaftspflicht-Verstoß (Art. 5 Abs. 2 DSGVO). Für LLM-basierte Anwendungen (Arztbrief-KI, Transkription, Kodierung): DSFA nach Art. 35 DSGVO erforderlich (DSK-Orientierungshilfe KI, Juni 2025).

17.2 Das Vier-Stufen-Modell — welche Stufe für welchen Workload

Das entscheidende Planungswerkzeug ist nicht mehr die binäre Frage "US-Hyperscaler oder nicht" — sondern die Einordnung jedes Workloads in das Souveränitätsspektrum:

Stufe 1 — Vollständige Abschottung (Full Isolation) Kein US-Technologieanteil, kein US-Eigentümer, kein US-Betrieb. Maximale rechtliche Souveränität.

Anbieter: plusserver, EWERK Leipzig (DE); 3DS Outscale, Cloud Temple (FR); STACKIT (mit Vorbehalt Lidl-US-Schwester)

Geeignet für: ePA-Kerndaten, KRITIS-Systeme, VS-NfD-Infrastruktur, GKV-Kernabrechnungssysteme, genetische Daten, psychiatrische Diagnostik — alles mit höchstem Schutzbedarf nach § 393 SGB V.

Vollständiger Technik-Stack (alle Komponenten heute produktionsreif):

Funktion	US-Stack (ersetzt)	EU-Stack (Ersatz)
Office-Suite	Microsoft 365 / Office	Euro-Office, Nextcloud Hub, Office.eu
E-Mail / Kalender	Exchange Online / Outlook	Open-Xchange + Thunderbird
Dokumentenmanagement	SharePoint Online	Nextcloud, OpenCloud, GoFAST
Video / Chat	Microsoft Teams	Jitsi, OpenTalk, Matrix/Element
Identity / SSO	Azure Active Directory	Keycloak, Univention Corporate Server
Cloud-Infrastruktur	Azure Compute / Storage	STACKIT, plusserver, Hetzner (EU-RZ)
Objektspeicher	Azure Blob Storage	MinIO, Ceph, STACKIT Object Storage
Datenbank	Azure SQL / CosmosDB	PostgreSQL, MariaDB
Container	Azure Kubernetes Service	Kubernetes (self-managed)
KI-Inferenz	Azure OpenAI / Copilot	vLLM + Mistral (lokal / STACKIT)
Analytics / BI	Power BI / Fabric	Metabase, Apache Superset, Grafana
CI/CD	Azure DevOps / GitHub	GitLab (self-hosted)
Logging / SIEM	Azure Monitor / Sentinel	Grafana + Loki + OpenSearch / Wazuh

Praxisbeleg: Schleswig-Holstein betreibt diesen Stack für 30.000 Mitarbeitende — mit €15 Millionen jährlichen Einsparungen bei einmalig €9 Millionen Investition. Engpass ist nicht Technologie, sondern Betriebspersonal und Fachverfahren-Integration.

Stufe 2 — Operator-Modell EU-Rechtsperson als Eigentümer und Betreiber, US-Technologie als lizenzierter Lieferant ohne Datenzugang. Operativer Ausschluss von US-Zugriff, strukturelle Technologieabhängigkeit bleibt.

Deutschland: Delos Cloud GmbH (SAP × Microsoft Azure) — BSI Cloud Platform Requirements, VS-NfD-fähig, deutsches Personal, BSI prüft alle Updates. Betrieb durch Arvato Systems. Preis: +15% auf

Microsoft-Listenpreise.

Frankreich: S3NS PREMI3NS (Thales × Google Cloud) — SecNumCloud 3.2, Quarantänezone für alle Google-Updates, ANSSI-validierte CLOUD-Act-Immunität. Referenzkunden: EDF, MGEN, Club Med.

Geeignet für: Organisationen, die nicht aus Microsoft 365 / SAP migrieren können; Kliniken mit tiefer M365-Integration; Verwaltungen; regulierte Industrien, die Azure-Service-Breite benötigen — aber keine direkten US-Hyperscaler-Verträge mehr wollen.

Nicht geeignet für: Workloads, die vollständige Unabhängigkeit vom US-Technologiestack erfordern (Verteidigung, nachrichtendienstliche Infrastruktur, höchste Geheimschutzklassen).

Stufe 3 — Hyperscaler Sovereign Region US-Eigentümer und US-Technologie, aber physisch und logisch getrennte EU-Infrastruktur mit EU-Personal und Residency-Garantien. Kein echter CLOUD-Act-Schutz — der Anbieter bleibt US-Rechtsperson.

Anbieter: AWS European Sovereign Cloud (Brandenburg), Azure EU Data Boundary, Google Workspace DE

Geeignet für: Workloads ohne personenbezogene Gesundheitsdaten, globale Entwicklungsumgebungen, öffentliche Webpräsenzen, unkritische Collaboration-Tools.

Nicht geeignet für: Gesundheitsdaten, KRITIS-Infrastruktur, regulierte Daten nach § 393 SGB V.

Stufe 4 — Standard US-Hyperscaler (Souveränitätswashing) US-Eigentümer, US-Technologie, EU-Serverstandort als Marketing-Argument. C5-Testat vorhanden, CLOUD-Act-Risiko direkt und strukturell.

Anbieter: AWS Frankfurt, Azure Deutschland, Google Cloud DE (Standard-Angebote ohne Sovereign-Zusatz)

Geeignet für: Keine personenbezogenen Gesundheitsdaten, keine regulierten Daten, keine KRITIS-Systeme.

17.3 Entscheidungsmatrix — Workload-Zuordnung

Workload	Schutzklasse	Empfohlene Stufe	Konkrete Anbieter / Software
ePA-Kerndaten, Diagnosen, Medikation	KRITIS / § 393 Klasse 1	**Stufe 1**	plusserver, EWERK Leipzig
GKV-Kernabrechnungssysteme	KRITIS / § 393 Klasse 1	**Stufe 1**	plusserver, STACKIT
Klinik-KIS, psychiatr. Daten	KRITIS / § 393 Klasse 1	**Stufe 1–2**	plusserver oder Delos Cloud
E-Mail (intern, mit Patientenbezug)	§ 393 Klasse 1–2	**Stufe 1**	Open-Xchange + Thunderbird auf plusserver/STACKIT
E-Mail (allgemein, kein Patientenbezug)	Klasse 2	**Stufe 1–2**	Open-Xchange auf EU-Cloud oder Delos
Office-Suite, Dokumente	§ 393 Klasse 2	**Stufe 1**	Euro-Office / Nextcloud Hub / Office.eu
SharePoint / Dokumentenmanagement	§ 393 Klasse 1–2	**Stufe 1**	Nextcloud, OpenCloud, GoFAST auf plusserver/STACKIT
Microsoft 365 (tief integriert, nicht migrierbar)	§ 393 Klasse 2	**Stufe 2**	Delos Cloud (Azure-Basis, BSI CPR, +15%)
Videokonferenz intern	Klasse 2	**Stufe 1**	Jitsi / OpenTalk auf EU-Cloud
Identity / Active Directory	Klasse 1	**Stufe 1**	Keycloak / Univention Corporate Server
KI-Diagnostik (LLM-Inferenz auf Patientendaten)	§ 393 Klasse 1	**Stufe 1**	vLLM + Mistral on-premise / STACKIT
Analytics / BI auf GKV-Daten	§ 393 Klasse 2	**Stufe 1–2**	Metabase/Superset auf STACKIT, OVHcloud SNC
Telemedizin-Plattform	§ 393 Klasse 2	**Stufe 1–2**	STACKIT, plusserver
Dev/Test-Umgebungen	Klasse 3	**Stufe 3–4**	Hetzner, IONOS
Öffentliche Webpräsenz	Klasse 3	**Stufe 4**	Beliebig

Drei-Zonen-Migrationsstrategie für GKVen und Kliniken:

Zone 1 — Jetzt umsetzbar (0–12 Monate): E-Mail (Open-Xchange), Dateiablage (Nextcloud), Videokonferenz (Jitsi/OpenTalk), Identity (Keycloak). Diese Dienste sind heute produktionsreif, tragen die höchsten CLOUD-Act-Risiken durch Kommunikationsdaten und sind technisch am einfachsten zu migrieren.

Zone 2 — Mittelfristig (1–3 Jahre): Office-Suite vollständig (Euro-Office/Nextcloud Workspace), Analytics auf Sozialdaten (EU-Cloud + Metabase/Superset), KI-Dienste (lokal/STACKIT + Mistral), CI/CD-Migration (GitLab).

Zone 3 — Komplex, langfristig (3–5 Jahre): Tief integrierte Fachverfahren (KIS-Systeme, GKV-Primärsoftware), Windows-Desktop-Ablösung (→ Linux, wie Schleswig-Holstein), SAP-Konsolidierung. Hier ist das Operator-Modell (Delos Cloud) der realistische Übergangspfad bis zur vollständigen Migration.

17.4 Datentransfer-Folgenabschätzung (TIA) — Pflichtinstrument für bestehende US-Provider

Wer heute Azure, AWS oder andere US-kontrollierte Dienste für Gesundheitsdaten nutzt, muss rechtlich handeln — nicht erst beim nächsten Vertrag, sondern jetzt. Das Instrument dafür heißt Transfer Impact Assessment, kurz TIA — auf Deutsch: Datentransfer-Folgenabschätzung.

Was ist ein TIA und warum ist er Pflicht?

Das EuGH-Urteil Schrems II (2020) hat festgestellt: Standardvertragsklauseln (SCCs — das sind Musterverträge, die die EU-Kommission für Datenübermittlungen in unsichere Drittländer bereitstellt) reichen allein nicht mehr aus. Der Grund: Sie garantieren zwar vertraglich Datenschutz, schützen aber nicht davor, dass US-Behörden die Daten auf anderem Weg anfordern können. Deshalb verlangt das Gericht seither zusätzlich eine individuelle Prüfung: Schützen die vertraglichen Garantien die Daten im konkreten Fall tatsächlich — angesichts der Rechtslage im Empfängerland? Diese Prüfung ist das TIA. Sie ergibt sich aus Klausel 14 der aktuellen SCCs (in Kraft seit 2022) und der DSGVO-Rechenschaftspflicht (Art. 5 Abs. 2 DSGVO). EU-Aufsichtsbehörden haben 2023–2024 über 127 Abhilfemaßnahmen wegen unzureichender TIAs verhängt; das BfDI (Bundesbeauftragter für den Datenschutz und die Informationsfreiheit) hat technische Kontrollen als stärkstes Nachweismittel eingestuft.

Was prüft ein TIA konkret?

Ein TIA für US-Cloud-Dienste im Gesundheitsbereich durchläuft vier Schritte:

Erstens die Bestandsaufnahme: Welche Daten fließen genau wohin? Dabei sind Kategorie (Diagnosen, Medikation, Versichertendaten), Menge, Format (verschlüsselt oder im Klartext) und Übertragungskanal zu dokumentieren. Gesundheitsdaten nach Art. 9 DSGVO erfordern eine besondere Begründung.

Zweitens die Rechtslageprüfung im Empfängerland: Gibt es Gesetze, die den US-Anbieter zur Herausgabe an Behörden verpflichten, obwohl die Daten in der EU liegen? Für US-Anbieter lautet die Antwort strukturell: Ja — CLOUD Act, FISA § 702, NSL. Diese Gesetze müssen im TIA namentlich analysiert werden.

Drittens die Risikoabwägung: Sind zusätzliche Schutzmaßnahmen (Verschlüsselung mit eigenem Schlüssel, Pseudonymisierung, technische Zugangssperren) geeignet, das Restrisiko auf ein akzeptables Maß zu senken? Für personenbezogene Gesundheitsdaten im Klartext auf US-Infrastruktur: in der Regel nein — der EuGH hat in Schrems II explizit klargestellt, dass FISA § 702 kein angemessenes Schutzniveau bietet.

Viertens die Dokumentation und Schlussfolgerung: Das TIA ist schriftlich zu dokumentieren, mit Datum und Unterschrift des Datenschutzbeauftragten, und bei Veränderungen der Rechtslage zu aktualisieren. Wenn das Ergebnis ist, dass kein angemessenes Schutzniveau erreichbar ist, darf der Transfer nicht stattfinden — oder er muss auf Basis einer anderen DSGVO-Ausnahme rechtlich begründet werden.

Was bedeutet das für Gesundheitsinstitutionen konkret?

Eine GKV, die Microsoft 365 mit Exchange Online für interne Kommunikation nutzt, bei der Patientenbezüge in E-Mails vorkommen, muss ein TIA für diese Datenübermittlung erstellt und dokumentiert haben. Liegt kein TIA vor, ist die Verarbeitung formell rechtswidrig — auch wenn § 393 SGB V und C5 eingehalten werden. Das TIA

ist nicht die Lösung des CLOUD-Act-Problems, sondern der dokumentarische Nachweis, dass die Organisation das Problem kennt, bewertet hat und Maßnahmen ergreift. Als Überbrückungsmaßnahme bis zur vollständigen Migration zur EU-Infrastruktur (Kap. 8, 15.2) ist es das Mindestdokument, das jede Aufsichtsbehörde erwarten wird.

17.5 Vertragliche Absicherung — AVV-Erweiterungen

Unabhängig von der gewählten Stufe: AVV-Erweiterungen (AVV = Auftragsverarbeitungsvertrag, der Standardvertrag zwischen einer Organisation und ihrem Cloud-Anbieter nach Art. 28 DSGVO) für CLOUD-Act-Schutz aufnehmen:

- **Informationspflicht:** Verarbeiter muss unverzüglich informieren, wenn eine CLOUD-Act- oder vergleichbare Anfrage eingeht
- **Ablehnungspflicht:** Explizite Pflicht, DSGVO-widrigen Herausgabeanordnungen zu widersprechen, solange kein Art.-48-DSGVO-konformes Rechtshilfeabkommen besteht
- **Haftungsklausel:** Verarbeiter haftet für Schäden aus nicht gemeldeten Herausgaben
- **Audit-Recht:** Regelmäßiges Recht auf Kontrolle der tatsächlichen Datenflüsse und Zugriffsprotokoll-Einsicht
- **Technologieänderungs-Klausel** (für Operator-Modell): Delos/S3NS müssen Veränderungen im Verhältnis zum US-Technologielieferanten melden, die die Souveränitätsarchitektur berühren
- **Change-of-Control-Klausel:** Bei Eigentümerwechsel des Anbieters (z.B. Übernahme durch US-Unternehmen) ist der Vertrag neu zu prüfen und ggf. zu kündigen — besonders relevant für PE-geführte Anbieter wie EWERK

17.6 Exit-Strategie und Cloud-Portabilität — der unterschätzte Engpass

Das häufigste Missverständnis in der Souveränitätsdebatte: Organisationen glauben, sie können Azure oder AWS jederzeit verlassen, wenn es nötig wird. In der Praxis ist ein Anbieterwechsel ohne Vorbereitung ein Mehrjahresprojekt mit erheblichen versteckten Kosten. Diesen Effekt nennt man Anbieterabhängigkeit (englisch: Vendor Lock-in) — die wachsende Schwierigkeit, einen einmal gewählten Cloud-Anbieter zu verlassen.

Warum ist der Ausstieg so schwer?

Drei Mechanismen binden Organisationen an ihren Cloud-Anbieter:

Technischer Lock-in entsteht durch proprietäre Dienste — das sind Funktionen, die ein Anbieter exklusiv anbietet und die kein direktes Äquivalent beim Wettbewerber haben. AWS Lambda (Programmierumgebung ohne eigene Server), Azure Active Directory (Nutzerverwaltung und Zugriffssteuerung), Microsoft 365-Datenformate für E-Mails und Kalender — all das lässt sich nicht mit einem Knopfdruck exportieren und anderswo weiterbetreiben. Je tiefer eine Organisation in anbieter-eigene Funktionen investiert hat, desto teurer und zeitaufwändiger wird der Wechsel.

Kommerzieller Lock-in kommt durch Rabattverträge: Cloud-Anbieter bieten erhebliche Preisnachlässe für mehrjährige Abnahmeverpflichtungen (sogenannte Reserved Instances oder Enterprise Agreements). Wer solche Verträge abgeschlossen hat, zahlt für einen vorzeitigen Ausstieg doppelt — einmal für die Migration und einmal für die nicht genutzten, bereits bezahlten Kapazitäten.

Betrieblicher Lock-in ist der subtilste: Wenn ein IT-Team jahrelang ausschließlich mit Azure-Tools gearbeitet hat, ist ein Wechsel zu STACKIT oder plusserver nicht nur eine technische, sondern auch eine Qualifikationsfrage. Schulung und Umgewöhnung kosten Zeit.

Was der EU Data Act ab September 2025 ändert

Der EU Data Act (in Kraft seit Januar 2024, Cloud-Bestimmungen vollständig anwendbar seit September 2025) verpflichtet Cloud-Anbieter erstmals rechtlich zu Portabilität: Kunden haben das Recht auf Datenexport in offenen, maschinenlesbaren Formaten, und Anbieter müssen den Wechsel technisch erleichtern. Ab 2027 entfallen auch Datenausgangsgebühren (sogenannte Egress-Kosten — Gebühren, die Anbieter bisher für den Datenabzug erhoben haben) vollständig. OVHcloud hat diese Gebühren bereits seit Dezember 2025

abgeschafft. Der EU Data Act senkt die Wechselkosten, ersetzt aber keine strategische Exit-Planung.

Wie eine Exit-Strategie aussieht

Eine Exit-Strategie ist keine Drohung gegenüber dem Anbieter, sondern die strukturierte Vorbereitung auf den Fall, dass ein Wechsel nötig wird — durch regulatorischen Zwang (Schrems III), politische Eskalation oder eine Übernahme des Anbieters durch ein US-Unternehmen. Sie umfasst:

Inventur: Welche Systeme laufen wo, mit welchen anbieter-spezifischen Funktionen? Wer einen Überblick hat, kann priorisieren — und findet meist, dass die Abhängigkeit an wenigen kritischen Diensten hängt, nicht gleichmäßig verteilt ist.

Datenexporttests: Können alle Daten vollständig und in offenen Formaten exportiert werden? Das sollte regelmäßig geprüft werden — nicht erst im Notfall. Besonders problematisch: E-Mail-Archive in Exchange-Formaten, SharePoint-Dokumentenbibliotheken und Azure-Active-Directory-Nutzerdaten.

Architektur für Portabilität: Workloads, die in Containern (standardisierte Software-Pakete, die auf jeder kompatiblen Infrastruktur laufen) auf Kubernetes (dem gängigen Standard zur Verwaltung von Containern) betrieben werden, lassen sich deutlich leichter migrieren als solche, die tief in anbieter-eigene Dienste integriert sind. Wer heute neu aufbaut, sollte offene Standards konsequent bevorzugen.

Migrationspfad für kritische Workloads: Die realistischen Kosten einer Migration — Personentage, Schulung, Ausfallzeiten, Vertragsrestlaufzeiten — sollten geschätzt und dokumentiert sein, damit die Entscheidung im Bedarfsfall schnell getroffen werden kann.

Für GKVen und Kliniken gilt: Ein Anbieterwechsel für Kernsysteme dauert 6 bis 18 Monate. Wer 2026 nicht beginnt zu planen, handelt 2028 unter Druck. Die Drei-Zonen-Strategie in §17.3 ist die praktische Umsetzung dieser Reihenfolge.

17.7 Verschlüsselung — wo HYOK hilft und wo nicht

Clientseitige Verschlüsselung mit eigener Schlüsselhoheit (HYOK — Hold Your Own Key) schützt strukturell vor CLOUD-Act-Zugriff, aber nur bei ruhenden Daten: Archivdaten, Backups, Objektspeicher, File-Storage. Für Daten, die der Anbieter verarbeiten muss — Microsoft 365, E-Mail-Spam-Filter, KI-Inferenz, SaaS-Anwendungen, Real-time-Analytics — funktioniert HYOK nicht, weil das System Klartextzugang benötigt. BYOK (Bring Your Own Key) bietet nur schwachen Schutz, weil der Anbieter die Schlüssel in seinem eigenen Key Management System verwaltet und technisch Zugriff hat. Die vollständige Analyse der drei Verschlüsselungsmodelle und die Gesundheitssektor-Matrix: → Kapitel 13.

17.8 Reise-Hygiene bei US-Einreisen

Betrifft Mitarbeitende mit Zugang zu sensiblen Gesundheitssystemen:

- Reisegerät ohne lokale Mail-Caches, VPN-Zugangsdaten und Gesundheitsdaten nutzen
- Apps vor Einreise ausloggen — CBP (US Customs and Border Protection) darf physische Geräte ohne richterlichen Herausgabebeschluss durchsuchen (vgl. §3.4)
- Keine KRITIS-relevanten Zugangsdaten, SSH-Schlüssel oder API-Tokens auf Reisegeräten
- Für hochsensible Positionen: dediziertes Reisegerät mit frischer Installation

17.9 Haftungskette: Wer haftet, wenn der Patient klagt?

Die bisherigen Kapitel haben das CLOUD-Act-Risiko als regulatorisches und technisches Problem beschrieben. Dieser Abschnitt zeigt die zivilrechtliche Konsequenz — in zwei Szenarien, die sich fundamental unterscheiden.

Szenario 1 — Latentes Risiko: Kein konkreter Zugriff, aber CLOUD-Act-exponierter Anbieter

Ein Patient erfährt, dass seine Krankenkasse oder sein Krankenhaus Gesundheitsdaten bei einem US-Hyperscaler verarbeitet. Er klagt auf Schadensersatz nach Art. 82 DSGVO. In diesem Szenario muss kein tatsächlicher US-Zugriff stattgefunden haben. Die EuGH-Rechtsprechung entwickelt sich in die Richtung, dass bereits der Kontrollverlust über die eigenen Daten einen immateriellen Schaden begründen kann — also die

Tatsache, dass die Daten bei einem Anbieter liegen, der einer US-Herausgabepflicht unterliegt, und die verantwortliche Institution das wusste oder hätte wissen müssen. Bei einem US-Hyperscaler mit öffentlicher NYSE-Notierung ist das schwer zu bestreiten. Die Schadensersatzsummen in diesem Szenario sind individuell gering — einige hundert bis wenige tausend Euro pro Person. Das ändert sich bei Sammelklagen: Eine GKV mit fünf Millionen Versicherten, deren Abrechnungsdaten auf US-Infrastruktur laufen, ist ein strukturelles Ziel für Musterfeststellungsklagen oder Beschwerden durch Datenschutz-NGOs wie noyb.

Szenario 2 — Konkreter Zugriff: US-Behörden haben auf Gesundheitsdaten zugegriffen und der Vorfall ist gemeldet

Dieses Szenario ist der harte Fall. Er wird greifbar, wenn man ihn an den dokumentierten Beispielen durchspielt.

Angenommen, eine der sanktionierten HateAid-Geschäftsführerinnen ist bei einer GKV versichert, die ihre Abrechnungsdaten auf Azure verarbeitet. Ab dem Zeitpunkt der Sanktionierung ist Microsoft verpflichtet, alle Daten zu dieser Person einzufrieren und auf Anfrage herauszugeben — Diagnosen, Medikation, Behandlungsverläufe, Arzt-Patienten-Kontakte. Oder eine FISA-§-702-Abfrage erfasst im Rahmen eines pauschalen Überwachungsprogramms die Daten von tausenden GKV-Versicherten bei einem US-Anbieter. Oder ein CLOUD-Act-Herausgabebeschluss in einer Strafermittlung gegen einen einzelnen Arzt zieht die Abrechnungsdaten seiner gesamten Patientenschaft mit.

Irgendwann wird der Zugriff bekannt — durch Aufhebung einer Schweigeverpflichtung, durch einen Whistleblower, durch ein US-Gerichtsverfahren, das öffentlich wird, oder durch eine Transparenzpflicht des Anbieters. Bei den ICC-Richtern war der Zugriff sofort sichtbar: Microsoft, Amazon und Gmail sperrten die Accounts. Bei den HateAid-Geschäftsführerinnen wird geprüft, ob Zahlungsdienstleister und Cloud-Konten betroffen sind. Die Gesundheitsinstitution meldet den Vorfall nach Art. 33 DSGVO an die zuständige Aufsichtsbehörde. Ab diesem Moment läuft eine Kaskade:

Stufe 1 — Bußgeld durch die Aufsichtsbehörde. Die Aufsichtsbehörde prüft nach Art. 58 DSGVO. Sie fragt: Lag ein TIA vor? Hat die Institution das CLOUD-Act-Risiko dokumentiert? Wurden EU-souveräne Alternativen evaluiert? Wenn nichts davon vorliegt — und das ist bei der Mehrheit der Gesundheitsinstitutionen der Fall —, ist die Verletzung der Rechenschaftspflicht nach Art. 5 Abs. 2 DSGVO offensichtlich. Das Bußgeld nach Art. 83 DSGVO kann bis zu 20 Millionen Euro oder 4 Prozent des Jahresumsatzes betragen. Bei einer großen GKV oder einem Universitätsklinikum sind das relevante Summen.

Stufe 2 — Schadensersatz pro betroffenem Patienten. Parallel können betroffene Patienten nach Art. 82 DSGVO Schadensersatz fordern — und in diesem Szenario geht es nicht mehr um abstrakten Kontrollverlust, sondern um einen dokumentierten Zugriff auf konkrete Gesundheitsdaten. Diagnosen, Medikationspläne, psychiatrische Befunde, HIV-Status, Suchterkrankungen — Daten, deren Offenlegung gegenüber einer ausländischen Behörde ohne Rechtsgrundlage einen massiven Eingriff in die Persönlichkeitsrechte darstellt.

Die Schadensersatzsummen pro Person liegen bei dokumentiertem Zugriff auf sensible Gesundheitsdaten nach bisheriger europäischer Rechtsprechung im Bereich von mehreren tausend bis fünfstelligen Euro-Beträgen — abhängig von der Sensitivität der betroffenen Daten und den Umständen der Offenlegung. Ein konkretes Rechenbeispiel: Bei einer FISA-§-702-Abfrage, die 100.000 Versichertendatensätze einer GKV erfasst hat, und einem durchschnittlichen Schadensersatz von 5.000 Euro pro Person ergibt sich eine Gesamtforderung von 500 Millionen Euro. Selbst bei konservativen 1.000 Euro pro Person wären es 100 Millionen Euro. Das sind keine theoretischen Zahlen — das ist die Arithmetik, die ein Gericht anwenden wird, multipliziert mit der Zahl der Betroffenen.

Stufe 3 — Sammelklagen und NGO-Beschwerden. Einzelne Patienten werden selten klagen. Aber Verbraucherschutzorganisationen, Datenschutz-NGOs wie noyb oder Anwaltskanzleien, die sich auf DSGVO-Sammelklagen spezialisiert haben, suchen gezielt nach genau solchen Fällen. Eine GKV mit Millionen Versicherten, bei der ein dokumentierter US-Behördenzugriff auf Gesundheitsdaten stattgefunden hat, ist der perfekte Musterfeststellungsklage-Fall. Die Haftungssummen werden dann nicht mehr individuell, sondern existenziell.

Die doppelte Haftung — Verantwortlicher und Auftragsverarbeiter. Die Klinik, Krankenkasse oder Kassenärztliche Vereinigung ist als Verantwortlicher nach Art. 4 Nr. 7 DSGVO haftbar. Sie bestimmt Zweck und

Mittel der Verarbeitung und hat nach Art. 28 Abs. 1 DSGVO die Pflicht, nur Auftragsverarbeiter einzusetzen, die hinreichende Garantien bieten. Wenn sie wissentlich einen Anbieter unter US-Jurisdiktion gewählt hat und die CLOUD-Act-Exposition nicht dokumentiert und bewertet hat, haftet sie für diese Entscheidung.

Der Cloud-Anbieter haftet als Auftragsverarbeiter nach Art. 82 Abs. 2 DSGVO direkt gegenüber Betroffenen, wenn er einer CLOUD-Act-Anordnung nachgekommen ist, ohne den Verantwortlichen zu informieren und ohne alle verfügbaren Rechtsmittel auszuschöpfen. In der Praxis wendet sich die Aufsichtsbehörde aber zuerst an den Verantwortlichen — an die GKV oder die Klinik. Liegt kein TIA vor (vgl. §17.4), ist die Haftungsfrage schnell beantwortet.

Die persönliche Geschäftsführerhaftung — drei Wege, sauber getrennt.

Die DSGVO selbst kennt keine explizite persönliche GF-Haftung. Bußgelder nach Art. 83 DSGVO treffen die Organisation — die GKV, die Klinik, die KV. Nicht den Geschäftsführer als Person. Aber die persönliche Haftung kommt über zwei andere Wege:

Der erste Weg ist die gesellschaftsrechtliche Organhaftung nach § 43 GmbHG beziehungsweise § 93 AktG. Wenn ein Geschäftsführer eine Entscheidung trifft, die vorhersehbar zu einem DSGVO-Bußgeld oder zu Schadensersatzansprüchen führt — etwa die bewusste Wahl eines CLOUD-Act-exponierten Anbieters ohne dokumentierte Risikoabwägung und ohne Prüfung europäischer Alternativen —, kann die Organisation ihren Geschäftsführer in Regress nehmen. Ein Bußgeld von 20 Millionen Euro oder Schadensersatzforderungen von hunderttausenden Patienten sind ein bezifferbarer Schaden, der auf eine konkrete Leitungsentscheidung zurückgeführt werden kann. Voraussetzung: Die Entscheidung beruhte nicht auf einer sorgfältigen, dokumentierten Abwägung. Liegt kein TIA vor (vgl. §17.4), fehlt genau diese Dokumentation.

Der zweite Weg ist die NIS2-Richtlinie, umgesetzt durch die BSIG-Novelle. NIS2 regelt Cybersicherheit, nicht Datenschutz — die Haftung nach § 38 BSIG greift bei Verletzung von Cybersicherheitspflichten. Ein US-Behördenzugriff per CLOUD Act ist kein Cyberangriff im klassischen Sinne. Aber NIS2 verlangt in Art. 21 Abs. 2 lit. d ausdrücklich die Bewertung von Sicherheitsrisiken in der Lieferkette — und ein CLOUD-Act-exponierter Cloud-Anbieter ist ein Lieferkettenrisiko. Wer als GKV oder Klinik unter NIS2 fällt und seine Cloud-Lieferkette nicht auf Jurisdiktionsrisiken geprüft hat, verletzt die NIS2-Sorgfaltspflicht. Für diese Verletzung haften Geschäftsführer nach § 38 BSIG persönlich — unabhängig davon, ob jemals ein US-Zugriff stattfindet.

In der Praxis verstärken sich beide Wege: Die fehlende DSGVO-Dokumentation (kein TIA) ist gleichzeitig der Nachweis einer fehlenden NIS2-Lieferkettenprüfung. Ein einziges fehlendes Dokument öffnet zwei Haftungspfade.

Die Dokumentationsfalle. Dieses Dokument — und zahlreiche vergleichbare Analysen, Aufsichtsbehörden-Beschlüsse und EuGH-Urteile — sind öffentlich zugänglich. Für eine Gesundheitsinstitution wird es zunehmend schwer zu argumentieren, sie habe von dem Risiko nichts gewusst. Das Wissen ist verfügbar. Die Frage vor Gericht wird sein: Hat die Leitung es zur Kenntnis genommen und darauf reagiert — oder hat sie es ignoriert?

17.10 Grundprinzip: Rechtsstaatlicher Zugriff als Maßstab — nicht politisches Vertrauen

Aus der Analyse in Kapitel 4 ergibt sich ein handlungsleitendes Prinzip für Infrastrukturentscheidungen:

Das richtige Kriterium ist nicht "Verbündeter oder nicht-Verbündeter" — es ist "rechtsstaatlich gebunden oder nicht."

Vier Leitfragen für jede Infrastrukturentscheidung im Gesundheitsbereich:

1. **Unabhängige richterliche Kontrolle für alle Betroffenen?** Gilt nicht nur für eigene Staatsbürger, sondern auch für EU-Bürger? Wenn nein: strukturell inakzeptabel für Art.-9-Daten.

2. **Anlassbezogen oder anlasslos?** FISA § 702 und NSL erlauben Massenerfassung ohne Einzelfallverdacht. Kein System, das das ermöglicht, ist eine akzeptable Grundlage für Gesundheitsdaten von 74 Millionen

GKV-Versicherten.

3. **Politisch instrumentalisierbar?** Der ICC-Präzedenzfall (2025): Cloud-Dienste wurden als Druckmittel in einer politischen Auseinandersetzung eingesetzt. Infrastruktur, die von der politischen Konstellation eines einzelnen Verbündeten abhängt, ist strategisch vulnerabel — unabhängig davon, wie eng die Allianz heute ist.

4. **Stabiles Recht oder Präsidialerlass?** EU-Recht und GRCh überdauern Regierungswechsel. Das Data Privacy Framework hängt an einem Präsidialerlass und kann durch eine gegenteilige Executive Order aufgehoben werden.

Für europäischen Behördenzugriff (e-Evidence-VO): Akzeptabel — rechtsstaatlich gebunden, verhältnismäßig, für alle Betroffenen anfechtbar.

Für US-Behördenzugriff (FISA § 702, NSL): Für Gesundheitsdaten strukturell nicht akzeptabel — nicht weil die USA ein Feind sind, sondern weil diese Instrumente den Anforderungen an Grundrechtsschutz für EU-Bürger nicht genügen.

Für den "westlichen Verbund"-Gedanken (NATO/Five Eyes): Militärische und geheimdienstliche Kooperation legitimiert keinen anlasslosen Zugriff auf Krankenakten. Der Kategorieunterschied zwischen SIGINT (Fernmeldeaufklärung)-Kooperation und Gesundheitsdaten ist nicht akademisch — er ist die Grundlage jeder verhältnismäßigen Abwägung.

18. Regulatorischer Ausblick 2025–2027

Dieses Kapitel behandelt regulatorische Entwicklungen, die bis 2027 neue CLOUD-Act-Relevanz entfalten. Bereits abgeschlossene oder im Dokument ausführlich analysierte Regelwerke werden hier nicht wiederholt, sondern querverwiesen: CLOUD Act und FISA § 702 (→ Kap. 3), e-Evidence-VO (→ Kap. 4), Data Privacy Framework und Executive Agreement (→ Kap. 9), Digital Omnibus und Lobbyarbeit (→ Kap. 10), EU Data Act und Cloud-Portabilität (→ §17.6).

Die folgende Tabelle gibt den Überblick über laufende und kommende Entwicklungen mit unmittelbarer Relevanz für die CLOUD-Act-Exposition des Gesundheitswesens. Die drei wichtigsten werden im Anschluss vertieft: TI 2.0, GeDIG und EHDS.

Instrument / Entwicklung	Status	CLOUD-Act-Relevanz
TI 2.0 (Telematikinfrastruktur)	Migration ab 2025, Vollbetrieb 2027	Cloud-basierte TI-Gateways ersetzen Hardware-Konnektoren. Offene Frage: US-Konzerne als Gateway-Betreiber? (→ §18.1)
GeDIG	Referentenentwurf April 2026	ePA-Ausbau auf 20 Mio. Nutzer, automatische FDZ-Ausleitung Ende 2026. Vergrößert CLOUD-Act-Angriffsfläche erheblich. (→ §18.2)
EHDS (European Health Data Space)	Ab 2026 schrittweise	Sekundärnutzung erhöht Datenpool-Attraktivität. Keine Cloud-Infrastrukturvorgaben — CLOUD-Act-Lücke. (→ §18.3)
Schrems III (EuGH)	Anhängig	Kippt das DPF, ändert sich das Enforcement-Bild schlagartig — sofortiger Handlungsdruck für alle US-Cloud-Nutzer. (Analyse: → §9.1)
FISA § 702 Verlängerung	Auslaufdatum 20. April 2026	Verlängerung ohne Reformen zementiert RISAA-Erweiterungen. Ablauf würde US-Zugriff temporär einschränken. (Analyse: → §3.2)
NIS2-Richtlinie	In deutsches Recht umgesetzt (BSIG-Novelle)	Lieferketten-Risikobewertung ist Pflicht (Art. 21 Abs. 2 lit. d) — erfasst CLOUD-Act-exponierte Anbieter. GF-Haftung nach § 38 BSIG bei Verletzung der Sorgfaltspflicht.
SharePoint On-Premise End-of-Life	Juli 2026	SharePoint 2013/2016/2019 verliert Support. Erzwingt Entscheidung: SharePoint Online (US-Cloud) oder souveräne Alternative (→ §8.3).
STACKIT Lübbenau-RZ	Fertigstellung 2027	11 Mrd. EUR, bis zu 100.000 GPUs. Erster EU-Anbieter mit Hyperscaler-Kapazität. (Analyse: → §5.5, §7.2)
Euro-Office / Office.eu	Rollout ab März–Q2 2026	Erste produktionsreife souveräne M365-Alternative. (Analyse: → §8.3)
BSI C5:2026	Veröffentlicht 7. April 2026	168 Kriterien (Nachfolger C5:2020). Technische Sicherheit modernisiert (Container, PQC, Confidential Computing). Souveränität weiterhin nicht geprüft — separate Kriterien angekündigt. (Analyse: → §5.3)

Instrument / Entwicklung	Status	CLOUD-Act-Relevanz
ANSSI-BSI Souveränitätskriterien	Joint Statement 17. Nov. 2025	ANSSI und BSI entwickeln gemeinsam Souveränitätskriterien auf Basis des EU Cloud Sovereignty Framework. Drei-Stufen-Progressionsmodell. Veröffentlichung "in Kürze". (Analyse: → §5.3)
EuroHPC AI Factories	19 Standorte, laufend seit 2025	Souveräne GPU-Infrastruktur für KI-Training. Zugang für Gesundheitsorganisationen.

18.1 Telematikinfrastruktur (TI 2.0) — was sich durch die Migration ändert

Die CLOUD-Act-Exposition der heutigen TI ist in §12.8 dokumentiert: IBM betreibt zwei Kerndienste (Rezeptserver, Identity Provider), Arvato Systems trägt die Sicherheitsinfrastruktur mit US-Technologieabhängigkeit. An dieser Bestandsaufnahme ändert sich kurzfristig nichts. Was sich ändert, ist die Architektur selbst.

Der Übergang von TI 1.0 zu TI 2.0: Die bisherige TI setzte auf physische Konnektoren in jeder Praxis — teuer und wartungsintensiv, aber vollständig in Deutschland kontrolliert. TI 2.0 ersetzt diese Hardware durch cloud-basierte TI-Gateways: Praxen und Kliniken mieten TI-Zugang als Managed Service von zertifizierten Dienstleistern. Das macht die TI flexibler und günstiger — öffnet sie aber für die CLOUD-Act-Problematik, weil die Gateway-Betreiber US-kontrollierte Anbieter sein könnten.

Die offene Frage: Wer die TI-Gateway-Betreiber sein werden und ob darunter US-Konzerne zugelassen werden, ist regulatorisch nicht abschließend definiert. Hier entsteht ein strukturell neues CLOUD-Act-Einfallstor — zusätzlich zu den bestehenden IBM- und Arvato-Abhängigkeiten.

Was Organisationen konkret tun können: Die TI-Abhängigkeit ist derzeit nicht auflösbar — die TI-Nutzung ist gesetzlich verpflichtend und die gematik legt die Anbieter fest. Was zählt: eigene Systeme, die über die TI kommunizieren, sollten so gebaut sein, dass Daten auf dem Transportweg und im eigenen System verschlüsselt sind. Inhalte, die nicht zwingend im Klartext übertragen werden müssen, sollten Ende-zu-Ende verschlüsselt werden. Für die Architekturentscheidung eigener Gesundheits-IT-Systeme bleibt die TI ein Systembestandteil mit Restrisiko, das transparent dokumentiert werden sollte — auch im TIA (vgl. §17.4).

18.2 GeDIG 2026 — wie das neue Digitalgesetz die CLOUD-Act-Exposition erhöht

Das Gesetz für Daten und digitale Innovation im Gesundheitswesen (GeDIG) ist das Nachfolgeprojekt des DigiG und GDNG. Bundesgesundheitsministerin Nina Warken (CDU) hat den Referentenentwurf im ersten Quartal 2026 vorgelegt. Das Gesetz hat erhebliche Konsequenzen für die CLOUD-Act-Exposition des deutschen Gesundheitswesens — obwohl der Begriff im Gesetzentwurf nicht vorkommt.

Was GeDIG im Kern vorhat

Die ePA (elektronische Patientenakte) soll vom passiven Datenspeicher zum aktiven Navigationssystem für das Gesundheitssystem werden. Bis 2030 sollen rund 20 Millionen Versicherte (aktuell: ca. 4 Millionen) die ePA aktiv nutzen. Neue Funktionen: digitale Ersteinschätzung, automatische Terminvermittlung, E-Überweisungen, digitaler Medikationsprozess (ab Oktober 2026), Volltextsuche über alle ePA-Inhalte (Ende 2026). Die ePA wird damit zur zentralen Schaltstelle für Versorgungsdaten eines erheblichen Teils der deutschen Bevölkerung.

Was das für die CLOUD-Act-Frage bedeutet

Je mehr Versicherte die ePA nutzen und je mehr Daten in ihr gespeichert werden, desto größer ist die potenzielle CLOUD-Act-Exposition — falls die ePA-Infrastruktur bei US-kontrollierten Anbietern liegt. Die gematik hat die ePA auf einer Infrastruktur aufgebaut, die TI-zertifizierte Anbieter nutzen. Für den Vollbetrieb mit 20 Millionen aktiven Nutzern werden erhebliche Skalierungskapazitäten benötigt — genau die Kapazitäten, bei denen europäische Anbieter noch Aufholbedarf haben (vgl. Kap. 7).

Hinzu kommt der geplante FDZ-Ausbau: Ab Ende 2026 soll die automatische Ausleitung von ePA-Daten an das Forschungsdatenzentrum Gesundheit beim BfArM starten (aktuelle CLOUD-Act-Bewertung des FDZ: §12.6).

Eine zentrale Plattform mit pseudonymisierten Gesundheitsdaten von Millionen Versicherten ist ein hochattraktives Ziel für CLOUD-Act-Zugriffe — auch pseudonymisierte Daten bleiben im Kontext einer großen Gesundheitsdatenbank re-identifizierbar. Die Frage, auf welcher Infrastruktur das FDZ für diese Skalierung betrieben wird, ist regulatorisch noch nicht abschließend festgelegt.

18.3 EHDS — der europäische Gesundheitsdatenraum und seine Grenzen

Der European Health Data Space (EHDS — Europäischer Gesundheitsdatenraum) ist eine EU-Verordnung, die ab 2026 schrittweise anwendbar wird. Sie schafft einen einheitlichen Rahmen für die Nutzung von Gesundheitsdaten in der EU — für die Versorgung (Primärnutzung) und für Forschung, Regulierung und Politikgestaltung (Sekundärnutzung).

Was der EHDS regelt und was nicht

Der EHDS verpflichtet Mitgliedstaaten, nationale Gesundheitsdatenzugangsstellen einzurichten, die Forschern und Behörden unter definierten Bedingungen Zugang zu anonymisierten Gesundheitsdaten geben. Er schafft EU-weit einheitliche Formate (z.B. für die Patientenzusammenfassung und das E-Rezept) und ermöglicht grenzüberschreitende Versorgung — ein Patient kann seine ePA-Daten künftig auch bei einem Arzt in Frankreich nutzen.

Was der EHDS nicht regelt: die CLOUD-Act-Frage. Der EHDS schreibt keine spezifischen Anforderungen an die Cloud-Infrastruktur vor, auf der Gesundheitsdaten verarbeitet werden. Eine nationale Gesundheitsdatenzugangsstelle könnte theoretisch bei einem US-Hyperscaler betrieben werden — und damit dem CLOUD Act unterliegen. Der EHDS ist ein Daten-Governance-Rahmen, kein Infrastruktur-Souveränitätsgesetz.

Für GKVen und Kliniken relevant: Der EHDS-Pflichten zur Sekundärnutzung — also die Möglichkeit, dass Forscher und Behörden Daten anfragen können — erhöhen den Wert und damit die Attraktivität der Datenpools. Umso wichtiger wird die Frage, auf welcher Infrastruktur diese Daten liegen und wer außer autorisierten europäischen Nutzern potenziell darauf zugreifen kann.

Fazit

> ***"Die Frage ist nicht mehr ob US-Behörden auf Daten in Europa zugreifen können. Die Frage ist, unter welchen Umständen sie es tun — und ob wir das als akzeptables Restrisiko bezeichnen wollen, wenn es um Diagnosen, Medikation und Krankenversicherungsdaten von 74 Millionen GKV-Versicherten geht."***

Zwölf Kernaussagen:

1. **Serverstandort schützt nicht.** Entscheidend ist, wer die Kontrolle über die Daten hat — Unternehmensstruktur, nicht Geographie.

2. **§ 393 SGB V und DSGVO Art. 48 ergänzen sich — die eine regelt IT-Sicherheit, die andere Jurisdiktion.** § 393 entbindet nicht von der DSGVO. Ein C5-konformer Anbieter unter US-Jurisdiktion erfüllt § 393, aber nicht Art. 48. Wenn US-Behörden zugreifen, ist das ein meldepflichtiger Datenschutzvorfall — unabhängig vom C5-Testat. Die Lücke liegt in der Beschaffungspraxis: C5 ist Pflicht, eine Jurisdiktionsprüfung nicht.

3. **US-Hyperscaler sind de facto akzeptiert — trotz DSGVO-Widerspruch. Und der Aufsichts-Flickenteppich macht es noch verwirrender.** Das ist die ehrlichste Zusammenfassung des Status quo. Die KVNO betreibt ihre KI-Plattform auf Azure (TED 98706-2026). Kubus IT hostet GKV-Daten über Arvato bei Google Cloud. Dutzende Kliniken laufen auf Oracle OCI. Die vollständige Positionierung aller 16 Landesbehörden + BfDI + BAS ist in §16.2 dokumentiert — das Bild reicht von [G] (Hessen, Niedersachsen) bis [R] (Hamburg, Schleswig-Holstein). Wer bei der "richtigen" Aufsichtsbehörde sitzt, bekommt Azure toleriert. Das Enforcement-Gap ist das eigentliche strukturelle Problem.

4. **Das Operator-Modell ist der pragmatische Mittelweg** für Organisationen, die heute in Microsoft- oder Google-Ökosysteme integriert sind: Delos Cloud (SAP × Azure) für Verwaltung und Kliniken, S3NS (Thales × Google) als europäisches Referenzmodell mit SecNumCloud. Preis der Souveränität: +15% auf Listenpreise.

5. **Der vollständige EU-Plattformstack existiert und ist produktionsreif.** US-Hyperscaler ersetzen bedeutet E-Mail (Open-Xchange), Office (Euro-Office/Nextcloud), SharePoint (Nextcloud/OpenCloud), Teams (Jitsi/OpenTalk), Active Directory (Keycloak) und KI (vLLM/Mistral) zu migrieren. Schleswig-Holstein macht das für 30.000 Mitarbeitende mit €15 Millionen jährlichen Einsparungen.

6. **Europäischer Behördenzugriff ist strukturell anders als US-Zugriff** — nicht weil Europa besser ist, sondern weil die e-Evidence-VO an Verhältnismäßigkeit, unabhängige Gerichte und Grundrechtsschutz für alle Betroffenen gebunden ist. FISA § 702 und NSL sind das nicht.

7. **Ein EU-US Executive Agreement ist juristisch möglich** — der CLOUD Act hat den Mechanismus eingebaut, das UK hat ihn 2019 genutzt. Aber: seit sieben Jahren keine EU-Einigung, weil die USA FISA § 702 und NSL nicht einschränken wollen.

8. **151 Millionen Euro** investiert Big Tech jährlich in EU-Lobbyarbeit — 19-mal mehr als die Automobilindustrie. Dieser strukturelle Vorteil prägt die Regulierungslandschaft direkt.

9. **Clientseitige Verschlüsselung (HYOK) schützt bei statischen Datenspeichern** — nicht bei KI, E-Mail, SharePoint oder SaaS. Die Grenze liegt bei "Data in Use".

10. **Kein europäischer Anbieter ist heute ein echter Hyperscaler** — aber die Frage ist nicht "kann STACKIT wie AWS skalieren?", sondern "braucht eine GKV das überhaupt?" STACKIT investiert 11 Milliarden Euro und wird 2027 ausreichend sein.

11. **Vier Souveränitätsstufen, nicht zwei:** Full Isolation (plusserver, Cloud Temple, EU-Open-Source-Stack) → Operator-Modell (Delos, S3NS) → Hyperscaler Sovereign (AWS ESC, Azure EU Boundary) → Sovereignty Washing (AWS Frankfurt, Azure DE). Für KRITIS-Gesundheitsdaten: mindestens Operator-Modell. Der

Maßstab für jede Stufe ist nicht "Verbündeter oder nicht" — sondern "rechtsstaatlich gebunden oder nicht."

12. **Patienten können klagen — und die Haftung erreicht die Leitung auf drei Wegen.** Art. 82 DSGVO gibt Betroffenen einen direkten Schadensersatzanspruch gegen die Organisation. Die Organisation kann ihren GF über die Organhaftung (§ 43 GmbHG / § 93 AktG) in Regress nehmen, wenn die Entscheidung nicht auf einer dokumentierten Risikoabwägung beruhte. Und NIS2 begründet eine eigenständige persönliche GF-Haftung für fehlende Lieferketten-Risikobewertung — ein CLOUD-Act-exponierter Anbieter ist ein Lieferkettenrisiko. Wer kein TIA erstellt hat, hat auf keinem der drei Wege eine Entlastung.

19. Quellenverzeichnis

Gesetzestexte & Primärquellen

• [1] US CLOUD Act (18 U.S.C. § 2713), Volltext: https://www.congress.gov/bill/115th-congress/house-bill/4943/text

• [2] Gutachten Universität Köln für BMI (März 2025): https://datenrecht.ch/us-zugriffsbefugnisse-auf-daten-in-der-cloud-gutachten-uni-koeln-vom-maerz-2025/

• [3] Stiftung Datenschutz: Microsoft kann Zugriff nicht ausschließen (Juli 2025): https://stiftungdatenschutz.org/veroeffentlichungen/datenschutz-im-fokus/datenschutz-im-fokus-detailansicht/us-cloud-act-microsoft-kann-zugriff-durch-us-behoerden-nicht-ausschliessen-600

• [4] OVHcloud CLOUD Act FAQ: https://us.ovhcloud.com/legal/faqs/cloud-act/

• [5] Wissenschaftlicher Dienst Bundestag WD 3-105-23 (2024): https://www.bundestag.de/resource/blob/990440/baf5c0d018ff7cdbfc08edf0f4ce6e64/WD-3-105-23-pdf.pdf

DSGVO-Konflikt & § 393 SGB V

• [6] Datenschutz-Notizen: § 393 SGB V Cloud-Regelungen ab Juli 2024: https://www.datenschutz-notizen.de/cloud-computing-im-gesundheitswesen-neue-regelungen-ab-juli-2024-1648899/

• [7] Heise: Kanada-Urteil — OVHcloud muss europäische Serverdaten herausgeben (2024): https://www.heise.de/news/Kanadisches-Gericht-OVHcloud-aus-Frankreich-muss-Nutzerdaten-herausgeben-11092024.html

• [8] LUTZ ABEL: US Cloud Act — Gefahr für den Datenschutz in Europa: https://www.lutzabel.com/artikel/20201009-der-us-cloud-act-eine-gefahr-fuer-den-datenschutz-europa/

Anbieterbewertung

• [9] eRecht24: Datenschutz bei Hetzner — US-Verbindung über Ashburn/Virginia: https://www.e-recht24.de/dsg/12970-hetzner.html

• [10] Hetzner Datenschutz-Docs — Standorte und Datenflüsse: https://docs.hetzner.com/de/general/general-terms-and-conditions/data-privacy-faq/

• [11] STACKIT CLOUD Act Statement: https://stackit.com/en/learn/knowledge/cloud-act

• [12] STACKIT-CEO Wagner: "Keine US-Investitionen" — it-daily.net (März 2026): https://www.it-daily.net/it-management/stackit-hyperscaler

• [13] Schwarz-Gruppe Wikipedia: Gesellschaftsrechtliche Struktur: https://de.wikipedia.org/wiki/Schwarz-Gruppe

• [14] Lidl Wikipedia: US-Filialen (Lidl Stiftung & Co. KG): https://de.wikipedia.org/wiki/Lidl

• [15] IONOS BMI-Gutachten Referenz (René Floitgraf, Dez. 2025): https://www.rene-floitgraf.de/2025/12/15/digitale-souveraenitaet-und-grenzueberschreitende-datenzugriffe/

• [16] CISPE: No such thing as "75% Sovereign" — EU Cloud Sovereignty Framework critique (Okt. 2025): https://www.cispe.cloud/no-such-thing-as-75-organic/

• [17] CISPE offener Brief: Cloud-CEOs warnen vor Sovereignty-Washing — CADA (März 2026): https://www.cispe.cloud/cloud-sovereignty-letter-march-2026

Hyperscaling

• [18] STACKIT vs. AWS Vergleich (AOE, Aug. 2025): https://www.aoe.com/de/blog/amazon-web-services-aws-vs-stackit-which-cloud-leads-the-pack

• [19] Deutsche Cloud — Hyperscaler-Alternative oder Nischenlösung? (Exxeta, Mai 2025): https://exxeta.com/blog/deutsche-cloud-digitale-souveraenitaet-datenschutz-alternative-aws

• [20] STACKIT — Lidl-Cloud eine Alternative zu Hyperscalern? (cloudcomputing-insider.de): https://www.cloudcomputing-insider.de/ist-die-lidl-cloud-eine-alternative-zu-den-hyperscalern-a-f0f841d498dadd66e5

baffb91fac836e/

• [21] STACKIT: Europas größter Hyperscaler (it-daily.net, März 2026): https://www.it-daily.net/it-management/stackit-hyperscaler

Executive Agreement / Bilaterales Abkommen

• [22] Haufe: Behördenzugriff — CLOUD Act, DSGVO, E-Evidence-VO: https://www.haufe.de/recht/weitere-rechtsgebiete/strafrecht-oeffentl-recht/behoerdenzugriff-auf-nutzerdaten-cloud-act-dsgvo-e-evidence-vo_204_500808.html

• [23] Xpert.Digital: Warum der US CLOUD Act ein Problem für Europa ist (April 2025): https://xpert.digital/us-cloud-act/

• [24] Kiteworks: EU Data Act vs. DSGVO vs. CLOUD Act (März 2026): https://www.kiteworks.com/de/dsgvo-compliance/eu-data-act-dsgvo-cloud-konflikt/

• [25] LUTZ ABEL: UK-Abkommen mit USA (Oktober 2019): https://www.lutzabel.com/artikel/20201009-der-us-cloud-act-eine-gefahr-fuer-den-datenschutz-europa/

Data Privacy Framework

• [26] Netzbegrünung: Warum europäischer Datenschutz mit US-Software schwierig ist (Juni 2025): https://netzbegruenung.de/blog/warum-europaeischer-datenschutz-mit-us-softwareanbietern-schwierig-ist-was-man-ueber-das-data-privacy-framework-wissen-sollte/

Lobbyarbeit

• [27] LobbyControl/CEO: Tech-Branche 151 Mio. EUR EU-Lobbyarbeit (Okt. 2025): https://www.lobbycontrol.de/pressemitteilung/enthuellt-tech-branche-investiert-rekordsumme-in-eu-lobbyarbeit-ausgaben-steigen-auf-151-mio-e-122994/

• [28] Netzpolitik: Big Tech — Rekordsumme EU-Lobbyarbeit (Okt. 2025): https://netzpolitik.org/2025/gegen-regulierung-big-tech-steckt-so-viel-geld-in-eu-lobbyarbeit-wie-noch-nie/

• [29] LobbyControl: Google-Lobbypapier an Bundesregierung (Nov. 2025): https://www.lobbycontrol.de/pressemitteilung/digitalgipfel-weniger-datenschutz-mehr-macht-fuer-big-tech-123225/

• [30] Xpert.Digital: Mehr Lobbyisten als Abgeordnete: https://xpert.digital/mehr-lobbyisten-als-abgeordnete/

Verschlüsselung

• [31] BYOK vs HYOK — Key Ownership vs. Key Management (Kiteworks): https://www.kiteworks.com/gdpr-compliance/customer-owned-encryption-key-control-data-privacy-compliance/

• [32] scip AG: Datenverschlüsselung in der Cloud — BYOK, BYOE, HYOK: https://www.scip.ch/?labs.20201105

• [33] Security-Insider: Verschlüsselung und Tokenisierung reichen nicht: https://www.security-insider.de/verschluesselung-und-tokenisierung-reichen-nicht-a-847984/

• [34] Thales: Cloud Encryption — BYOK und HYOK erklärt: https://cpl.thalesgroup.com/blog/encryption/cloud-encryption-key-management-byok-hyok

Globaler Vergleich

• [35] India sovereign cloud — DPDP Act und RBI-Sanktionen: https://techobserver.in/news/opinion/india-cloud-sovereignty-316729/

• [36] Japan: Sakura Internet Government Cloud (Digital Agency): https://www.digital.go.jp/en/policies/gov_cloud

• [37] Japan: ESPA und Sovereign Cloud Strategy: https://itbusinesstoday.com/tech/cloud/japans-sovereign-cloud-strategy-balancing-innovation-with-national-security/

• [38] Saudi Arabia: 18 Mrd. USD RZ-Strategie: https://stlpartners.com/articles/data-centres/sovereign-ai/

• [39] UAE: OneCloud Sovereign Platform (Oracle Alloy): https://www.oracle.com/middleeast/news/announcement/blog/new-sovereign-cloud-for-an-ai-future-2025-10-03/
• [40] Israel: Project Nimbus — Wikipedia: https://en.wikipedia.org/wiki/Project_Nimbus
• [41] Israel: Microsoft Kill Switch — Israel Democracy Institute (Sept. 2025): https://en.idi.org.il/articles/61802
• [42] Israel: Nimbus Wink-Mechanismus (+972 Magazine, Febr. 2026): https://www.972mag.com/project-nimbus-contract-google-amazon-israel/
• [43] Russia: Public Cloud Market (DataCube Research): https://www.datacuberesearch.com/russia-public-cloud-market
• [44] Russia: Sovereign Internet Law (DGAP): https://dgap.org/en/research/publications/russias-quest-digital-sovereignty
• [45] Africa: Data Sovereignty Trap (New America, Juli 2025): https://www.newamerica.org/planetary-politics/briefs/africas-digital-sovereignty-trap/
• [46] Asia-Pacific Sovereign Cloud Rise (März 2026): https://stealthcloud.ai/analysis/sovereign-cloud-apac-rise/
• [47] China: OpenStack — China Mobile BigCloud: https://www.openstack.org/marketplace/hosted-private-clouds/china-mobile/bigcloud

Operator-Modell (S3NS, Delos Cloud)

• [48] S3NS: SecNumCloud 3.2 Qualifikation für PREMI3NS (Dez. 2025): https://www.s3ns.io/en/news/premi3ns-secnumcloud-qualification
• [49] S3NS Pressemitteilung BusinessWire (19. Dez. 2025): https://www.businesswire.com/news/home/20251218817208/en/S3NS-Announces-SecNumCloud-Qualification-for-PREMI3NS-its-Trusted-Cloud-Offering
• [50] Delos Cloud GmbH, Microsoft, Arvato Systems: finale Verträge unterzeichnet (Sep. 2024): https://news.microsoft.com/de-de/erste-souveraene-cloud-plattform-fuer-die-deutsche-verwaltung-auf-der-zielgeraden/
• [51] SAP: Milliardenschweres Investitionsprogramm souveräne Cloud (Sep. 2024): https://news.sap.com/germany/2024/09/sap-digitale-souveraenitaet-investitionsprogramm-cloud-angebote/
• [52] Computerwoche: Delos Cloud — Das kostet die digitale Souveränität (+15%): https://www.computerwoche.de/article/3833699/delos-cloud-das-kostet-die-digitale-souveranitaet.html
• [53] SKR: Delos Cloud als Modellprojekt?: https://skr-ag.com/de/2023/01/17/delos-cloud-als-modellprojekt/
• [54] Microsoft Q&A: Azure status of SecNumCloud — Bleu als SecNumCloud-Weg für Microsoft: https://learn.microsoft.com/en-us/answers/questions/5590756/azure-status-of-secnumcloud-qualification-by-anssi
• [55] SoftwareSeni: AWS European Sovereign Cloud — Three-Layer Framework (Feb. 2026): https://www.softwareseni.com/aws-european-sovereign-cloud-and-azure-sovereign-options-assessed-against-the-three-layer-framework/

Europäische Anbieter — vollständige Bewertung

• [56] Söldner IT / T Cloud Public: Vergleich 8 europäischer Cloud-Anbieter: https://public.t-cloud.com/en/blog/benefits/european-cloud-alternatives-to-hyperscalers
• [57] SoftwareSeni: EU-Native Cloud Providers Compared (Feb. 2026): https://www.softwareseni.com/eu-native-cloud-providers-compared-hetzner-ovhcloud-scaleway-and-t-systems/
• [58] European.cloud: Anbieterverzeichnis: https://european.cloud/
• [59] Callista Benchmark (Feb. 2026): Hetzner 14,3x Preis/Performance vs. AWS: https://www.fromeuropewithlove.eu/en/blog/european-cloud-providers-vs-aws-comparison-2026
• [60] EU-Kommission: Cloud Sovereignty Framework + 180 Mio. EUR Tender (Okt. 2025): https://commission.europa.eu/news-and-media/news/commission-moves-forward-cloud-sovereignty-eur-180-million-te

nder-2025-10-10_en

• [61] Broadcom: Three Predictions Sovereign Cloud 2026 — 70% US-Marktanteil: https://news.broadcom.com/sovereign-cloud/three-predictions-for-sovereign-cloud-in-2026

• [62] Windows News: Frankreich Health Data Hub Migration Azure → SecNumCloud 2026: https://windowsnews.ai/article/frances-health-data-hub-migration-from-azure-to-eu-cloud-sovereignty-vs-technology.401470

• [63] PAC Blog: S3NS Thales Google Summit 2026 — SecNumCloud-Markt Frankreich: https://sitsi.pacanalyst.com/thales-s3ns-google-summit-2026-the-trusted-cloud-shifts-to-scale/

• [64] Cloud Temple: SecNumCloud IaaS + PaaS, 100% französisches Eigentum: https://www.redhat.com/tracks/_pfcdn/assets/10330/contents/1096276/fbbed16f-8809-4afc-afce-b53652c5b0e2.pdf

• [65] OVHcloud: SecNumCloud Bare Metal Pod — Zertifizierungsdetails: https://www.ovhcloud.com/en/compliance/secnumcloud/

• [66] OVHcloud Summit 2025: SecNumCloud IaaS-Roadmap 2026: https://itdaily.com/blogs/cloud/ovhcloud-summit-2025/

• [67] Drime: 7 certified French cloud solutions 2025 — NumSpot, Outscale, Cloud Temple: https://drime.cloud/blog-posts/7-certified-french-cloud-solutions-for-your-business-in-2025

• [68] Xpert.Digital: Deutschlands Kampf um die Cloud — Delos vs. STACKIT: https://xpert.digital/deutschlands-kampf-um-die-cloud/

• [69] SoftwareSeni: Comparing European Cloud Providers — Open Source Alternatives: https://www.softwareseni.com/comparing-european-cloud-providers-and-open-source-alternatives-to-us-platforms/

Vollständiger EU-Plattformstack / Office-Souveränität

• [70] Nextcloud + IONOS: Nextcloud Workspace als M365-Alternative (Sept. 2025): https://nextcloud.com/blog/nextcloud-workspace-microsoft-365-alternative-by-nextcloud-and-ionos/

• [71] Euro-Office Launch: IONOS, Nextcloud, EuroStack Koalition (März 2026): https://nextcloud.com/blog/press_releases/industry-initiative-launches-euro-office-as-true-sovereign-office-suite/

• [72] TechRadar: Euro-Office — European giants launch sovereign office suite (April 2026): https://www.techradar.com/pro/watch-out-microsoft-365-european-giants-launch-euro-office-a-true-sovereign-office-suite

• [73] Office.eu Launch — 100% europäische M365-Alternative (März 2026): https://winbuzzer.com/2026/03/17/officeeu-launches-europes-sovereign-alternative-microsoft-365-xcxwbn/

• [74] Office Watch: Office.eu — European alternative to Microsoft 365: https://office-watch.com/2026/office-eu-europes-microsoft-365-alternative/

• [75] OpenCloud 1.0 — Open Source SharePoint-Alternative (Feb. 2025): https://opencloud.eu/en/press/opencloud-now-available-new-open-source-alternative-microsoft-sharepoint

• [76] GoFAST — SharePoint On-Premise End-of-Life Migration (2026): https://www.ceo-vision.com/en/content/end-support-sharepoint-premises-2026-switch-gofast-sovereign-european-alternative

• [77] Schleswig-Holstein: E-Mail-Migration abgeschlossen, 40.000 Accounts (Okt. 2025): https://www.theregister.com/2025/10/15/schleswig_holstein_open_source/

• [78] Schleswig-Holstein: €15 Mio. jährliche Einsparungen durch LibreOffice (Dez. 2025): https://itsfoss.com/news/german-state-ditch-microsoft/

• [79] Schleswig-Holstein: Deutschland-Stack-Impulspapier (Jan. 2026): https://nextcloud.com/blog/schleswig-holsteins-impulspapier-for-deutschland-stack-vision/

• [80] EuroStack Directory: Schleswig-Holstein Open Source Modell (März 2025): https://euro-stack.com/blog/2025/3/schleswig-holstein-open-source-digital-sovereignty

• [81] Computerworld: Nextcloud als M365-Alternative — IDC-Analyse (Sept. 2025): https://www.computerworld.com/article/4064116/a-european-alternative-to-m365-nextcloud-looks-to-capitalize-on-digital-sovereignty-interest.html

• [82] Mistral AI: Sovereign AI Stack, €1,7 Mrd. Funding (Sept. 2025): https://aibusiness.com/foundation-models/mistral-pioneers-sovereign-ai-in-europe

• [83] EuroHPC JU: 19 AI Factories in Europa (Okt. 2025): https://www.eurohpc-ju.europa.eu/eurohpc-ju-selects-six-additional-ai-factories-expand-europes-ai-capabilities-2025-10-10_en

• [84] LUMI: TildeOpen 30B-Parameter-Modell auf LUMI trainiert (Sept. 2025): https://lumi-supercomputer.eu/tildeopen/

• [85] OpenEuroLLM: Erster strategischer Zugang zu LUMI/Leonardo/JUPITER (Dez. 2025): https://www.ai.se/en/news/openeurollm-takes-next-step-european-ai-sovereignty

US-Beratungspartnerschaften und Interessenkonflikte

• [86] Avanade GmbH: "About Avanade — Joint Venture Accenture & Microsoft", avanade.com/en-us/about-avanade, abgerufen April 2026. 50.000 Mitarbeitende, gegründet April 2000.

• [87] Avanade Wikipedia: "Avanade", en.wikipedia.org/wiki/Avanade, abgerufen April 2026. Gründung, Eigentümerstruktur, CEO-Wechsel 2026.

• [88] Microsoft Source Blog: "Accenture, Microsoft and Avanade help enterprises reinvent business functions with generative AI and Copilot", news.microsoft.com/source, 14. November 2024. 5.000-köpfige Copilot Practice, 50.000+ geschulte Profis, 65.000 Microsoft-zertifizierte Mitarbeitende.

• [89] Accenture: "Accenture and Microsoft", accenture.com/us-en/services/ecosystem-partners/microsoft, abgerufen April 2026. 16-facher Global Alliance Partner of the Year, 25-jährige Partnerschaft.

• [90] Maven Collective Marketing: "Microsoft Fiscal Year 2025 Updates — Partner Opportunities", mavencollectivemarketing.com, Oktober 2024. Bis zu 120.000 USD pro Kunde für M365 E3-Workloads; 150 Mio. USD Azure Migrate & Modernize Co-Investment.

• [91] Redmond Channel Partner: "Microsoft To Pour Millions into Partner Incentives, Azure and Security in FY2025", rcpmag.com, 12. Juli 2024. 90 Mio. USD Sicherheits-Investments, Copilot-Incentives +1.000% gegenüber FY24.

• [92] VentureBeat: "KPMG to invest $2 billion in AI in expanded partnership with Microsoft", venturebeat.com, Juli 2023. 5-Jahres-Partnerschaft, 2 Mrd. USD Investment, 12 Mrd. USD erwartetes Wachstumspotenzial.

• [93] SiliconAngle: "KPMG invest $2B in AI and cloud as it expands partnership with Microsoft", siliconangle.com, Juli 2023. Alle Big Four haben vergleichbare Microsoft-Partnerschaften.

• [94] CFO Dive: "KPMG inks $100M Google Cloud deal", cfodive.com, November 2024. KPMG parallel bei Microsoft (2 Mrd.) und Google (100 Mio.) investiert.

• [95] McKinsey & Company: "Amazon McKinsey Group", mckinsey.com/about-us/new-at-mckinsey-blog/mckinsey-and-amazon-launch-amazon-mckinsey-group, 22. Januar 2026. Offizieller Launch AMG.

• [96] TechInformed: "McKinsey, AWS launch Amazon McKinsey Group", techinformed.com, 23. Januar 2026. Outcome-basiertes kommerzielles Modell, Ziel >1 Mrd. USD Kundenimpact.

• [97] McKinsey & Company: "AWS & McKinsey Alliance", mckinsey.com/about-us/overview/alliances-and-acquisitions/aws, abgerufen April 2026. Strategische Allianz seit 2019, AWS APN Partner.

• [98] OpenAI: "Introducing Frontier Alliances", openai.com/index/frontier-alliance-partners/, 23. Februar 2026. Offizielle Ankündigung der Partnerschaften mit BCG, McKinsey, Accenture, Capgemini.

• [99] Fortune: "OpenAI partners with McKinsey, BCG, Accenture, and Capgemini to push its Frontier AI agent platform", fortune.com, 23. Februar 2026. Strategische Rollenverteilung der Partner.

• [100] CNBC: "OpenAI lands multiyear deals with consulting giants in enterprise push", cnbc.com, 23. Februar 2026. Mehrjährige Partnerschaften, Forward Deployed Engineering Support.

• [101] Atelier & Avenue: "The 4 unacceptable Conflicts of Interest of classic consultancies", atelierandavenue.com, 2019. Mechanismus der Provisionszahlungen von Technologieanbietern an Berater.

• [102] Apotheke Wirtschaft: "Rien ne va plus — ohne die Riesen im Hintergrund läuft in der TI gar nichts", Heft 16/2025. IBM, Arvato als zentrale TI-Infrastrukturpartner; IBM als Identity Provider

zugelassen seit Dezember 2023.

Oracle / Oracle Cerner im deutschen Gesundheitswesen

• [103] Wikipedia: "i.s.h.med", de.wikipedia.org/wiki/I.s.h.med, abgerufen April 2026. Geschichte, Eigentümerstruktur, Cerner-Übernahme 2015, Oracle-Übernahme 2022, >500 Installationen weltweit.

• [104] kma-online.de: "Gute Aussichten dank SAP — Über Cloud, SaaS und KI: Das planen die Top-Player des KIS-Marktes", April 2024. Oracle Cerner plant OCI-basierte Nachfolgelösung für i.s.h.med; 300 Kliniken vor KIS-Wechsel bis 2030.

• [105] Krankenhaus-IT Journal: "Oracle Cerner und SAP-Strategiewechsel", Januar 2024. Einstellung Betreuungsvertrag IS-H RKT durch Oracle Cerner; DSAG-Reaktion.

• [106] kma-online.de: "Heftige Turbulenzen im KIS-Markt nach SAP-Ausstieg", April 2023. Oracle-Übernahme von Cerner für 28 Mrd. USD 2022; i.s.h.med in 250 deutschen Kliniken; KIS als "Beifang" in Oracle-Zentrale Austin/Texas.

• [107] rewion.com: "Krankenhausinformationssystem (KIS): Welche Anbieter gibt es?", Juni 2025. Marktübersicht KIS Deutschland: Oracle Cerner ~250 Installationen; CGM ~850, Dedalus ~830, Meierhofer ~250, Telekom iMedOne ~240.

• [108] Oracle Blog: "US CLOUD Act: You have questions and we have answers", oracle.com/cloud-infrastructure, 2022. Oracle-eigene Darstellung des CLOUD-Act-Umgangs, Verschlüsselungsneutralität.

• [109] Oracle Blog: "Oracle sovereign cloud solutions: Providing transparent review of data access requests", oracle.com/cloud-infrastructure, 2024. EU Sovereign Cloud Argumentation: Realm-Isolation, EU-Rechtsperson, Widerspruchsmechanismus.

• [110] Oracle: "EU Sovereign Cloud FAQ", oracle.com/cloud/eu-sovereign-cloud/faq/, abgerufen April 2026. Frankfurt und Madrid als EU Sovereign Cloud Regionen; EU-ansässiges Personal; Isolation von US-Infrastruktur.

KIS-Marktdaten und Ausschreibungskonzentration

• [111] kma-online.de: "KIS-Markt 2025 — das sind die Top-Hersteller", April 2025. CGM: 319 Mio. EUR KIS-Umsatz 2024, ~20% Marktanteil; Dedalus 821 Installationen DE, 930 DACH; Meierhofer ~260 Kunden.

• [112] kma-online.de: "KIS-Markt 2026: Trends, Anbieter und Strategien im Überblick", April 2026. NEXUS 326 Installationen DE, 288,6 Mio. EUR Umsatz 2025; CGM veröffentlicht keine aktuellen Installationszahlen; CGM verliert Charité-Ausschreibung gegen Epic.

• [113] bibliomedmanager.de: "KI ist für uns ein großes Thema", Oktober 2023. CGM: "rund 800 Kliniken in Deutschland"; "im Reha-Bereich sogar das KIS mit den meisten Installationen."

• [114] kma-online.de: "Über Cloud, SaaS und KI: Das planen die Top-Player des KIS-Marktes", April 2024. Direktzitat CGM: "Über 900 Kliniken in Deutschland setzen ein KIS von CGM ein"; Produktlinien inkl. CGM Reha.

• [115] kma-online.de: "Das Geschäft brummt wie lange nicht — KIS-Markt 2022", April 2022. CGM 2020: 350 Akut- und 500 Rehakliniken nach Cerner-Übernahme; Kaufpreis 203 Mio. EUR.

• [116] EY Deutschland: "Asklepios: So geht digitale Transformation", ey.com/de_de, 2022/2023. Vollständige S/4HANA-Migration aller 170 Asklepios-Einrichtungen; EY als Implementierungspartner seit 2019.

• [117] EY Deutschland: "EY unterstützt Asklepios bei der Migration zu S/4HANA", ey.com/de_de, 2022. Go-live Oktober 2022; EY-Partner und EY-Gesundheitsexperte als Projektverantwortliche benannt.

• [118] Asklepios Geschäftsbericht 2023: "Daten — Heilmittel der Zukunft", bericht.asklepios.com. Health Data Hub als "eines der wichtigsten Zukunftsprojekte"; Ziel: KI-Lernplattform für alle Einrichtungen.

• [119] Asklepios: "Health Data Hub", asklepios.com/konzern/digitalisierung/health-data-hub, abgerufen April 2026. Nutzung anonymisierter Daten mit KI für bessere Abläufe.

• [120] Deloitte Deutschland: "Zukunftsprogramm Krankenhäuser — KHZG", deloitte.com/de, 2021/2024. Deloitte-KHZG-Beratungsangebot: 360°-Unterstützung von Identifikation bis Fördermitteladministration.

• [121] Deloitte Deutschland: "Studie: Digitalisierung des Gesundheitsmarktes", deloitte.com/de, 2021. Deloitte-Studie im Auftrag des GKV-Spitzenverbandes; institutionelle Positionierung als GKV-Berater.

• [122] McKinsey & Company: "Der GKV-Check-up 2025", mckinsey.de/publikationen/gkv-check-up-2025, Mai 2025. Jährliches GKV-Standardwerk; Motto 2025: "Mit Innovation und Datenanalytik neue Maßstäbe setzen."

• [123] McKinsey & Company: "Gesundheitswirtschaft Deutschland", mckinsey.de/branchen/gesundheitswirtschaft, abgerufen April 2026. >2.200 Healthcare-Kundenprojekte seit 2000; >200 Mitarbeitende im deutschen Gesundheitssektor.

• [124] PwC Deutschland: "Transaktionsmonitor Gesundheitswesen 2023/2024", März 2024. 234 Transaktionen 2023; 13. Ausgabe der jährlichen Analyse; PwC als Standard-Referenzwerk M&A Kliniksektor.

• [125] ibau.de: "Wenn Vergabestellen nur erfahrene Unternehmen wollen", August 2024. OLG Schleswig-Holstein, 10.12.2020, 54 Verg 4/20: Mindestanforderungen an Geschäftstätigkeit rechtmäßig, auch wenn neue Unternehmen ausgeschlossen werden.

• [126] Vergabe24.de: "Nachweise zur Leistungsfähigkeit, Referenzen und Besonderheiten für Start-ups", 2024. § 45 Abs. 1 VgV: Mindestjahresumsatz bis zum Zweifachen des Auftragswertes zulässig.

• [127] juniorconsultant.net: "Managementberater — Wer kommt hinter McKinsey und BCG?", August 2024. Roland Berger: ~500 Mio. EUR Umsatz weltweit, Fokus Restrukturierung/M&A; kein Platz im IT-Implementierungsmarkt.

STACKIT / Schwarz Digits — erweiterte Quellen

• [128] it-daily.net: "'Einfach mal machen': Stackit will Europas größter Hyperscaler werden", März 2026. 7 RZ in Europa, Expansion 2026 in 3+ Länder; Finanzsektor-Fokus.

• [129] Silicon Saxony: "Schwarz Digits: Spatenstich in Lübbenau — 11 Milliarden Euro in Europas digitale Souveränität", 17. November 2025. Vollständige Investitionsdaten, Minister-Statement, Partnerschafts-Ökosystem.

• [130] niederlausitz-aktuell.de: "11 Milliarden Investition in Lübbenau: Mega-Rechenzentrum entsteht", November 2025. 6 Module, Baubeginn Oktober 2025, Fertigstellung Ende 2027, Verfügbarkeitsklasse 3.

• [131] Schwarz Digits Pressemitteilung: "C5 Type 2 certificate: STACKIT receives confirmation of the highest security standards", 21. August 2024, schwarz-digits.de. C5 Typ 2 Testat August 2024; Gesundheitssektor und öffentliche Verwaltung explizit adressiert.

• [132] Schwarz Digits Pressemitteilung: "Sovereign STACKIT Cloud with BSI's C5, ISAE 3000 (SOC 2) and ISAE 3402 Certified", Januar 2024. C5 Typ 1 Testat Januar 2024; ISO 27001 Rezertifizierung.

• [133] BSI Pressemitteilung: "Cloud Computing: BSI und Schwarz Digits planen Kooperation", 18. März 2025, bsi.bund.de. Strategische Kooperation für souveräne Bundesverwaltungs-Cloud, inkl. Geheimhaltungsstufe "Geheim"; BSI-Präsidentin Plattner-Zitat.

• [134] Behörden Spiegel: "BSI kooperiert mit STACKIT für souveräne Cloud-Lösungen", 19. März 2025. Bestehende BSI-Kooperationen: SAP, Oracle, Google Cloud; geplant: STACKIT, AWS. Post-Quanten-Kryptographie als Schwerpunkt.

• [135] Computerwoche: "BSI und Schwarz Digits kooperieren bei Cloud-Sicherheit", 19. März 2025. Keine Vergabeentscheidung, reine Analysekooperation; BSI-Vizepräsident Caspers-Zitat.

• [136] Schwarz Digits Wikipedia: "Schwarz Digits", en.wikipedia.org/wiki/Schwarz_Digits, Stand April 2026. DataHub Europe (Dt. Bahn), AuditGPT produktiv August 2025, SWR-Partnerschaft August 2025, Google Workspace 575.000 MA via STACKIT, 1,9 Mrd. EUR Umsatz 2024/25.

• [137] CANCOM Newsroom: "CANCOM integrates STACKIT's sovereign cloud services into the Cloud Marketplace", November 2025. Explizite CLOUD-Act-Freiheit als Vermarktungsargument; C5 Typ 2, ISO 27001, ISAE 3000/3402 bestätigt.

• [138] Computerwoche: "Schwarz Digits bietet deutsche Cloud für SAP-Lösungen", Mai 2025. Wire als BSI-freigegebener VS-NfD-Messenger auf STACKIT; Schwarz Gruppe Gesamtinvestitionen 8,6 Mrd. EUR 2024, 9,6 Mrd. EUR 2025 geplant.

• [139] xpert.digital: "From discount retailer to STACKIT Cloud AI hyperscaler", November 2025. AWS Deutschland: 7,8 Mrd. EUR Gesamtinvestition; STACKIT 11 Mrd. EUR nur für Lübbenau; Lübbenau als KI-Gigafactory-Kandidat in Branchendebatten.

• [140] STACKIT: "The sovereign cloud for the public sector", stackit.com/en/solutions/industries/public-sector, abgerufen April 2026. DRV Bund Cloud RealLabor; GovTech Campus BMI; Wire VS-NfD-Freigabe.

Enforcement-Gap — neue Quellen

• [141] DSK-Beschluss: "Festlegung der Datenschutzkonferenz — Datenschutzkonformer Betrieb von Microsoft 365 nicht nachweisbar", 24. November 2022. Wortlaut: "Der Nachweis eines datenschutzrechtskonformen Betriebs von Microsoft 365 auf Grundlage des Datenschutznachtrags vom 15.09.2022 kann nicht geführt werden." DSK-Mehrheitsbeschluss 9:8 Stimmen.

• [142] FragDenStaat / DSK: Beschlussentwurf AK Verwaltung zu Microsoft Office 365, September 2020 (fragdenstaat.de/dokumente/7571). Erste DSK-Einstufung: "kein datenschutzgerechter Einsatz von Microsoft Office 365 möglich."

• [143] Artikel91.eu: "Aufsichten vs. Microsoft-Cloud: Viel Dialog, (fast) keine Sanktionen", November 2021. Dokumentation: keine systematischen anlasslosen Prüfungen trotz DSK-Beschluss; Hamburger DSB bestätigt rein beratungsbasiertes Vorgehen.

• [144] dsgvo-portal.de: "Rückblick DSGVO-Bußgeldverfahren und Datenpannen 2024", Januar 2025. Deutsche Behörden: 266 Bußgelder, ~2,5 Mio. EUR Gesamtvolumen 2024. Höchstbußgeld: 900 Tsd. EUR (Forderungsmanagement, Hamburg). Kein Gesundheitswesen-Cloud-Fall dokumentiert.

• [145] LfDI Baden-Württemberg: "Datenschützer verhängen Millionen-Bußgeld gegen AOK Baden-Württemberg", 30. Juni 2020. 1,2 Mio. EUR wegen Gewinnspielmissbrauchs 2015–2019 — nicht wegen Cloud-Nutzung oder DSGVO Art. 48.

• [146] dsgvo-portal.de: "Rückblick DSGVO-Bußgeldverfahren und Datenpannen 2025", Februar 2026. Deutsche Behörden: 249 Bußgelder, ~46,9 Mio. EUR (davon 45 Mio. EUR allein Vodafone/BfDI). Kein GKV/Klinik/Cloud-Act-Fall dokumentiert.

Kapitel 13 — erweiterte Marktbeispiele

• [147] Apotheke Adhoc: "DAVASO/IQVIA: Kartellamt fragte bei BMG nach", ohne Datum (2023). Kartellamt-Prüfung; BMG, BAS, BfDI einbezogen; Iqvia-Übernahme genehmigt.

• [148] Apotheke Adhoc: "Iqvia kauft Retaxfirma Davaso", August 2021. DAVASO: >50 % Apothekenrezepte DE, Abrechnungsvolumen 22 Mrd. EUR, 1.400 MA Leipzig/Taucha/Suhl.

• [149] Apotheke Adhoc: "Retax: Davaso wird Iqvia", März 2026. Umbenennung DAVASO → IQVIA Health System Services (IQVIA HSS).

• [150] Doctolib Datenschutzhinweise: help.doctolib.de, abgerufen April 2026. Patientendaten: AWS Frankfurt (primär), AWS Paris (Spiegelung).

• [151] kuketz-blog.de: "Datenschutz: Was Patienten zu Doctolib und ihren Rechten wissen müssen", November 2024. Stammdatensatz-Import bei jeder Praxisanbindung.

• [152] netzpolitik.org: "Doctolib: Wachsender Riese im Gesundheitsdatenmarkt", April 2024. Doppelrolle als Auftragsverarbeiter und eigenverantwortlich.

• [153] HNO Nachrichten/Springer: "Patientendaten sind in Doctolib-Cloud sicher", Dezember 2025. C5 Typ 2 Testat Doctolib 2025; 12 Monate Audit.

• [154] netzpolitik.org: "Neue Datenschutzhinweise: Doctolib will KI-Modelle mit Gesundheitsdaten trainieren", Januar 2025.

• [155] NOVENTI expopharm 2024: Pressemitteilung Oktober 2024. TIaaS, PROKAS Evolution, eigene RZ, apothekereigenes Unternehmen (FSA e.V.).

• [156] CGM Wikipedia: "CompuGroup Medical", en.wikipedia.org, Stand April 2026. CVC Capital Partners ~28 % seit Juni 2025, Delisting TecDAX; 30 % aller deutschen E-Rezepte über CGM.

• [157] bibliomedmanager.de: "CGM-Umsatz 2025: Wachstum durch Cloud und KI", Februar 2026. Gesamtumsatz 1,213 Mrd. EUR; KH-Segment +10 % auf 353 Mio. EUR.

• [158] CGM Pressemitteilung: "Entwicklungspartnerschaft CGM / UKH Heidelberg zur SAP IS-H-Nachfolge", April 2024. CGM CLINICAL als IS-H-Nachfolge; private Cloud-Option.

• [159] Arvato Systems: "Cloud migration for kubus IT", us.arvato-systems.com/more/about-arvato-systems/references/kubus-it, abgerufen April 2026. Vollmigration Kubus IT → Arvato Systems RZ; 17.500 IT-Nutzer; Google Cloud als Hyperscaler-Option.

• [160] Arvato Systems Blog: "Digitalization for health insurers: at the Google Cloud Summit South", Juni 2024. Kubus IT als Nachweis Google Cloud + souveräne GKV-IT; Sovereign Cloud Diskussion; Panel Google Cloud Summit München Juni 2024.

• [161] e-health-com.de: "adesso wird Cloud-Transformationspartner für das ITSC", 2024. ITSC → OVHcloud (FR, EU-souverän); Projektstart Mai 2024; siebenstelliges Budget; adesso als Migrationspartner.

US-Sanktionen und digitale Abhängigkeit

• [162] HateAid: Pressemitteilung, 14. Januar 2026. US-Sanktionierung der HateAid-Geschäftsführerinnen Josephine Ballon und Anna-Lena von Hodenberg durch US-Außenminister Rubio.

• [163] CNN: "US sanctions European officials and activists over online censorship concerns", 24. Dezember 2025. Berichterstattung zur HateAid-Sanktionierung, EU-Kommissar Breton, britische Anti-Desinformations-Organisationen.

• [164] The Local: "US sanctions two German anti-hate speech activists", 24. Dezember 2025. Reaktion Bundesregierung; Bundestags-Vizepräsident Nouripour fordert Einbestellung des US-Geschäftsträgers.

• [165] MIT Technology Review: "What happens when the US sanctions you — and you depend on US tech", 19. Januar 2026. Fallstudie ICC-Richter: Verlust des Zugangs zu Microsoft, Amazon, Gmail, Visa, Mastercard nach Sanktionierung.

GKV-/KV-Infrastruktur und Ausschreibungen

• [166] govdigital.de: "BITMARCK tritt govdigital bei", Oktober 2024. BITMARCK govdigital-Beitritt; Kontext BITMARCK-all-in-ONE-Programm.

• [167] BITMARCK: Kundentag 2025. Strategiepräsentation Cloud-Migration und SAP S/4HANA-Roadmap.

• [168] kvno.de: "KV-IT GmbH", kvno.de/kv-it-gmbh, abgerufen April 2026. Gemeinsame IT-Gesellschaft KVWL/KVNO in Düsseldorf/Dortmund.

• [169] TED: Ausschreibung 98706-2026, EU-Amtsblatt S 29/2026, 11. Februar 2026. KVNO-Ausschreibung X-KVNO-2025-0023: "Entwicklung und Betrieb einer KI-Plattform als PaaS-Lösung" auf Azure Cloud.

• [170] BMG: Pressemitteilung, Oktober 2025. FDZ Gesundheit beim BfArM: Betriebsstart, GKV-Abrechnungsdaten 2009–2023 von 73 Mio. Versicherten.

Weitere Marktbeispiele

• [171] zaronews.world: Pressemitteilung HBSN AG, Juni 2018. MDK-Gemeinschaft: europaweites Vergabeverfahren, Konsortium HBSN/EWERK RZ/MOBIL ISC.

• [172] Charité — Universitätsmedizin Berlin: Pressemitteilung, Dezember 2025. Vergabe KIS-Neubeschaffung an Epic Systems (Verona, WI); 200 Mio. EUR / 10 Jahre; Implementierung bis Ende 2029.

• [173] Energieforen Leipzig / EWERK: Zertifizierungsseite, abgerufen April 2026. EWERK ISO 27001, ISO 20000, ISAE 3402 Typ II; BSI C5 Typ 2 in Vorbereitung. Ergänzend: Trusted Cloud, EWERK Digital

Profil.

SecNumCloud, EUCS und Cloud-Souveränität

• [174] Ifri: Digital Sovereignty — Review of Macron's Term and Debates in the 2022 Presidential Campaign, 2022. Pierre Bellanger, *Souveraineté Numérique* (2014); Institut de la Souveraineté Numérique gegründet nach drei nationalen Gipfeltreffen 2014–2017: https://www.ifri.org/en/memos/digital-sovereignty-review-macrons-term-and-debates-2022-presidential-campaign

• [175] Cloud Temple: SecNumCloud 3.2 — The new sovereign cloud standard. Über 360 Anforderungen, 14 Sicherheitsthemen, Souveränitätsklausel: EU-Eigentum, EU-Hauptsitz, Immunität gegen extraterritoriale Gesetze: https://www.cloud-temple.com/en/secnumcloud-3-2-strengthening-security-and-legal-sovereignty-in-the-cloud/

• [176] numerique.gouv.fr: Doctrine "Cloud au centre" — Rundschreiben des Premierministers vom 5. Juli 2021, aktualisiert 31. Mai 2023. SecNumCloud-Qualifizierung verpflichtend für sensible Daten des Staates: https://www.numerique.gouv.fr/services/cloud/doctrine/

• [177] Kiteworks: BSI C5 Explained — Germany's Cloud Security Standard for CSPs in 2026. 121 Kontrollen in 17 Domänen; prüft Informationssicherheit, nicht Jurisdiktion: https://www.kiteworks.com/regulatory-compliance/bsi-c5-germanys-cloud-security-framework-requirements/

• [178] ITI (Information Technology Industry Council): ITI Urges EU Lawmakers to Drop Sovereignty Requirements in Final EUCS, 2024. US-Industrieverband fordert Streichung der Souveränitätsanforderungen: https://www.itic.org/news-events/news-releases/iti-urges-eu-lawmakers-to-drop-sovereignty-requirements-in-final-eucs

• [179] The Register: US lobbyists pay for report critical of EU cloud regulation, März 2023. ITIF-Studie gegen EU-Souveränitätsanforderungen von US-Lobbyisten finanziert: https://www.theregister.com/2023/03/06/proposed_eu_cloud_regulation/

• [180] EU ISS (Institute for Security Studies): Technical is political — When a cloud certification scheme divides Europe. 7 EU-Mitgliedstaaten (NL, DK, SE, EE u.a.) reichen Non-Paper gegen Souveränitätsstufe ein: https://www.iss.europa.eu/publications/briefs/technical-political-when-cloud-certification-scheme-divides-europe

• [181] European Business Review: France and Germany increasingly drift apart on digital sovereignty of cloud sector. Divergierende Positionen bei EUCS und Cloud-Souveränität: https://www.europeanbusinessreview.eu/page.asp?pid=6989

• [182] Bitkom Cloud Report 2025: 78 % der befragten Unternehmen halten Deutschland für zu abhängig von US-Cloud-Anbietern. Position Paper Cloud & AI Development Act, Juli 2025: https://www.bitkom.org/EN/List-and-detailpages/Publications/Cloud-AI-Development-Act

• [183] cep (Centrum für Europäische Politik): EU Cloud Certification at an Impasse, cepInput Nr. 8, April 2025. EUCS-Pattsituation durch ungelösten Souveränitätsstreit: https://www.cep.eu/fileadmin/user_upload/cep.eu/cepItalia/cepInput_EU_Cloud_Certification_at_an_Impasse.pdf

• [184] Tandfonline: European ambitions captured by American clouds — digital sovereignty through Gaia-X?, 2025. Gaia-X-Governance-Scheitern durch Aufnahme von US-Hyperscalern; Souveränitätslabels unverbindlich: https://www.tandfonline.com/doi/full/10.1080/1369118X.2025.2516545

• [185] About Amazon EU: AWS and BSI sign cooperation agreement to advance cybersecurity and digital sovereignty in Germany and the EU. BSI-Präsidentin Plattner begrüßt AWS European Sovereign Cloud als Souveränitätsbeitrag: https://www.aboutamazon.eu/news/aws/aws-and-bsi-sign-cooperation-agreement-to-advance-cybersecurity-and-digital-sovereignty-in-germany-and-the-eu

• [186] BSI: C5:2026 — Kriterienkatalog für Cloud Computing (finale Version, veröffentlicht 7. April 2026). Souveränitätskriterien als separates Dokument angekündigt ("in Kürze"), nicht in C5:2026 integriert: https://www.bsi.bund.de/DE/Themen/Unternehmen-und-Organisationen/Informationen-und-Empfehlungen/Empfehlungen-nach-Angriffszielen/Cloud-Computing/Kriterienkatalog-C5/C5_2025/C5_2025_node.html

• [187] Élysée: Summit on European Digital Sovereignty delivers landmark commitments, 18. November 2025. Macron/Merz, Joint Task Force, 12 Mrd. EUR Investitionszusagen, 900+ Teilnehmer: https://www.

elysee.fr/en/emmanuel-macron/2025/11/18/summit-on-european-digital-sovereignty-delivers-landmark-commitments-for-a-more-competitive-and-sovereign-europe

• [188] BSI Pressemitteilung: "Sicheres Cloud-Computing: BSI veröffentlicht C5:2026", 7. April 2026. 168 Kriterien in 17 Themengebieten; Container-Management, Post-Quanten-Kryptographie, Confidential Computing, Supply-Chain-Management; strukturell an EUCS angelehnt; maschinenlesbar: https://www.bsi.bund.de/DE/Service-Navi/Presse/Pressemitteilungen/Presse2026/260407_C5_Cloud_Computing.html

• [189] BSI/ANSSI: Joint Statement by ANSSI and BSI on Cloud Sovereignty Criteria, 17. November 2025. Gemeinsame Souveränitätskriterien auf Basis EU Cloud Sovereignty Framework; Drei-Stufen-Progressionsmodell; strikte Datenlokalisierung, kein Zugang durch nicht-europäische Dritte, Geschäftskontinuität ohne außereuropäische Technologien: https://www.bsi.bund.de/SharedDocs/Downloads/EN/BSI/Publications/ANSSI-BSI-joint-releases/Cloud-Sovereignty-Criteria.html

• [190] DSK: Beschluss Positionspapier zu cloudbasierten digitalen Gesundheitsanwendungen, 06. November 2023. Cloud-Funktionen standardmäßig deaktiviert; Privacy by Default; BSI-TR als Maßstab: https://www.datenschutzkonferenz-online.de/media/dskb/2023_11_06_Beschluss_cloudbasierte_digitale_Gesundheitsanwendungen.pdf

• [191] DSK: Entschließung zu Confidential Cloud Computing, 16. Juni 2025. Cloud-Betreiber behalten umfassenden physischen und technischen Zugriff; Marketingversprechen halten regelmäßig einer Prüfung nicht stand: https://www.datenschutz-berlin.de/fileadmin/user_upload/pdf/publikationen/DSK/2025/20250617-DSK-Entschliessung_Confidential-Cloud-Computing.pdf

• [192] DSK: Orientierungshilfe zu empfohlenen technischen und organisatorischen Maßnahmen bei der Entwicklung und beim Betrieb von KI-Systemen, Mai/Juni 2025. Erste koordinierte KI-Orientierungshilfe aller Aufsichtsbehörden; DSFA für LLMs erforderlich: https://www.lfd.niedersachsen.de/dsk-ki

• [193] DSK: Positionspapier Datenschutz bei der Terminverwaltung durch Heilberufspraxen, 16. Juni 2025. Patientenstammdaten nicht pauschal an Cloud-Termindienstleister übermitteln: https://www.datenschutzkonferenz-online.de/media/dskb/DSK-Beschluss_Positionspapier_Terminverwaltungsunternehmen.pdf

• [194] BfDI: "KI in Behörden — Datenschutz von Anfang an mitdenken", KI-Handreichung für die Bundesverwaltung, 22. Dezember 2025: https://www.bfdi.bund.de/SharedDocs/Downloads/DE/DokumenteBfDI/Dokumente-allg/2025/Handreichung-KI.pdf

• [195] LfDI Baden-Württemberg: Diskussionspapier "Rechtsgrundlagen im Datenschutz beim Einsatz von Künstlicher Intelligenz", Version 2.0, 17. Oktober 2024. Rechtsgrundlage für jede KI-Phase separat; EHDS-VO referenziert: https://www.baden-wuerttemberg.datenschutz.de/rechtsgrundlagen-datenschutz-ki/

• [196] BayLDA: Checkliste "Datenschutz und KI" (Konsultationsentwurf) + Flyer "Next-Level-Bausteine für KI", 2024/2025. AI-as-a-Service = Auftragsverarbeitung; Drittlandstransfer prüfen: https://www.lda.bayern.de/de/ki.html

• [197] LfDI Rheinland-Pfalz: Aktive KI-Prüfung im Gesundheitswesen — Auskunftsersuchen nach Art. 58 Abs. 1 lit. a DSGVO, März 2026. Erste dokumentierte Enforcement-Aktion KI + Gesundheitswesen: https://www.bublitzpeters.de/2026/03/12/datenschutzaufsicht-prueft-ki-einsatz-im-gesundheitswesen/

• [198] EDPB: Report on Coordinated Enforcement Framework — Use of cloud-based services by the public sector, 2023. 7 deutsche Landesbehörden beteiligt; nur 32 von 86 geprüften Stellen hatten DSFA vor Cloud-Einsatz durchgeführt: https://www.edpb.europa.eu/system/files/2023-01/edpb_20230118_cef_cloud-basedservices_publicsector_en.pdf

• [199] DSK: Positionspapier "Kriterien für Souveräne Clouds", 11. Mai 2023. Drittlandszugriffsrisiko muss ausgeschlossen sein; Open-Source-Basis empfohlen: https://www.datenschutzkonferenz-online.de/media/weitere_dokumente/2023-05-11_DSK-Positionspapier_Kritierien-Souv-Clouds.pdf

• [200] LfDI Baden-Württemberg: Empfehlungen zum Einsatz von KI-Anwendungen von Anbietern außerhalb der EU, 2025. Warnung vor KI-Anbietern ohne Art.-27-DSGVO-Vertreter; koordiniertes Verfahren gegen DeepSeek: https://www.baden-wuerttemberg.datenschutz.de/drittstaaten-ki/

• [201] BayLfD: Orientierungshilfe zum Gesundheitsdatennutzungsgesetz (GDNG), Januar 2026. §§ 5 und 6 GDNG und EHDS; Muster-Einwilligung:

https://www.datenschutz-bayern.de/infothek/OH_GDNG.pdf

• [202] HBDI / DGIM: Leitfaden für Datenschutz in der medizinischen Forschung, Dezember 2025. Vier Use Cases; Pseudonymisierung; föderierte Datenmodelle: https://datenschutz.hessen.de/sites/datenschutz.hessen.de/files/2025-12/20251028_dgim_hbdi_leifaden_datenschutz_1.01.pdf

• [203] BAS: Rundschreiben "Wesentliche Anforderungen an Cloud-basierte IT-Lösungen in der Sozialversicherung", 14. März 2018 (aktualisiert). Datenortung EU/EWR, AVV-Pflicht: https://www.bundesamtsozialesicherung.de/de/service/rundschreiben/detail/wesentliche-anforderungen-an-cloud-basierte-it-loesungen-in-der-sozialversicherung/

• [204] BAS: Digitalausschuss — Cloud Computing, KI und automatisierte Bearbeitung in der Sozialversicherung. Sondervereinbarung Microsoft; KI-Systeme zur Fehlverhaltensbekämpfung: https://www.bundesamtsozialesicherung.de/de/themen/digitalausschuss/ki-big-data-cloud-computing-und-automatisierte-bearbeitung/cloud-computing/

• [205] KBV: IT-Sicherheitsrichtlinie nach § 390 SGB V, verpflichtend ab Oktober 2025. Cloud-Apps nur mit C5; Microsoft-Cloud-Sync deaktivieren: https://www.kbv.de/html/it-sicherheit.php

• [206] KBV: PraxisWissen "Künstliche Intelligenz — Hinweise zum Einsatz in Praxen", 28. Mai 2025. KI = Cloud-Anwendung mit C5-Pflicht; Patienteneinwilligung bei KI-Transkription: https://www.kbv.de/documents/infothek/publikationen/praxiswissen/praxiswissen-ki.pdf

• [207] gematik: Impulspapier "Künstliche Intelligenz im Gesundheitswesen", Juli 2025. FHIR-Starter; KI für Datenstrukturierung: https://www.gematik.de/media/gematik/Medien/Telematikinfrastruktur/gematik_Impulspapier_KI_Juli_2025.pdf

• [208] BMG: C5-Äquivalenzverordnung Referentenentwurf, 6. Januar 2025. Definiert C5-äquivalente Sicherheitsstandards: https://www.bundesgesundheitsministerium.de/fileadmin/Dateien/3_Downloads/Gesetze_und_Verordnungen/GuV/C/C5-AequivalenzVO_RefE.pdf

• [209] DKG: Positionspapier "Nutzung von Künstlicher Intelligenz (KI) im Krankenhaus", 23. Oktober 2025. Cloud-Betrieb für KI als Notwendigkeit; KHZG 2.0 gefordert: https://www.dkgev.de/fileadmin/default/Mediapool/1_DKG/1.3_Politik/Positionen/2025-10-23_DKG-Positionspapier_KI_im_Krankenhaus.pdf

• [210] AWS: Lobbyregister Bundestag, Regelungsvorhaben RV0008560 — Lobbytätigkeit zu § 393 SGB V / Digital-Gesetz: https://www.lobbyregister.bundestag.de/inhalte-der-interessenvertretung/regelungsvorhabensuche/RV0008560/8636

Dieses Dokument basiert ausschließlich auf öffentlich zugänglichen Quellen, wurde mit Claude (Anthropic) erstellt. Version 22.0, April 2026. 210 Quellen. 19 Kapitel. Es stellt keine Rechtsberatung dar.